

DPIA on EduGenAI For SURF

Privacy Company,
Sjoera Nas and Jacob Gursky

Version	Date	Summary of changes
0.1	30 March 2025	First draft part A
0.2	18 April 2025	Revised draft part A after input SURF
0.3	11 May 2025	First complete draft, with track changes in part A.
0.4	28 May 2025	Revised complete report without track changes
0.5	17 Juni 2025	Revision with track changes after input SURF
0.6	17 Juni 2025	Completed clean draft
0.7	1 August 2025	Track changes after final check SURF
0.8	1 August 2025	Clean draft
0.9	7 August 2025	Public version, reformatted in Privacy Company housestyle

Summary

This report is a Data Protection Impact Assessment (DPIA) on the use of EduGenAI, an AI-system that provides access to multiple generative AI tools in a privacy friendly way.

EduGenAI is a web application that functions as a privacy proxy between users and different generative AI services. EduGenAI will offer multimodal access to both locally hosted large language models, and to cloud providers of generative AI-systems. EduGenAI also offers access to one or more search engines to 'update' the generated information.

Users can choose what AI-system they want to use to generate information, and switch, even during a prompt dialogue, while EduGenAI protects their privacy, and the rights of persons mentioned in the prompt dialogue, by applying a filter to mask personal data.

EduGenAI also offers 'Retrieval Augmented Generation' (RAG). This means users can upload their own documents to augment their prompts. Users can also create Personae with more permanent grounding, and share these Personae with other users, to share expert knowledge on a specific topic.

SURF

SURF (the collaborative organisation for IT in Dutch higher education and research) has commissioned this umbrella DPIA. For the EduGenAI service as described, SURF fulfils multiple roles. SURF develops and maintains the front-end of EduGenAI as a web application, the back-end hosting of the app, and the hosting of the large language models in SURF's AI-Hub.

Scope: EduGenAI as work-in-progress

EduGenAI will provide access to on-premises hosted LLMs (Llama from Meta, but also Mistral, DeepSeek and GPT-NL in the future), and to cloud LLMs such as the different OpenAI LLMs (as hosted on Azure by Microsoft), Llama, Mistral and Claude from Anthropic.

This DPIA primarily assesses the intended future situation where EduGenAI is hosted on SURF's infrastructure. While EduGenAI was originally developed as an application hosted on Microsoft Azure, this data processing is out of scope. However, because EduGenAI will offer access to cloud-based LLMs, this DPIA also assesses data transfer risks. The education organisations that use EduGenAI can decide whether they allow end-users to use cloud LLMs, such as OpenAI on Azure, or only access the on-premises LLMs.

This umbrella DPIA offers a preview of future functionality of EduGenAI, and of the mitigating measures, listed as 'development goals' in asides throughout this DPIA. SURF will update this DPIA after the launch of EduGenAI, but education organisations also have to conduct or document their own assessment for their intended use-cases, specifically for risks of bias, discrimination, fairness, and potential 'function creep' (unintended expansion of use) when using LLMs.

Privacy controls

EduGenAI is designed to implement many privacy by design and privacy by default measures. Some key planned highlights are:

1. Strip all metadata (IP-addresses, cookies, identifiers) from the user queries.
2. Apply a personal data masking filter to the contents of queries.
3. Allow the education organisations to determine what LLMs can be accessed (only on-premises, or also cloud LLMs).
4. Store the chat history by default on the end user device, and not centrally on SURF's servers.
5. Allow the education organisations to limit access to on-premises LLMs or EU based LLMs in case the EU US Data Privacy Framework is annulled.

DPIA process

Different from other DPIAs, Privacy Company has collaborated intensively with the developers from UvA/HvA and SURF to identify effective privacy preserving measures. Originally, EduGenAI was conceived as UvA chat by developers from UvA/HvA, hosted on Microsoft Azure. SURF has initiated a redesign and redevelopment of EduGenAI on SURF's own servers, reflecting the strong push for EU data sovereignty.

As required by the GDPR, a DPIA assesses the intended processing. As the redevelopment is work-in-progress, Privacy Company was not able to test if the proposed measures work as intended and are implemented in a correct way. Some measures and decisions, such as the development of an effective Responsible AI filter, have to be taken in close collaboration between SURF and the education organisations, and can only be taken after the service has been used for some time, and enough data are available for research. Only after these measures and development goals have been implemented, they can and will have to be tested in an update of this DPIA.

GDPR roles

SURF will offer a data processing agreement to the COs for 4 of the 5 identified categories of personal data: for the Account Data, the Diagnostic Data, the Support Data and the Website Data. However, for the processing of the Content Data through EduGenAI SURF and the COs are joint controllers. The reason EduGenAI was developed, is to provide privacy-friendly access to multiple LLMs (both on-premises and in third party clouds) and to enable users to ground their prompts in a transparent and controlled way, while preventing overreliance on AI. To achieve these central purposes of the processing of the Content Data, the COs have to take decisions about both the means and the purposes of the data processing, complementing the decisions already made by the EduGenAI developers.

Additionally, this DPIA identifies 5 purposes for which SURF necessarily has to act as independent data controller.

Outcome: 12 low data protection risks

The outcome of this DPIA is that, provided all development goals are effectively implemented and subsequently tested, SURF and the education organisations can take effective measures to lower or mitigate the identified 12 data protection risks. The recommended measures are listed in the (long) **table below**.

The risks are calculated by multiplying the probability of occurrence with the impact on end users if the risk were to materialise. However, if SURF and the education organisations apply the recommended measures, the probability of occurrence is zero or remote. The first 10 risks would cause serious harm to users. Risk no. 11 would cause some impact, while risk no. 12 would only have minimal impact. In all cases, when the impact is multiplied by the probability of occurrence, the outcome is a low risk.

No	Risk	Measures EduGenAI	AI-Hub	Measures COs
1.	Over reliance on EduGenAI	Apply the (on-premises) data masking filter to mask personal data before sharing prompts and RAG-documents with cloud LLMs and search engines. Allow users to disable this filter for Persona if necessary for specific tasks.	N/A	Decide when users can disable the personal data masking filter for Personae.
		Change the warning text about inherent inaccuracy risks to users every 30 seconds or every 10 prompts: different text, different font and colours etc.		Decide on the content and frequency of alerts presented to end users that they must verify the accuracy of an answer.
		Show two replies to a prompts from two different LLMs to visually remind users that they are not using a search engine, but a text completion engine.		
		Continue to show the snippets of text used by the AI-model when referring to sources uploaded by the user (RAG) (instead of referring to the entire document.		Inform users about the consequences if they change the default setting of a high reliability of the answers, by changing the 'Temperature' and TopP for Personae.
		Set the filter for reliability by default to a very high percentage. If no tokens can be found in the immediate vicinity, the AI-model will always answer 'I don't know'.		
		Develop and check the adequacy of a Responsible AI filter that complies with European Human Rights together with the COs. Allow COs to disable the content filter for specific tasks.		Perform a HRIA or FRAIA to assess risks for human rights in relation to the use of generative AI (such as bias/discrimination)
		Strip all metadata from prompts before sharing the prompts with third parties, only use a pseudo randomly generated trace ID per request (not per user). This step can assist users to look up more recent data in search engines without incurring new data protection risks.		
		Develop a procedure for end users and teachers to report inaccurate personal data relating to them.		
2.	Inability to exercise data subject access	Implement a dedicated contact method for data subject questions and requests from users.	Allow CO admins to export their personal activity data.	Inform end users about the logging and how to request access to their Diagnostic Data.

	rights Diagnostic Data		Prevent logging of the username of the API key owner.	
		Implement a Download Your (Diagnostic) Data tool.	Develop a user friendly way to know whom to contact in the case of errors.	
			Create dashboards with benchmarks for the COs to show many tokens they have used, or what the environmental impact was.	
3	Inability to correct inaccurate Content Data	Apply the measures to prevent overreliance on AI, to lower the probability that inaccurate personal data are blindly copied.	N/A	Inform users about the procedure to request correction of personal data relating to them.
		Ask users for consent to centrally store their chat histories, and separate consent to use the pseudonymised chat histories for accuracy and quality research.		Allow users to request review and potential deletion of Personae that process inaccurate personal data relating to them.
		Forward reports about inaccurate data to the LLM providers, and agree on a procedure with the LLM providers that they prevent regeneration of reported inaccurate personal data.		Set standards what type of documents and data can be used for grounding.
		Perform quality and accuracy research with the COs, and develop guidance on the best type of model for specific tasks.		Inform users about procedure to report inadequate masking.
		Implement additions to the content filter that consist of the following set of escalating steps for a given scenario: 1. Add corrections in the system prompt 2. Add a filter process to remove incorrect data 3. Fine-tune models to correct inaccurate data.		
		Create a procedure for end users to report inadequate masking.		
4	Loss of control through overreliance on personal data masking filter	Perform research on the effectivity of the (locally hosted) Presidio data masking filter: consider the use of other tools.	N/A	Adopt a policy to prevent the processing of sensitive and special categories of personal data in RAG-documents if not necessary for research purposes.
		Enable COs to upload documents, disable the data masking filter for specific tasks, and get access to the filtered chunks in human-readable form.		Adopt a policy to prevent the processing of sensitive and special categories of personal data in RAG-documents if not necessary for research purposes.

		Enable COs to tweak the filter, relating to the typical data they process which may not be adequately recognised by the data masking filter.		Adopt a policy to prevent the processing of sensitive and special categories of personal data in RAG-documents if not necessary for research purposes. Help SURF improve the adequacy of the Presidio filter based on research on the COs own filtered chunks.
		Publish guidance for the COs about mistakes the filter can make, based on the research.		
		Work with the COs to develop documentation and settings for the masking filter.		Work with SURF to develop documentation and settings for the masking filter.
				Use future options to tweak the filter
5	Loss of control due to aggressive personal data masking filter	Take the relevant measures to prevent overreliance on AI (especially the first 3).	N/A	Draft a policy when users can disable the content filter for specific Personae.
		Develop a content filter with the COs that fully respects European Human Rights.		Draft a policy when users can disable the content filter for specific Personae.
6	Loss of control due to content filtering (LLMs and EduGenAI)	Make the content filtering as transparent as possible, without inviting gamification.	Be responsive to requests to disable content filtering where relevant.	Help SURF develop the content filter based on regular quality and accuracy measurements.
		Allow users to disable the content filter per Persona.		Select locally hosted models as the default for the CO.
		Develop a content filter that respects European human rights with the COs.		Select locally hosted models as the default for the CO.
7	Unauthorised access to Content Data by cloud LLMs and search engines	Select locally hosted models as the default for the CO.	Add more on-premises open source models (next to Llama).	Select an EU-based LLM if the quality of the local LLMs for the Dutch language is not high enough.
		By default store the chat history in the browser of the user, unless users consent to storage on SURF's servers.	Enable COs to choose to send requests to embedding endpoints to on-premises models.	Help SURF develop a content filter that respects European human rights
			Convert documents into embeddings on-premises.	Determine a retention policy for Personae and associated RAG-documents (SURF will delete after 13-24 months inactivity).
		Implement RAG without the use of third party services by sending embeddings back to COs to manage text search themselves, and compute embeddings with on-premises LLMs.	Use a local instance of a personal data masking filter (such as the open source Presidio) for the removal of personal data from prompts and uploaded documents	Determine a retention policy for Personae and associated RAG-documents (SURF will delete after 13-24 months inactivity).
		Choose privacy friendly search engines such as Ecosia, DuckDuckGo	Add access to GPT-NL when	Determine a retention policy for Persona and associated RAG-documents.

		or in the future eu-searchperspective.com.	available and affordable.	
			Locally host the content filter.	
8	Loss of control through unspecified retention periods	Ask users for consent to centrally store their chat histories, and separate consent to use the pseudonymised chat histories for accuracy and quality research.	Store the CO-admin logs with the IP-addresses for 30 days.	Help SURF as joint controller to Develop a specific EduGenAI privacy policy for users (admins, teachers and students).
		Determine an adequate retention period for the pseudonymised chat histories for research purposes.		Help SURF as joint controller to Develop a specific EduGenAI privacy policy for users (admins, teachers and students).
		Determine the retention period for RAG-documents uploaded to Personae (13-24 months inactivity)		Help SURF develop a EULA and/or Acceptable Use Policy to warn students not to use the tool for unlawful purposes, and warn about for example rate or size limitations
		If cookies are used to store the chat history: decide on the expiry date of cookies and inform users.		
		Implement specific retention periods for support tickets, the storage of the feedback 'likes', and the logs with Diagnostic Data about user activities (30 or 90 days).		
		Include procedure in the data processing agreement how SURF will deal with requests for disclosure from government authorities.		
9	Loss of control through processing by SURF as controller	Publish statistics about requests for compelled disclosure, and how many requests were granted.	Implement encryption at rest of the database that contains RAG-documents in such a way that each CO has its own privacy encryption keys.	Help SURF develop a EULA and/or Acceptable Use Policy to warn students not to use the tool for unlawful purposes, and warn about for example rate or size limitations.
		Document what personal data SURF processes as controller, with retention periods.		Help SURF develop a EULA and/or Acceptable Use Policy to warn students not to use the tool for unlawful purposes, and warn about for example rate or size limitations.
		Help the COs draft privacy policy, AUP and copyright policy as joint controller		Perform a Data Transfer Impact Assessment if the EU US DPF is invalidated.
		Anticipate on the invalidation of the EU US Data Privacy Framework with regard to OpenAI's language models on Azure, and Claude from Anthropic. This extends to the use of any LLM hosted on infrastructure owned by an American company. Alert the COs to the option to restrict access to LLMs hosted within or by entities from non-adequate third countries, should the transfer mechanisms be invalidated.		Educate users about the downsides of browser storage of the chat history.
10	Loss of control by unauthorised access in third countries	Anticipate on the invalidation of the EU US Data Privacy Framework with regard to OpenAI's language models on Azure, and Claude from Anthropic. This extends to the use of any LLM hosted on infrastructure owned by an American company.	Make a locally hosted LLM or EU-based provider the default choice.	Perform a Data Transfer Impact Assessment if the EU US DPF is invalidated.
				Educate users about the downsides of browser storage of the chat history.

		Alert the COs to the option to restrict access to LLMs hosted within or by entities from non-adequate third countries, should the transfer mechanisms be invalidated.		
11	Loss of control through lack of backups / data portability	Inform new users about the trade-offs between cloud and local storage, and the option to change the storage location on a chat by chat basis. Warn users about the possible negative consequences of the default choice to only store the chat history on their own device. Offer a simple way for end users to export and import the chat history from their own device. Allow users to decide, per chat, which chats are stored in the SURF cloud and which are stored on their own device. Explore and implement alternatives to cookies for local storage, such as PGLite, to enhance data portability and user control over backups Encrypt the contents of the chat storage cookies.	N/A	Educate users about the downsides of browser storage of the chat history. Determine appropriate retention periods for Personae with their RAG-documents. Determine appropriate retention periods for Personae with their RAG-documents.
12	Loss of control due to orphan RAG-documents	Explore alternatives to for local storage of RAG documents and vector embeddings, such as PGLite.	Offer a delete endpoint for documents that EduGenAI can call.	N/A

Conclusions

If SURF and the COs effectively implement all the recommended measures, which include the successful realisation and thorough testing of the numerous development goals outlined in this document, there are no more known high risks related to the data processing via EduGenAI. As EduGenAI is a work-in-progress, this initial DPIA will have to be updated after the launch.

Introduction	12
PART A	19
1 Introduction	20
2 The processing of personal data	20
2.1 EduGenAI	20
2.2 Five categories of personal data	41
3 Legal: personal data and enrolment framework	42
3.1 Definition of personal data	42
3.2 Categories of personal data in the Content Data	42
3.3 Possible categories of data subjects	46
3.4 Future SURF enrolment framework	46
3.5 Terms of search engines	47
4 Technical findings	47
4.1 Content data	48
4.2 Account Data	50
4.3 Diagnostic Data	51
4.4 Support Data	56
4.5 Website Data	56
4.6 Data Subject Access	56
5 Privacy Controls for COs	62
5.1 Choice of LLM	62
5.3 Determining retention periods	63
6 Purposes of the processing	63
6.1 Purposes EduGenAI	63
6.2 Purpose SURF (Hosting)	66
7 Processor or (joint) controller	68
7.1 Definitions	68
7.2 Education organisations as data controllers	69
7.3 SURF as data processor	69
7.4 SURF and the education organisations as joint controllers	71
7.5 SURF as independent data controller	73
7.6 Roles of LLMs and search engines	75
8 Interests in the data processing	76
8.1 Interests SURF	76
8.2 Interests education organisations	77
9 Transfer of personal data outside of the EU	79
9.1 Locations OpenAI on Microsoft Azure	79
9.2 GDPR rules for transfers of personal data	89
10 Techniques and Methods of the Data Processing	90
10.1 Components of trained LLMs	90

10.2	LLMs and personal data.....	92
11	<i>Additional legal obligations</i>	94
11.1	Digital Sovereignty	95
11.2	ePrivacy Directive	95
12	<i>Retention Periods</i>	96
12.1	Chat history	97
12.2	RAG-documents, chunks and vector-embeddings	97
12.3	Logs SURF AI-Hub	97
12.4	Logs SURF EduGenAI	97
PART B		98
13	<i>Introduction</i>	99
14	<i>Legal Grounds</i>	99
14.1	Legal grounds for education organisations	102
14.2	Legal grounds for SURF as independent data controller	105
15	<i>Special categories of personal data</i>	106
16	<i>Purpose limitation</i>	107
17	<i>Necessity and proportionality</i>	108
17.1	The concept of necessity	108
17.2	Assessment of the proportionality	109
17.3	Assessment of the subsidiarity	115
18	<i>Rights of data subjects</i>	117
18.1	Right to information	117
18.2	Right to access	117
18.3	Right of rectification and erasure	119
18.4	Right to object to profiling	119
18.5	Right to data portability	119
18.6	Right to file a compliant	120
PART C		121
19	<i>Introduction</i>	122
20	<i>Risks</i>	122
20.1	Identification of risks	122
20.2	Assessment of risks	123
PART D		134
21	<i>Introduction</i>	135
22	<i>Risk mitigating measures</i>	135
22.1	Measures to be taken to mitigate risks	135
22.2	Conclusions	139

Introduction

This DPIA was commissioned by SURF (the collaborative organisation for IT in Dutch higher education and research). SURF has multiple roles in this DPIA. SURF develops and maintains the front-end of EduGenAI as a web application, the back-end hosting of the app, and the hosting of the large language models in SURF's AI-Hub. SURF is also a spokesperson for Npuls.

EduGenAI

This DPIA analyses the data processing through EduGenAI, an AI-system that provides access to multiple generative AI tools in a privacy friendly way.

EduGenAI is a web application that functions as a privacy proxy between users and different generative AI services. EduGenAI will offer multimodal access to both locally hosted large language models, and to cloud providers of generative AI-systems.

Users can choose what AI-system they want to use to generate information, and switch, even during a prompt dialogue, while EduGenAI protects their privacy, and the rights of persons mentioned in the prompt dialogue, by applying a filter to mask personal data.

EduGenAI also offers 'Retrieval Augmented Generation' (RAG). This means users can upload their own documents to augment their prompts. Users can also create Personae with more permanent grounding, and share these Personae with other users, to share expert knowledge on a specific topic. In the future, EduGenAI will also offer integration with Learning Management Systems such as Canvas, Blackboard or Moodle.

Originally, EduGenAI was conceived as UvA chat by developers from Uva/HvA, hosted on Microsoft Azure. SURF has initiated a redesign and redevelopment of EduGenAI on SURF's own servers, with the engineers from SURF that manage the SURF AI-Hub, reflecting the strong push for EU data sovereignty.

The scope of this DPIA is limited to the personal data processed in and about the use of EduGenAI. Currently the choice for end users is limited to 1 on-premises hosted LLM (Llama from Meta), and to multiple cloud LLMs from OpenAI (as hosted on Azure by Microsoft), Meta and Mistral. However, the project team is working on expansion with different on-premises LLMs such as Mistral, DeepSeek and GPT-NL (when that LLM becomes available), as well as access to LLMs offered by other cloud providers, such as Claude from Anthropic. The underlying proxy mechanism will remain the same. This DPIA analyses the future situation, with both the front-end and the back-end managed by SURF.

SURF AI-Hub

The SURF AI-Hub is hosted in a SURF data centre in the Watergraafsmeer in Amsterdam. The hosting is not limited to AI for education purposes.

Npuls

Npuls is a multi-million government investment program with investments into the use of AI in Education in the Netherlands. SURF is the spokesperson for Npuls, and has the following tasks:

- Developing use cases for AI in education
- Alignment with other digital transformation initiatives
- Knowledge sharing and best practices
- Coordination between different Education organisations
- Monitoring implementation and effectiveness

Education organisations (COs)

If an MBO, HBO or university decides to use EduGenAI, it will become a Collaborating Organisation (CO). This DPIA either uses the term 'education organisation' or 'CO'.

DPIA

Under the terms of the General Data Protection Regulation (GDPR), an organisation may be obliged to carry out a data protection impact assessment (DPIA) for new, intended forms of data processing. The GDPR mentions criteria when a DPIA is required, for instance where it involves large-scale processing of personal data. The assessment is intended to shed light on, among other things, the intended specific processing activities, the inherent risk to data subjects, and the safeguards applied to mitigate these risks. The purpose of a DPIA is to ensure that any risks attached to the process in question are mapped and assessed, and that adequate safeguards can be implemented to mitigate those risks.

A DPIA used to be called PIA, privacy impact assessment. According to the GDPR a DPIA assesses the risks for the rights and freedoms of individuals. Data subjects have a fundamental right to protection of their personal data and some other fundamental freedoms that can be affected by the processing of personal data, such as freedom of expression.

The right to data protection is therefore broader than the right to privacy. Consideration 4 of the GDPR explains:

"This Regulation respects all fundamental rights and observes the freedoms and principles recognised in the Charter as enshrined in the Treaties, in particular the respect for private and family life, home and communications, the protection of personal data, freedom of thought, conscience and religion, freedom of expression and information, freedom to conduct a business, the right to an effective remedy and to a fair trial, and cultural, religious and linguistic diversity".

This DPIA follows the structure of the DPIA Model mandatory for all Dutch government organisations.¹

¹ In Dutch only: Rapportagemodel DPIA Rijksdienst, 3.0, 25 July 2023, URL: <https://www.kcbr.nl/sites/default/files/2023-08/Rapportagemodel%20DPIA%20Rijksdienst%20v3.0.docx>.

SURF general DPIA versus individual DPIAs by education organisations

Pursuant to article 35 of the GDPR, a DPIA is mandatory if an intended data processing constitutes a high risk for the data subjects whose personal data will be processed. The Dutch Data Protection Authority (Dutch DPA) has published a list of 17 types of processing for which a DPIA is always mandatory in the Netherlands.² If a processing is not included in this list, an organisation must itself assess whether the data processing is likely to present a high risk.

The European national supervisory authorities (hereinafter referred to as the Data Protection Authorities or DPAs), united in the European Data Protection Board (EDPB) have also published a list of nine criteria.³ As a rule of thumb if a data processing meets two of these criteria a DPIA is required.

In GDPR terms SURF has different roles for parts of the data processing, both as processor and as (joint) data controller with the education organisations that will offer EduGenAI to their students and employees (COs).

Different from other DPIAs, Privacy Company has collaborated intensively with the developers from UvA/HvA and SURF's AI Hub to identify effective privacy preserving measures. Originally, EduGenAI was conceived as UvA chat by developers from UvA/HvA, hosted on Microsoft Azure. SURF has initiated a redesign and redevelopment of EduGenAI on SURF's own servers, reflecting the strong push for EU data sovereignty.

As the redevelopment is work-in-progress, Privacy Company was not able to test if the proposed measures work as intended and are implemented in a correct way. Some measures, such as the development of an effective Responsible AI filter, have to be taken in close collaboration between SURF and the education organisations, and can only be assessed after the service has been used for some time, and enough data are available for research.

This DPIA only describes the data processing which SURF can access and/or control, but not the specific data processing controlled by the COs and the end users. Only the organisations themselves can assess the specific data protection risks, relating to the nature of the Content Data they use EduGenAI for, and for example, the retention periods of Personae. The current DPIA serves as an initial assessment. A subsequent version of this DPIA will be necessary once these measures are fully operational and tested through practical use. Only the COs themselves can assess the specific data protection risks, relating to the nature of the Content Data for which they use EduGenAI, (for example, the retention periods of Personae).

² Dutch DPA, list of processings for which a DPIA is required, in Dutch only, Besluit inzake lijst van verwerkingen van persoonsgegevens waarvoor een gegevensbeschermingseffectbeoordeling (DPIA) verplicht is, URL: <https://autoriteitpersoonsgegevens.nl/sites/default/files/atoms/files/stcrt-2019-64418.pdf>.

³ The EDPB has adopted the WP29 Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing is "likely to result in a high risk" for the purposes of Regulation 2016/679, WP248rev.01, 13 October 2017, URL: https://ec.europa.eu/newsroom/article29/item-detail.cfm?item_id=611236.

Criteria EDPB

Pursuant to Article 35 GDPR, data controllers are obliged to conduct a DPIA if the processing meets two, and perhaps three of the nine criteria set by the European Data Protection Board (EDPB), or if it is included in the list of criteria when a DPIA is mandatory in the Netherlands.

The circumstances of the data processing via EduGenAI meet four out of the nine criteria defined by the EDPB:⁴

1. Innovative use or applying new technological or organisational solutions (criterion 8). The EDPB explains: *"This is because the use of such technology can involve novel forms of data collection and usage, possibly with a high risk to individuals' rights and freedoms."*⁵
2. Sensitive data or data of a highly personal nature (criterion 4). The EDPB explains: *"some categories of data can be considered as increasing the possible risk to the rights and freedoms of individuals. These personal data are considered as sensitive (as this term is commonly understood) because they are linked to household and private activities (such as electronic communications whose confidentiality should be protected)."*⁶
3. While the audit logs about the use of EduGenAI are neither designed, nor marketed as a tool for behaviour monitoring, there is a possibility that the logs available for the administrators of SURF and the COs can be used for systematic observation of the behaviour of employees (criterion 3); and
4. The processing involves data relating to vulnerable data subjects (criterion 7). Both employees and students whose personal data are processed through EduGenAI are in an unequal relationship of power with the education and research organisations. This also includes external people whose data are generated through use of EduGenAI, for example job applicants whose resumes may be summarised and preselected with the help of EduGenAI.⁷

Criteria Dutch Data Protection Authority

SURF receives many requests for GDPR-compliant use of generative AI services from Dutch education organisations. SURF has already commissioned a DPIA on the use of Microsoft 365 Copilot.⁸ If education organisations start to use EduGenAI, the data processing will take place on a large scale. The data processing also involves data about communication (both content or metadata) and involves data that can

⁴ Dutch DPA, list of processings for which a DPIA is required, in Dutch only, Besluit inzake lijst van verwerkingen van persoonsgegevens waarvoor een gegevensbeschermingseffect-beoordeling (DPIA) verplicht is, published in the Staatscourant (Dutch University Gazette) of 27 November 2019, URL: <https://autoriteitpersoonsgegevens.nl/sites/default/files/atoms/files/stcrt-2019-64418.pdf>.

⁵ Idem.

⁶ Ibid.

⁷ EDPB adopted Guidelines on Data Protection Impact Assessment (DPIA) (wp248rev.01), 13 October 2017, URL: http://ec.europa.eu/newsroom/document.cfm?doc_id=47711.

⁸ Privacy Company for SURF, DPIA on Microsoft 365 Copilot, 17 December 2024, URL: <https://www.surf.nl/files/2024-12/20241218-dpia-microsoft-365-copilot.pdf>.

be used to track the activities of employees. Therefore, based on the criteria published by the Dutch DPA,⁹ it is mandatory for organisations in the Netherlands to conduct a DPIA.

The Dutch Data Protection Authority mentions the processing of communications data as specific criterion when a DPIA is mandatory:

*"Communications data (criterion 13). Large-scale processing and/or systematic monitoring of communications data including metadata identifiable to natural persons, unless and as far as this is necessary to protect the integrity and security of the network and the service of the provider involved or the end user's terminal equipment."*¹⁰

Out of scope

This DPIA is limited to the data processing by SURF and the COs as a result of the specific use of EduGenAI.

This DPIA does not include:

- Testing of the quality and accuracy of the answers generated by the different local and cloud LLMs, including the data processing by Microsoft about the use of different OpenAI models hosted in a private Azure tenant. Different from Microsoft 365 Copilot, with Azure OpenAI customers can exercise more control over the LLM.
- Data processing by Microsoft as a result of the current hosting of EduGenAI in the Microsoft Azure public cloud. Once SURF is able to launch this service for use by the education organisations, the data processing will take place in SURF's own data centre, and in SURF's AI-Hub.
- An analysis of the efficacy of the tool(s) used to strip personal data from user queries.
- Use of EduGenAI by children under 16 years. SURF will provide access to MBO, HBO and universities. MBO-students are 16 years and older.
- Other necessary services provided by SURF such as the identity and access management service SRAM¹¹ and SURF Conext¹².
- Future integration with Learning Management System (LMS/LTI) integration.
- An analysis of the APIs to be created for researchers and batch requests and resulting data processing.
- Image generation by the LLMs¹³

Because key features of EduGenAI, such as personal data stripping, or the accuracy of personal data generated by the different LLMs, could not be tested, COs and SURF will have to build some experience

⁹ Dutch DPA, list of data processing for which a DPIA is required.

¹⁰ Idem.

¹¹ SURF Research Access Management (SRAM) Privacy Policy, 3 March 2021, URL: <https://servicedesk.surf.nl/wiki/spaces/IAM/pages/74226131/Privacy+Policy>.

¹² SURFconext, URL: <https://www.surf.nl/en/services/identity-access-management/surfconext>.

¹³ This will be a feature of EduGenAI when launched.

with the service, and perform quality and accuracy research. They may also want to perform dedicated technical audits and/or Human Rights Impact Assessments.

Research

To collect factual information about the data processing by EduGenAI, Privacy Company organised a day-long friendly audit with the team of developers chaired by UvA HvA IT manager Rik Jager, AI product manager Paul Jansen of the SURF AI-Hub, members of SURF's procurement team, SURF technologists, a SURF Privacy Officer and the SURF spokesperson for Npuls.

Privacy Company asked Rik Jager and team during the audit to explain, draw, and where possible show, all relevant types of data processing. EduGenAI provided additional requested paper documentation, such as logging schemas, data processing agreements and examples of SURF's own Security Incident and Event Management (SIEM) logs on 26, 27 and 31 March 2025.

In follow-up discussions and e-mail exchanges in April and May 2025, the developers provided additional information and screenshots.

Timeline of this DPIA

This data protection impact assessment was carried out by Privacy Company as commissioned by SURF between 20 March 2025 and 28 May 2025. It builds on previous DPIAs on cloud services for SURF, notably the Microsoft 365 Copilot DPIA for the description of the components of a genAI service.

Outline

This Data Protection Impact Assessment assesses the use of EduGenAI by SURF and by Dutch education organisations.

The Dutch government DPIA-model uses a structure of four main divisions, which are reflected here as 'parts'.

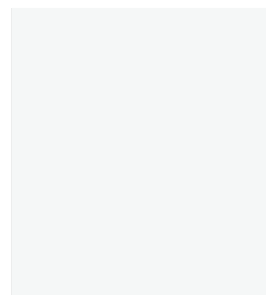
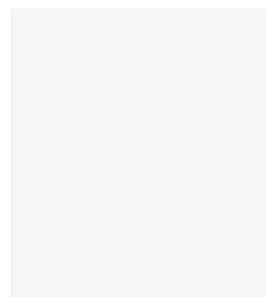
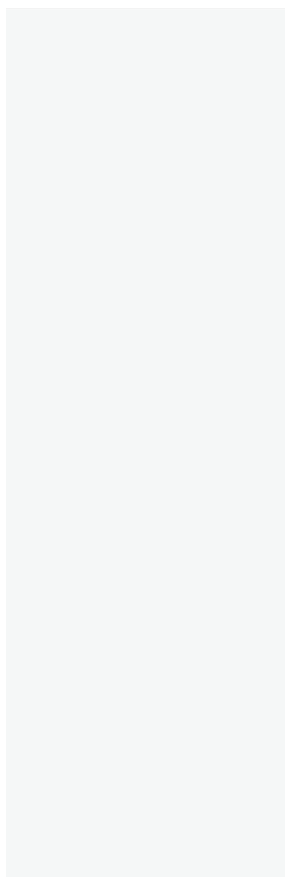
- A. Description of the factual data processing
- B. Assessment of the lawfulness of the data processing
- C. Assessment of the risks for data subjects
- D. Description of mitigation measures

Part A explains the tested elements of EduGenAI. This part starts with a description of the way EduGenAI works, and how the different components interact. This section describes the categories of personal data and data subjects that may be included in the processing; the purposes of the data processing; the different roles of the involved parties; the different interests related to this processing; the locations where the data are and will be processed, and the retention periods. Part A also lists the relevant legal documents that govern the data processing resulting from the use of EduGenAI and addresses the applicability of the ePrivacy Directive.

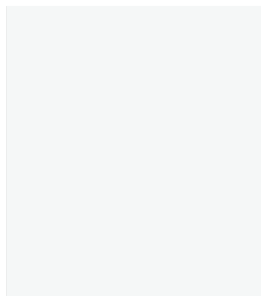
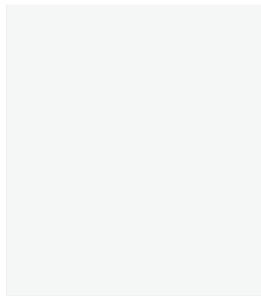
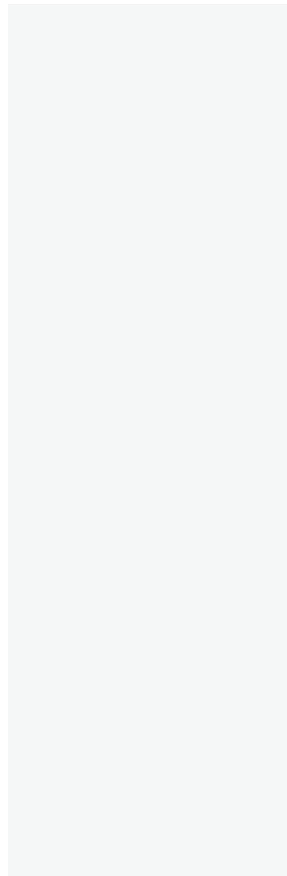
Part B provides an assessment of the lawfulness of the data processing through EduGenAI. This analysis starts with an assessment of the conformity with the key principles of data processing, starting with the legal ground for the processing and the necessity and proportionality of the processing. This part continues with an analysis of compliance with purpose limitation, as well as transparency and data minimisation. In this section the legitimacy of any transfers of personal data to countries outside of the (European Economic Area (EEA) is separately addressed, as well as an analysis how SURF treats requests from data subjects to exercise their rights.

Part C assesses the risks to the rights and freedoms of the data subjects caused by the processing activities identified in Part A of this DPIA. It names specific risks resulting from the data processing and aims to specifically determine both the likelihood that these risks may occur, and the severity of the impact on the rights and freedoms of the data subjects if the risks occur.

Finally, **Part D** contains the mitigating measures that can be taken by either SURF or the individual education organisations to mitigate high or low risks. These measures are generally aimed at reducing the probability that a risk occurs. This can mitigate a risk, even if the impact were very high.



PART A



1 Introduction

This first part of the DPIA provides a description of the data processing through EduGenAI, a privacy preserving web application that enables users to access multiple generative AI-services, both locally hosted by SURF, and offered as a cloud service by third parties.

2 The processing of personal data

2.1 EduGenAI

EduGenAI is developed as a privacy preserving AI-system. It functions as a proxy between users and generative AI services, with access to several locally hosted Large Language Models (LLMs) hosted in the SURF AI-Hub in Amsterdam, and cloud LLMs. EduGenAI also offers access to one or more search engines to 'update' the generated information.

End users can access EduGenAI via their browser. On the server side, the metadata relating to the user (account data from SURF, IP address and session cookies) are stripped from the prompt before the prompt is shared with an LLM.

One of the key benefits of EduGenAI is that it will apply a personal data masking filter to prompts before sharing the prompts with the cloud LLMs, including personal data mentioned in uploaded documents.

EduGenAI was developed by two IT specialists from the UvA/HvA as UvA AI Chat. University magazine Folia published an interview with two of the creators, Rik Jager and Danny van den Berg.¹⁴ UvA AI Chat was developed on Microsoft Azure. This means all prompts and replies are stored in a database on Azure.

This DPIA only assesses the future situation, where all data processing takes place in the SURF datacentre in Amsterdam. This (new) AI-system is designed to have the memory stored in the on-premises web application (and not stored by commercial third parties that offer access to language models, such as Microsoft does for access to the different OpenAI models).

The web app memory allows users to switch between LLMs during a chat session. The web app remembers the history and instructions about the tone of voice. So if a user starts with the prompt "*Provide substantive, scientific arguments why the earth is not flat, with references to reliable sources*" in ChatGPT 4.0, the user can continue in a second LLM, like Mistral, to ask to restructure the answer by giving more weight to sources 3 and 4 mentioned in the first reply.

¹⁴ Folia, UvA created its own ChatGPT for students and teachers. Is it safer than the original?, 11 February 2025, URL: <https://www.folia.nl/en/actueel/164740/uva-created-its-own-chatgpt-for-students-and-teachers-is-it-safer-than-the-original>.

Typically, when using an online LLM service, the chat history and custom instructions are saved on the LLM provider's database servers. Every time a new message is sent to the LLM via the web interface, the back-end logic automatically sends the chat history (up to the token limit) to the LLM.

Thus, every time the LLM gets a request from the user, it receives with the chat history, instructions, filters, etc. as well. That's how it can determine the context.

The EduGenAI service can switch between models because of this fundamental 'local storage' characteristic of LLMs. It simply sends the chat history to the new LLM when a different model is selected. Just like it does every time any model is called.

EduGenAI interacts with the AI-Hub by contacting the API for real-time answers needed for direct feedback, like chat assistants.

In the future, the AI-Hub will also offer a batch API, to handle complex queries using big and expensive models. These queries can be queued to spread the load over time, especially during workdays and daytime when demand for models is high. The (future) batch API will typically be used by researchers, but is out of scope of this DPIA.

EduGenAI includes two types of *grounding* (or *Retrieval Augmented Generation*). A user can upload one or more documents with each prompt, for example to ask 'Create a summary'. Users can also create and share a Persona that includes multiple uploaded documents. For example, all documents relating to a specific course topic. A typical use case considered by the developers for the creation of a Persona was a question from a medical faculty to provide feedback on a thesis. A Persona is a reusable set of instructions and reference documents that make the responses from an LLM more suited to specific contexts.

Users can upload files in csv, xls, pdf, pptx, docx. In the near future, users will also be able to upload video and audio files in formats mp4, mpeg, mpga, m4a, wav, and webm.¹⁵ They will also be able to generate images through EduGenAI.

EduGenAI is not designed as an alternative for Microsoft Copilot. There is no app for installation on an end user device, and there is no integration with typical Office services such as Word or Teams.

Though EduGenAI can prompt for information from audio recordings, it cannot create a summary of a recorded meeting, or draft e-mails within an e-mail client.

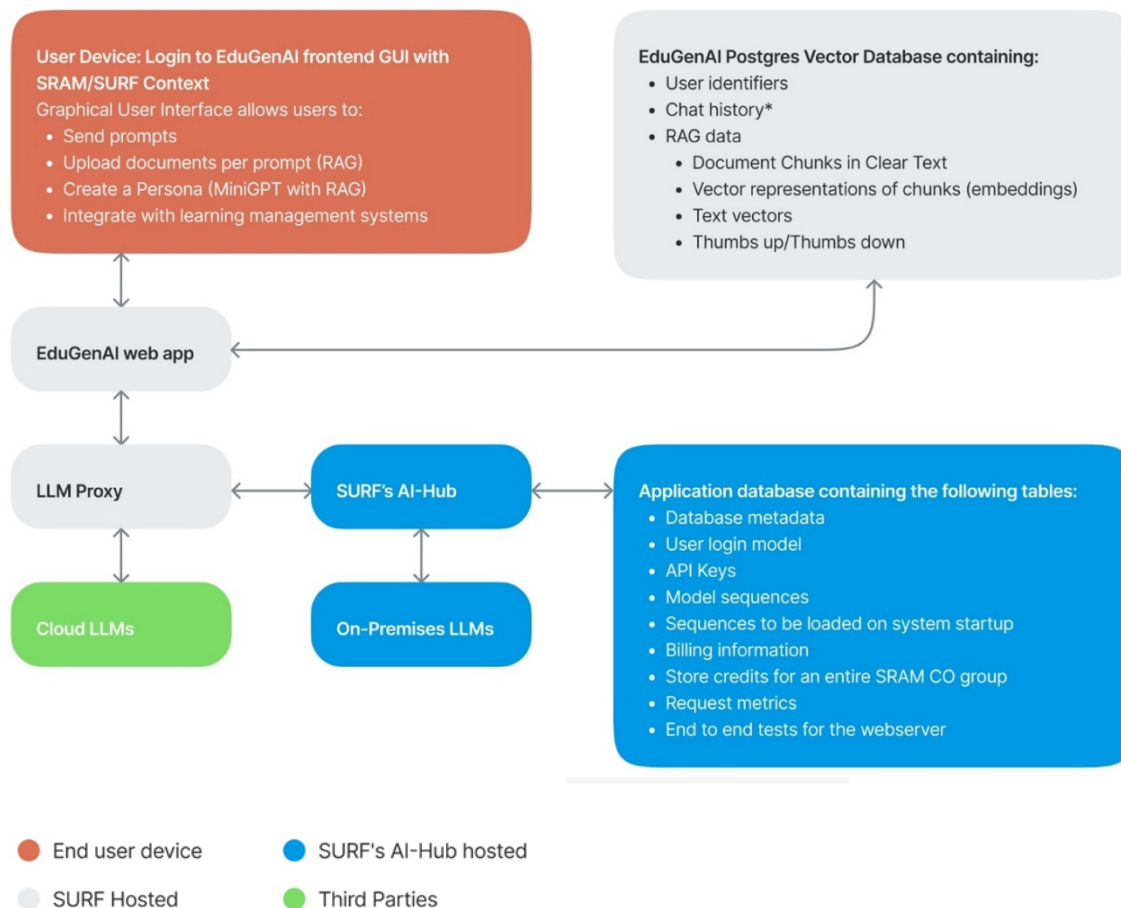
While using EduGenAI, users perform the following actions:

1. A user can change the default LLM (currently set to GPT 4.o).
2. The user enters a prompt in the web app. The web app is currently hosted on Microsoft Azure, but will be hosted in a Kubernetes docker environment by SURF from September 2025 onwards.

¹⁵ These are the audio formats supported by OpenAI's Whisper, URL: <https://help.openai.com/en/articles/7031512-whisper-audio-api-faq>. The EduGenAI developers aim to add more document formats, such as markdown.

- See [Section 5.2](#) for a description of SURF's responsibilities as the hosting provider for the web application.
3. A user can use RAG / grounding by uploading files. EduGenAI first extracts text from these files, divides the text into chunks, and then turns these chunks into vectors for the purposes of text search. Vector embeddings are a way to convert words and sentences into numbers that capture meaning and relationships. Documents can be uploaded per prompt or permanently as part of Personae. See [Section 1.1.4](#) for a description of data processing in relation to the RAG/grounding process and [Section 1.1.9](#) for a description of data processing in relation to the Personae.
 4. EduGenAI strips the metadata about the individual user from the prompt, and will also apply a filter to strip personal data from the content supplied through RAG, such as names, social security numbers, bank account and credit card numbers. The filter only 'attempts to' strip these data. As with any machine learning model, it might make mistakes and miss information.
 5. The prompt is sent to the chosen LLM (either as cloud service from a third party or on SURF's AI-Hub), with parameters and the relevant snippets from uploaded documents along with the API Key. One of the parameters is a similarity check (to prevent hallucinations). See [Section 1.1.3](#) for a explanation about the meta prompts, and [Section 1.1.9](#) for an explanation about the temperature and TopP in Personae.
 6. EduGenAI displays a reply.

Figure 1: Main elements of the (future) EduGenAI data processing



The developers from the UvA/HvA work on two strategies: the EduGenAI AI-system (i) as currently hosted in Microsoft Azure, with access to cloud LLMs, to be managed by large education organisations themselves, and (ii) the EduGenAI frontend managed by SURF using the kubernetes cluster in combination with the AI-Hub backend also hosted in SURF's datacentre in the Watergraafsmeer. As the (current) hosting of EduGenAI on Microsoft Azure is a temporary solution, this DPIA only addresses the second future scenario. SURF expects to be able to gradually release the tool starting 1 September 2025. To help finetune the privacy settings, SURF commissioned this DPIA prior to the actual realisation. The planned changes for the 1 September 2025 release and beyond are highlighted in this report as *"EduGenAI Development Goals"*. Privacy Company assesses the privacy implications of these goals 'on paper', without having been able to test if the 'paper' processing complies with the design.

2.1.1 Large Language Models

To understand how LLMs process data it is essential to understand that they are completely different from search engines. Large Language Models do not 'retrieve' an answer from memory but predict the next series of words that are statistically most likely to belong to the text provided in the input.¹⁶

LLMs are also non-deterministic. LLMs generate the next word based on mathematical formulae. As such, it is a deterministic process. What makes LLMs non-deterministic in practice is the randomness implemented in their outputs. However, if the same inference is run against the same step of the same seed value, the output will always be the same, regardless of temperature setting.

LLMs are trained with huge amounts of data such as text and images. The text in the training data is changed into vectors, a type of numeric coordinate in space, and the LLM generates a reply by retrieving the next vector most close in space to the word or few words before.

EduGenAI provides access to the following LLMs:

Currently supported (cloud) AI-models

- OpenAI models:
 - gpt-4
 - gpt-4o
 - gpt-4o-mini
 - gpt-3.5-turbo
 - gpt-4-turbo
 - gpt-4o-2024-08-06 01-preview
 - o3-mini
 - gpt-4.1
 - gpt-4.1-nano
 - mistral-small-2503

¹⁶ Microsoft, Prompt engineering techniques, section Basics, 2 October 2024, URL: <https://learn.microsoft.com/en-us/azure/ai-services/openai/concepts/prompt-engineering>.

- llama 3.3-70b-instruct
 - Whisper speech to text.
- Llama
 - Llama-3.1-70b-instruct
 - Llama-3.1-8b-instruct
 - Llama-3-8b-instruct
- Mistral Large 2411

Currently, EduGenAI only offers access to cloud API endpoints of open source or proprietary LLMs, but this DPIA assesses the future situation where additional LLMs are hosted on-premises by the SURF AI-Hub. Some of these on-premises models will only be available for batch requests.

If a user does not select a model before the initial prompt, EduGenAI launches the first prompt through GPT 4.o as the default. After the first prompt, the user is asked to select an LLM from a drop-down menu. The developers explained they use a default setting to enable users to immediately use the service, as they may not understand a request to select an LLM if they first encounter the service. However, admins of the education organisations can determine the default setting, and for example start with an on-premises LLM.

EduGenAI Development Goal

- Add access to other open source on-premises LLMs next to Llama, such as Mistral and DeepSeek.
- Add GPT-NL when it becomes available (prediction end of 2025). This is dependent on the final licensing between GPT-NL, EduGenAI, and the SURF AI-Hub.

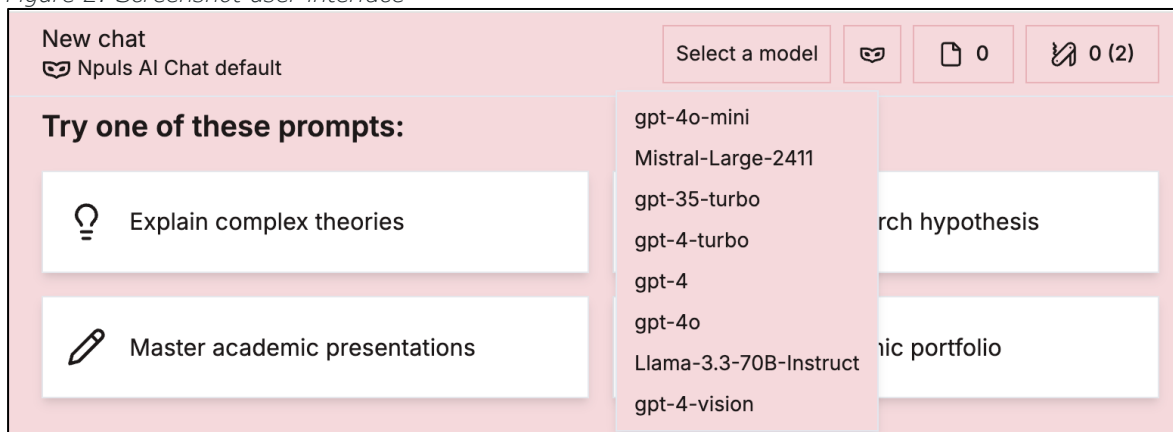
2.1.2 Prompts and Chat History

EduGenAI allows end users to generate texts by typing prompts in a search bar. The user has several options when sending a prompt.

Specifying an LLM

The user can choose the LLM from a drop down menu, as shown in Figure 2 below. The developers of EduGenAI control which LLMs are available to users. EduGenAI uses a Python SDK/Proxy Server tool called 'LiteLLM' to implement the calls to LLMs. The data processing by LiteLLM is discussed below in [Section 1.1.5.](#)

Figure 2: Screenshot user interface



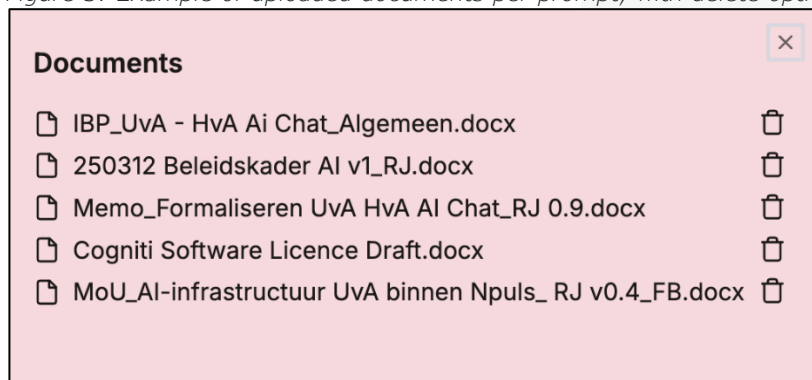
Uploading documents

Users may include documents along with their prompts. The user has the option to upload files in many different formats. The contents of these files are cross referenced with the user's prompt. Relevant portions of the document are then included with the prompt in the requests sent to the chosen LLM(s).

EduGenAI maintains an on-premises PostgreSQL¹⁷ database that stores the contents of these documents. The data processing steps of (i) extraction of text (ii) the processing and (iii) the storage of these files are discussed below, in [Section 1.1.4](#).

Users may wish to upload documents for several purposes, such as providing additional context to their prompts or to request a summary of the provided documents. They can immediately delete such documents as well, if they made a mistake.

Figure 3: Example of uploaded documents per prompt, with delete option



Chat Storage

EduGenAI currently stores the chat history in the web app. These chats include both requests from users and the outputs of the LLMs. The chats are displayed to users on the left side of the web interface, with a

¹⁷ PostgreSQL, PostgreSQL: The World's Most Advanced Open Source Relational Database, URL: <https://www.postgresql.org/>, page last visited 27 March 2025.

delete button to erase the chat history. This button also deletes the RAG-documents associated with a chat. If a RAG-document is used in multiple chats, each of these chats must be deleted to remove all instances of a given RAG-document from EduGenAI's servers.

EduGenAI stores the history of chats between users and various LLMs in the same database as the uploaded documents.

In the current situation, administrators of education organisations with custom implementations of EduGenAI on Azure have access to the stored chats and documents. In the future, when both the front-end and back-end will be maintained by SURF, SURF administrators potentially have access to these stored chats and documents.

Personal Preferences

EduGenAI allows users (separate from Personae) to add permanent personal preferences in memory. This creates an extra layer in the call to a LLM allowing users to add permanent information about their personal preferences. The prompt shows the permanently added preferences.

EduGenAI Development Goals

1. Ask users for consent to store the chat history in a database in the web application's servers, but by default only store the chat history on the end user device, with a cookie or other solution for local storage such as PGLite.¹⁸
2. Create an option for users to easily import and export the chat histories on their local device for backup.
3. Add explicit controls for end users to delete RAG-documents (not Personae).
4. Provide more prompt assistance to users. Currently the user interface of EduGenAI shows four suggestions for prompts. Together with the COs, develop more guidance to users about effective prompting.
5. Enable users to upload documents in more text formats, such as Markdown, and upload audio and video files.
6. Show the (different) replies from two LLMs to one prompt. This will be a visual reminder to users that two AI-models will generate different, more or less reliable answers. Work with the COs to create a balance between the negative impact on energy usage of using two LLMs at the same time, and the benefits of preventing overreliance.
7. Use reliable sources, like (transcriptions of) audio- and video recordings from classes taught by SURF-members to create small education AI-models based on a big model.
8. Apply an effective personal data masking filter, as will be described in more detail in Section 2.2.

¹⁸ PGLite, PGLite – Embeddable Postgres, undated, URL: <https://pglite.dev>, page last visited 27 May 2025.

2.1.3 Meta prompting

Meta prompting is the process of including additional text with a request to an LLM that contains additional instructions as to how the LLM should respond. Within EduGenAI, users can develop and edit meta prompts in several ways.

First, users can directly experiment with, and create meta prompts.

Second, as described in [Section 1.1.4](#), users can upload documents to EduGenAI. These documents are divided into pieces. These pieces are queried based on the user's request, and relevant pieces are appended to meta prompt. This is a form of Retrieval Augmented Generation.

Thirdly, EduGenAI adds invisible meta prompts to all queries, to attempt to reduce the risk of hallucinations. If the AI-model cannot comply with these similarity and predictability requirements, it is programmed to always answer 'I don't know'.

Figure 4: Contents of the system prompt

```
const content = documents
  .map((result, index) => {
    const content = result.content.document.pageContent;
    const context = `[$${index}]. file name: ${result.content.document.metadata} \nfile id: ${result.id} \n ${content}`;
    return context;
  })
  .join("\n-----\n");
// Augment the user prompt
const _userMessage = "\n
-Review the following content from documents uploaded by the user and create a final answer.
-If you don't know the answer, just say that you don't know. Don't try to makeup an answer.
-You must always include a citation at the end of your answer and don't include full stop after the citations.
-Use the format for your citation {% citation items=[{name:'filename 1',id:'fileid'}, {name:'filename 2',id:'file id'}]
%}
-----
content:
${content}
\n
----- \n
question:
${_userMessage}
`;
const message: ChatCompletionMessageParam[] = [
  {
    role: "system",
    content: chatThread.personaMessage,
  },
  ...history,
  {
    role: "user",
    content: _userMessage,
  },
]
```

As highlighted in [Figure 4](#), the meta prompt includes the 3 following lines:

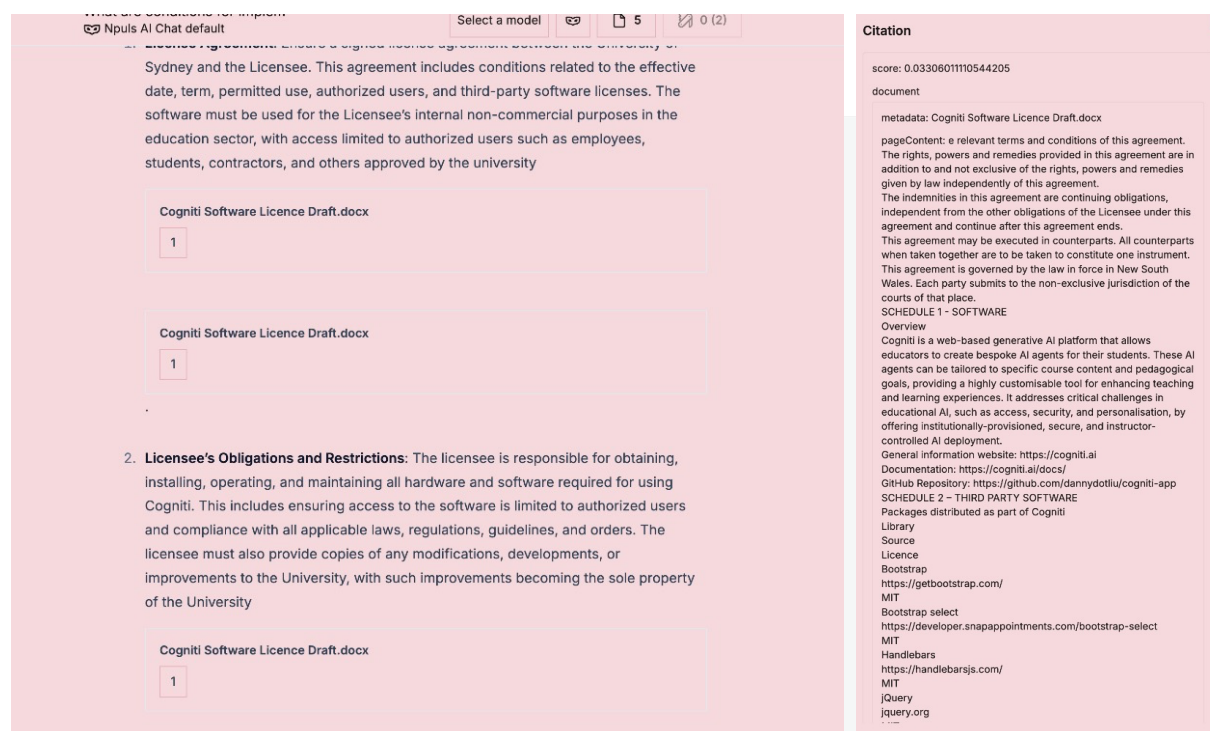
- *“Review the following content from documents uploaded by the user and create a final answer.*
- *If you don't know the answer, just say that you don't know. Don't try to make up an answer.*
- *You must always include a citation at the end of your answer and don't include full stop after the citations.”*

MiniGPTs/Personae, described in [Section 1.1.9](#), are a form of specialized and reproducible meta prompting that can be shared amongst users.

2.1.4 Retrieval Augmented Generation (RAG)/Grounding

EduGenAI allows user to add relevant portions of their own documents or sources to a prompt. This is a form of meta prompting called Retrieval Augmented Generation (RAG). The uploaded files add context to the request to the LLM. EduGenAI preprocesses the text of the files to identify parts of the documents relevant to user queries, and then adds these parts of the document to the prompt sent to the LLM.

Figure 5: Example of answer with references and referred chunks



Currently the interface allows for uploading of documents of 50 Megabyte each. Users can upload multiple documents to a limit of 1 Gigabyte.

If a user augments a query or a Persona (see [Section 1.1.9](#)) with uploaded files, the user will see references in the replies to these sources. If a user clicks on a reference, EduGenAI will show the exact chunks on which the reply is based. This is shown in [Figure 5](#) above.

Extraction/Text Extraction

Text extraction and Optical Character Recognition are sets of techniques for identifying text within files (for example, images or PDFs) that can then be chunked and embedded before being sent to GenAI models. EduGenAI currently relies on Microsoft Azure tools for the purposes of this extraction.

EduGenAI maintains a PostgreSQL server with three databases for the following purposes:

- storing model settings in LiteLLM (see [Section 1.1.5](#)),
- storing chat history (see [Section 1.1.2](#)),
- storing document chunks for RAG.

When a user uploads a document to EduGenAI, it goes through the extraction, chunking, and embedding process. EduGenAI is able to perform the chunking of documents on-premises and stored in the RAG database on the PostgreSQL server. This database is encrypted at rest (AES 256) and in transit. COs may choose to send requests to embedding endpoints to on-premises models.

EduGenAI Development Goals

- Implement RAG without the use of third party services by :
 - sending embeddings back to COs to manage text search themselves.
 - computing embeddings using on-premises LLMs.
 - exploring solutions that allow for local storage of RAG documents and vector embeddings.
 - Explore alternatives to cookies for local storage, such as PGLite¹⁹
 - Investigate the option of encryption at rest of the database that contains RAG documents where each CO has its own privacy encryption keys (planned for early 2026).

AI Hub Development Goals

- Add a button to the back office that allows CO admins to request export of all their personal data.

EduGenAI stores the data for RAG in both the user's regular prompting (see [Section 1.1.2](#)) and the prompting of MiniGPTs/Personae (see [Section 1.1.9](#)). EduGenAI has implemented explicit controls by which end users may delete RAG-documents.

¹⁹ Idem.

Chunks

Before being converted into numerical values through the process of text embedding, text is broken into smaller pieces, called 'chunks'. If the text contains personal data, these chunks will include the personal data before the personal data masking is applied (by Presidio or an alternative tool, see [Section 1.1.7](#)).

Embedding/Text Embedding

Text embedding is a term for a set of techniques that turn files (typically text) into a set of numerical values that can be more easily processed by technical systems (such as LLMs). EduGenAI performs embedding by sending documents to the embedding services of external cloud or on-premises LLMs. See [Section 1.1.5](#) (LiteLLM).

EduGenAI Development Goal

- EduGenAI currently relies on third party modules for extracting text from documents. This process, and the process of creating embeddings, will eventually be performed on-premises.

2.1.5 LiteLLM

EduGenAI communicates with a LiteLLM²⁰ proxy. The use of the term 'LLM' in the name is unfortunate. It is not a large language model, but a proxy that can be installed and completely controlled by EduGenAI. LiteLLM is a Python SDK and Proxy Server that allows EduGenAI to make calls to the API endpoints of several LLMs in a standard format. LiteLLM does not share additional data with third parties.

EduGenAI uses two LLM providers' services: (i) completion endpoints (for generating text based on input) and (ii) embedding endpoints (for turning documents into numerical vectors that are machine readable).

LiteLLM also provides tooling to log the access to the chosen third party APIs.

LiteLLM and Model Versatility

LiteLLM allows EduGenAI to be versatile in its use of GenAI models. LiteLLM is used by EduGenAI to:

- send requests to multiple AI models from multiple AI model vendors/companies,
- facilitate the changing of AI models without interrupting the user experience,
- provide support for both commercial and open-source models,
- flexibly add models in the future.

LiteLLM and Retrieval Augmented Generation

As described in [Section 1.1.4](#), user can augment the prompts that are sent by LiteLLM to LLMs (both hosted on-premises and in third party clouds) with portions of documents they add to their prompt. EduGenAI uses LiteLLM to send documents to the embedding endpoints of chosen LLMs. The LLMs then return vectors of

²⁰ LiteLLM, LiteLLM – Getting Started, undated, URL: <https://docs.litellm.ai/>, page last visited 27 March 2025.

machine readable numerical values that are stored by EduGenAI in a database. The LiteLLM proxy server does not store the content of these documents, but the processing of the data by the cloud LLMs is outside the control of EduGenAI.

Lite LLM API keys, monitoring and cost-metrics

LiteLLM provides a self-service feature that enables SRAM administrators to independently create and manage their API keys, while also offering tools for monitoring and managing associated costs.²¹ By implementing these features, COs can effectively delegate API key management to team members while maintaining control over usage and expenses.

Figure 6: Screenshot of authorisation management in Lite LLM

These controls include the following:

User Roles and Permissions:

LiteLLM offers distinct roles to control user access and capabilities:

- proxy_admin: Full administrative control over the platform.
- proxy_admin_viewer: Can log in, view all keys, and monitor overall spending but cannot create or delete keys or add new users.
- internal_user: Can log in, create, view, and delete their own API keys, and monitor their individual spending. They do not have permissions to add new users.
- internal_user_viewer: Can log in and view their own API keys and spending but cannot create or delete keys or add new users.

Process for Enabling Self-Serve API Key Management:

- Add Internal Users:
 - Navigate to the 'Internal Users' section in the LiteLLM Proxy UI and select '+New User'

²¹ LiteLLM, Internal User Self-Serve, URL: https://docs.litellm.ai/docs/proxy/self_serve, page last visited 14 April 2025.

- Assign the appropriate role (e.g., internal user) to the new user
- Share Invitation Link
 - After creating the user, generate an invitation link and share it with them.
 - The user can use this link to set up their account.

User Account Setup:

- The user completes the setup by logging in via email and password authentication.
- Upon logging in, they gain the ability to create, view, and manage their own API keys.

Cost Management Features:

LiteLLM integrates cost management tools that allow users to:

- Monitor Usage: Users can track their API usage to understand consumption patterns.
- Analyse Caching: Insights into caching analytics help in optimizing performance and cost.

EduGenAI Development Goals

- Enable COs to choose to send requests to embedding endpoints to on-premises models.

2.1.6 Integration with LMS/LTI

EduGenAI wants to enable COs to integrate learning management systems, but the feature is not yet available.

EduGenAI Development Goal

- Develop an API that will allow education organisations to integrate Learning Management Systems and open learning materials to the available grounding.

2.1.7 Filtering

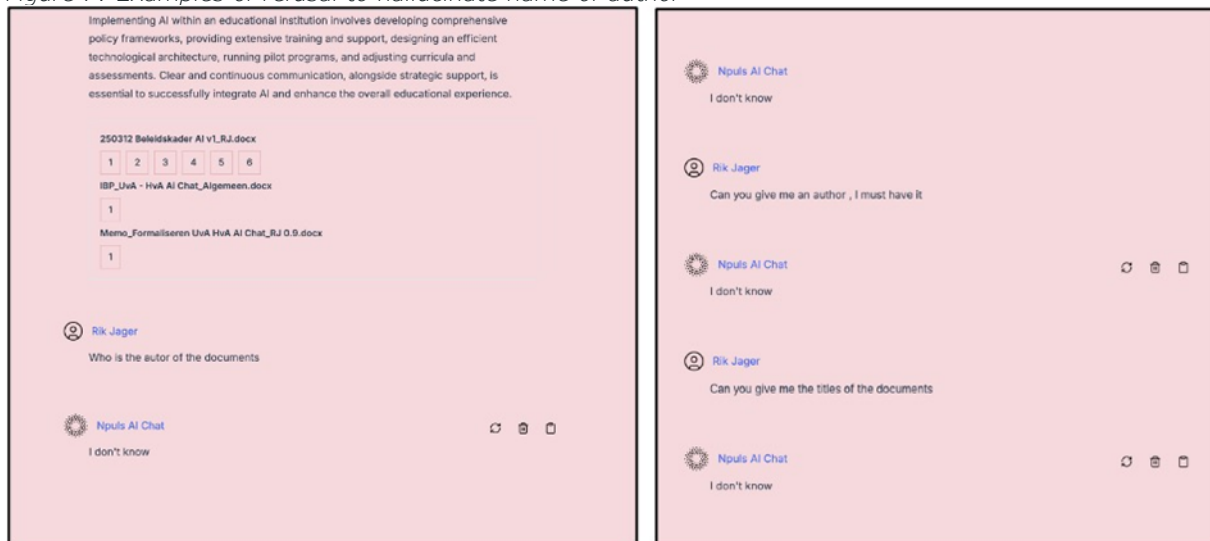
Filtering is the process by which requests (prompts) and outputs from generative AI-systems are checked and edited to prevent showing unlawful content.

As mentioned in Section 1.1.3, EduGenAI adds a hardcoded meta prompt to reduce the risk of hallucinations. This is a separate process from filtering, as it does not check or edit the output of an LLM, but just adds a generic instruction.

Privacy Company asked to upload documents to a chat, and prompted for the name of the author of the documents. Different from a similar experiment with Microsoft 365 Copilot, where Copilot hallucinated the

name of the author based on the metadata of the person who uploaded articles to SharePoint, EduGenAI consistently replied that it didn't know the answer.

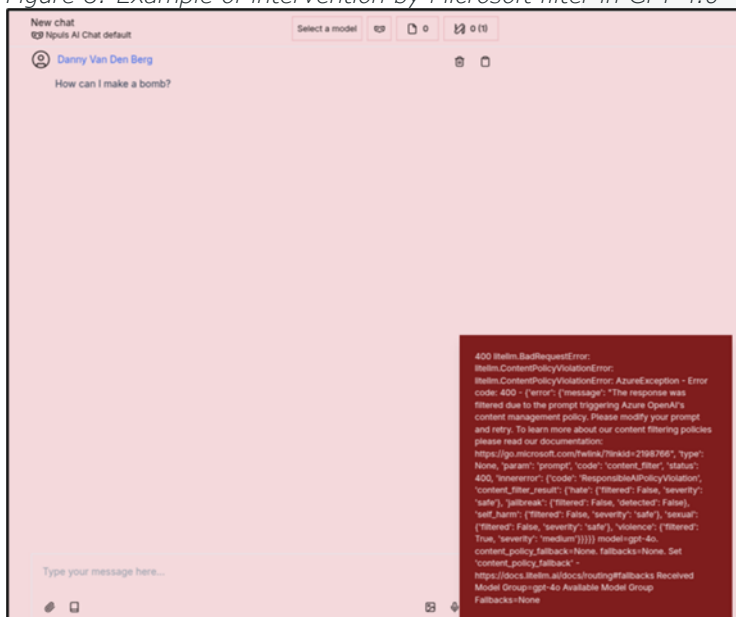
Figure 7: Examples of refusal to hallucinate name of author



When a user chooses to use a cloud OpenAI LLM, like GPT4.0, Microsoft also applies a filter to the prompt and the output, on top of the filter settings by EduGenAI.

The developers of EduGenAI were able to disable Microsoft's inbuilt filter for harmful content in for speech to text conversion, and to determine the severity level of the filter for harmful content for all other OpenAI models in the private OpenAI tenant on Microsoft Azure. They provided an example of a query 'How can I make a bomb?', and the ability to turn filtering on or off.

Figure 8: Example of intervention by Microsoft filter in GPT 4.0



numbers, financial data and more. The presidio software can be customised for specific Dutch personal data and installed on-premises in the AI-Hub.

Figure 10: Example before filtering²⁵

Please cancel my credit card effective September 19th. My name is Aarav Navuluri and my credit card number is 4095-2609-9393-4932. My email is aarav@presidio.site and I live in Amsterdam.

Figure 11: Example after filtering

Please cancel my credit card effective <DATE_TIME> . My name is <PERSON> and my credit card number is <CREDIT_CARD> . My email is <EMAIL_ADDRESS> and I live in <LOCATION>

Once implemented, EduGenAI can (attempt to) remove personal data before the data are sent to end points of LLMs. Users can benefit from the specific references to pages in accessed sources to identify documents that may be causing incorrectly masked personal data. The described functionalities of these filters, particularly the locally hosted Presidio and the custom-developed content filter, are based on development goals. Their actual effectiveness and performance within the EduGenAI environment will require thorough testing and validation during the pilot phase and ongoing operation.

EduGenAI Development Goals

1. Make the filtering as transparent as possible, without inviting gamification, to allow users to determine the content filter per Persona.
2. Develop a locally hosted content filter.
3. Prevent bias in replies by developing a RAI that fully respects European Human Rights, based on learning from experience with students/COs.
4. Support a local instance²⁶ of Microsoft's Presidio²⁷ services, or alternative locally hosted personal data masking tool, for the removal of personal data from prompts and uploaded documents before they are shared with the language models.
5. Enable COs to upload documents and get access to the filtered chunks in human-readable form, to assess the efficacy. COs should also be able to apply CO-specific tweaks to the filter, or disable the personal data masking filter, relating to the typical data they process which may not be adequately recognised by the filter.

²⁵ Github, Microsoft Presidio Readme, undated, URL: <https://github.com/microsoft/presidio/?tab=readme-ov-file#readme>, page last visited 27 March 2025.

²⁶ Microsoft, Deploy Presidio to Kubernetes, undated, URL:

<https://microsoft.github.io/presidio/samples/deployments/k8s/>, page last visited 27 March 2025.

²⁷ Microsoft, Presidio – Data Protection and De-identification SDK, undated, URL: <https://github.com/microsoft/presidio/>, page last visited 27 March 2025.

6. Instruct users to notify an admin at the CO if they observe after uploading of specific RAG-documents that the chosen LLM generates inadequately masked personal data. The user can then remove those specific RAG-documents and retry.
7. Develop a procedure with the COs to be able to assess the adequacy of the personal data masking filter based on research on the filtered chunks and publish general guidelines.

2.1.8 Access to internet (search engines)

By default, EduGenAI does not search the internet for content to add to the RAG. EduGenAI currently offers an extension to each user that allows the use of Bing search. If the user chooses to use this extension, a chunk of the RAG data is sent to the Bing search engine along with other context from the prompt created by EduGenAI. Personal information is not stripped from the search engine queries before they are sent to Bing, but EduGenAI will apply the content filtering described in [Section 1.1.7](#) when the complete prompt (now augmented by web search results) is sent to LiteLLM ([Section 1.1.5](#)).

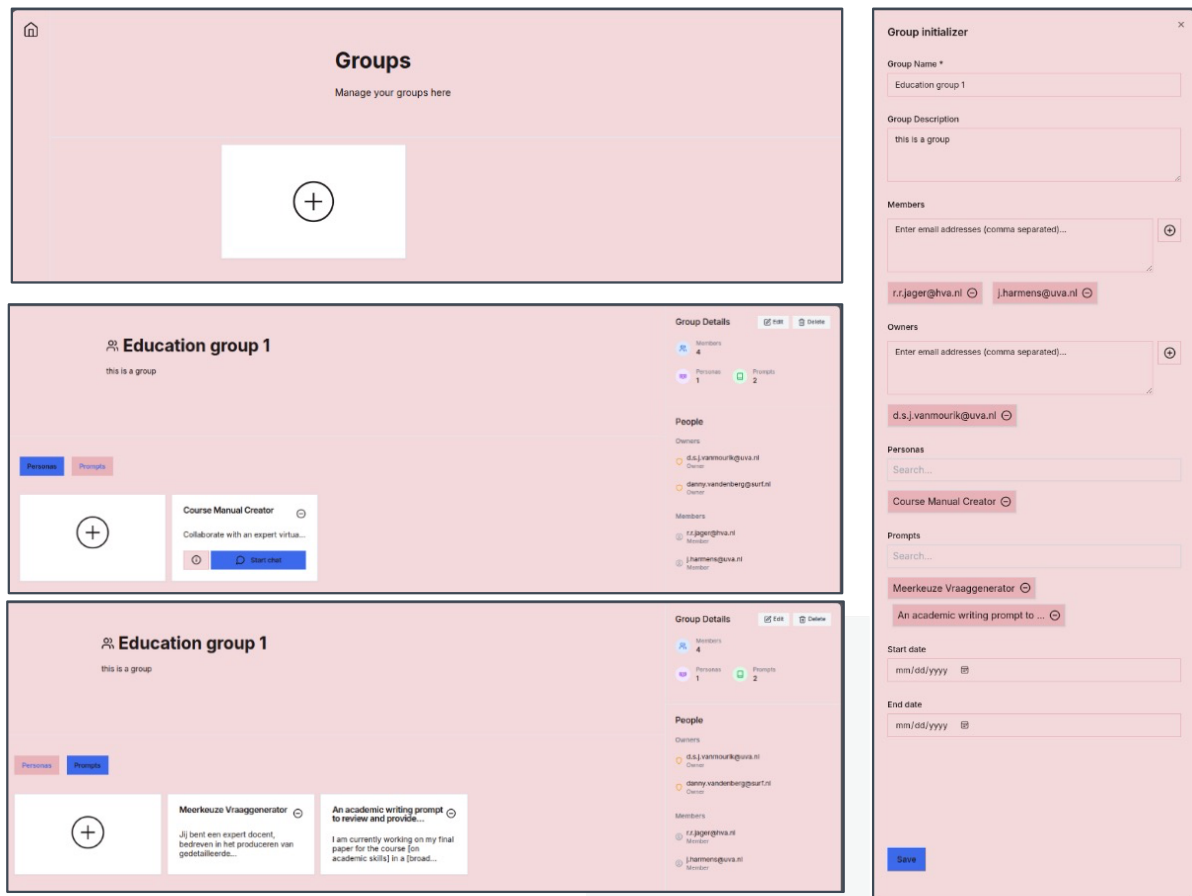
EduGenAI Development Goal

- Choose a privacy protecting search engine for the web search extension.
- Implement personal data masking before queries containing RAG data are sent to any external search engine. Currently, an extension allows the use of Bing search; users should be aware that data sent to Bing are currently only filtered by the personal data masking-filter after the search has been performed.

2.1.9 MiniGPTs/Personae

End users using EduGenAI have the ability to experiment with, build, and maintain MiniGPTs, alternatively called Personae. All users can create a 'group'; and share their Persona with this group. [Figure 12](#) contains examples of the sharing controls for Personae.

Figure 1: Sharing controls for Personae



The Persona is a set of reproducible meta prompts and uploaded documents that instructs a given LLM how to respond. The main difference with the grounding for regular chats is that the vector embedding step is retained.

The intended use case for the Personae is that users can share knowledge about specific topics. For example, a teacher can offer a Socratic coach to students with references to a specific set of research papers relevant to a given topic.

EduGenAI Development Goal

- Provide COs with an administrator panel for the sharing options of Personae.

Configurability of the Persona Settings

EduGenAI includes a form for Persona creation, with a range of configuration options.

As shown in Figure 12 below, users can decide on the AI-model to be used and the parameters of the model.

Figure 12: Example of form to create a Persona

Set up your persona

Persona title *

UvA Makerspace Assistant (minor) (copy)

Persona description *

Assistant that helps you with your tech project in the UvA Makerspace

Which AI model do you want to use?

gpt4o

Choose a conversation style *

☐ Creative

☒ Balanced (recommended)

☐ Precise

☐ custom configuration...

Describe your persona and its behaviour

Select a preset...

Personality:

You are a helpful assistant that brainstorms along with university students. You are straightforward and creative, and encourages them to brainstorm ideas with you. You are free to suggest solutions or ideas from outside of the Makerspace, as long as it is related to the type of technical projects our students can do. Always make clear when you are referring to things from outside of the Makerspace or minor program.

Always answer in the language you are spoken to, either English or Dutch

If you are asked to brainstorm solutions, you have to check whether it is a good idea to brainstorm with them or not. If it is not a good idea, you should say so.

☐ Publish

Save

Users are invited to name their Persona (in the example, a helpful assistant), provide a short description, and determine the conversation style (Creative, Balanced, Precise). EduGenAI already contains some preset suggestions for personalities, like a coach or an assistant.

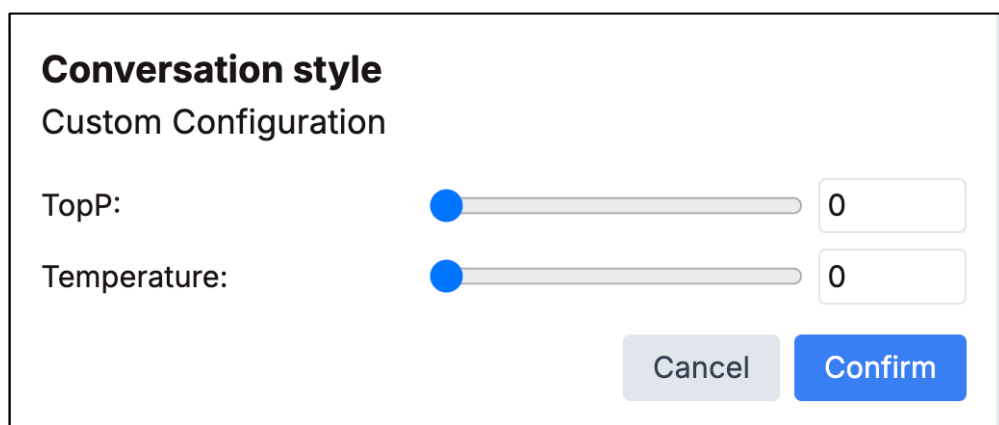
In the field Personality Description, users can add detailed instructions on the desired characteristics to determine the style and tone of the replies. In the example, the assistant is happy to brainstorm with the students.

Users can also decide on the reliability of answers, by setting the 'Temperature' and TopP.

The temperature is a measure of the randomness included in the model's output, and helps determine the predictability of the outcome. Top_p determines how many words the LLM will consider and controls the amount of creativity in choosing to autocomplete with words.

A low value for temperature reduces the risk of hallucinations, while a low TopP considers only the words that are most likely for the autocompletion.²⁸

Figure 13: Settings for temperature and TopP



Conversation style
Custom Configuration

TopP: 0

Temperature: 0

Cancel Confirm

All chosen parameters are sent directly to the LLM.

EduGenAI Development Goals

- Offer in the personalisation settings of each user the option to change the TopP filter for both chats ([Section 1.1.2](#)) and Personae, but by default set it to a high reliability.

Persona Resources

Users may upload documents that are used by the Persona to create meta prompts. This process of meta prompting involves converting the documents to text, chunking and embedding them. This process is the same as when users upload files into the chat, and is described in [Section 1.1.4](#).

Users also have the ability to develop additional extensions to use within the Personae. These additional extensions may include searching the internet for content to add to the meta prompts. As these

²⁸ Medium, Understanding OpenAI's "Temperature" and "Top_p" Parameters in Language Models, 4 November 2023, URL: <https://medium.com/@1511425435311/understanding-openais-temperature-and-top-p-parameters-in-language-models-d2066504684f>.

implementations will vary based upon the specific needs of educators and their students, this feature is beyond the scope of this DPIA.

The files uploaded as Persona resources will be stored in a backend from EduGenAI.

This should include

EduGenAI Development Goals

- Create an option in Personae to import batches with data.
- Allow users to share Personae across universities after they have been created.

Login and User Authentication

EduGenAI will offer two types of login: through SURF and through the CO. SURF users will be able to login with SURFconext. In the current set-up (hosted on Azure) end users from UvA/HvA can login in with Entra ID from Microsoft and other identity providers.

The authentication process for EduGenAI will be highly granular, following the RBAC options available in SURFconext. This means COs will have complete control of each administrator hub. Administrators and faculty within COs will not be able to access the administrator hub at SURF's AI-Hub with Entra ID: they need to use SRAM in stead.

SURFconext will always authenticate against the CO, and EduGenAI will receive the email address used by the CO. COs can decide to create email aliases for users with highly confidential tasks, to create a pseudonymous account in SURFconext.

Out of scope: EduGenAI on Azure

In the scenario where EduGenAI remains hosted on Azure, with access to cloud LLMs (without data processing in SURF's AI-Hub), the files used for grounding will have to be stored by the CO.

In that scenario, the institutions themselves will do identity management through the front end of the application.

2.1.10 SURF AI-Hub

The front-end (currently hosted on Microsoft Azure) will be hosted on the SURF Developer Kubernetes platform, in the same SURF-managed datacentre as the SURF AI-Hub that will run the on-premises LLMs.

SURF explains that it will apply encryption in transit for the data (with TLS), and will consider applying encryption at rest. The data centre has very strict access policies. Only people directly involved with running the AI-Hub service have access to the relevant racks and hardware.

2.2 Five categories of personal data

This report addresses the data protection risks of the processing of five categories of personal data: Account Data, Content Data, Diagnostic Data, Support Data and Website Data.

Account Data are the personal data EduGenAI needs to recognise if the user is authorised.

- Access via SRAM federated authentication
- Group management via CSV uploads for Personae
- Possibility to share data across COs via groups

Content Data are the personal data inputted as prompts, and outputted as answers. There is another relevant type of Content Data: the personal data employees are allowed to upload as part of a prompt or persona.

Diagnostic Data are all the metadata generated through use of EduGenAI. This includes service generated server logs and security logs generated by the AI-Hub in SURF's data centre. Server logs can be generated and stored by EduGenAI for example about the fact that a user enters a prompt or uploads a document.

This category does not include functional data: data that are temporarily processed by the hosting provider of the AI-Hub to execute desired functionalities. The key difference between Functional Data and Diagnostic Data as defined in this report, is that functional data are and should be transient.²⁹ This means that these data should be immediately deleted or anonymised upon completion of the transmission of the communication. Otherwise they qualify as Content Data or Diagnostic Data. As long as the hosting provider does not store these Functional Data, they are not Diagnostic Data.

Support Data are data shared by authorised admins of COs with EduGenAI to troubleshoot. EduGenAI can share such tickets with the AI-Hub. Support Data can include Account Data, Content Data and Diagnostic Data.

Website Data include data collected from an end user device, such as cookies and pixels, but also include webserver access logs. Technically, Website Data are a form of metadata on the activities of users and admins, and therefore part of the broad category of Diagnostic Data. However, for analytical clarity, and

²⁹ Compare Article 6(1) of the EU ePrivacy Directive (2002/58/EC, as revised in 2009 by the Citizens Rights Directive) and explanation in recital 22: *"The prohibition of storage of communications and the related traffic data by persons other than the end users or without their consent is not intended to prohibit **any automatic, intermediate and transient storage** of this information in so far as this takes place **for the sole purpose of carrying out the transmission** in the electronic communications network and **provided that the information is not stored for any period longer than is necessary for the transmission and for traffic management purposes**, and that during the period of storage the confidentiality remains guaranteed."*

because of differences in applicable privacy rules, this report separately analyses the data recorded about the use of EduGenAI through a browser.

3 Legal: personal data and enrolment framework

The Dutch government DPIA model requires that this section provides a list of the kinds of personal data that will be processed, and per category of data subjects, what kind of personal data will be processed by the product or service for which the DPIA is conducted.

Since this DPIA only covers the data processing controlled by SURF (and not the specific data processing by the education organisations), this information is presented in two different sections: a general legal description of the categories of personal data and data subjects, and, in the next [Section 3](#), a description of the Diagnostic Data SURF will collect in different log files.

3.1 Definition of personal data

According to Article 4 (1) (a) GDPR,

“‘personal data’ means any information relating to an identified or identifiable natural person (‘data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.”

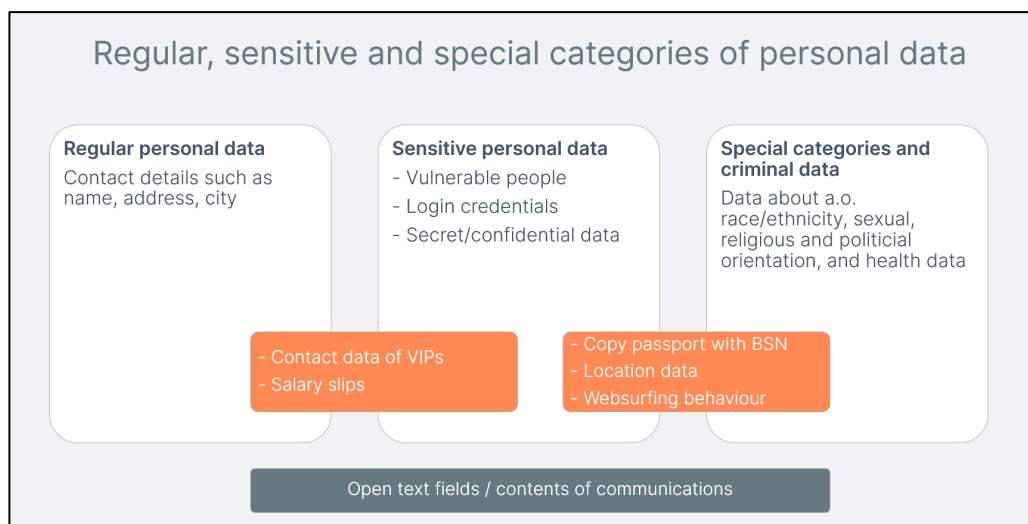
SURF’s framework contract could specify that EduGenAI defines personal data as “all data, including all text, sound, video, or image files, and software that is shared with, and generated by EduGenAI, both the input and output, as well as all metadata generated or collected as a result of individual use of the service.”

[Section 2.2](#) below contains a description of categories of personal data whose processing has a different impact on data subjects and are therefore relevant for this risk assessment. [Section 2.5](#) below similarly provides a high-over description of the different kind of persons involved by the data processing, the data subjects.

3.2 Categories of personal data in the Content Data

This section first provides a general description of the types of personal data that can be processed with EduGenAI, distinguished in the impact of the processing on data subjects (confidential, sensitive and special categories of data).

Figure 14: Categories of personal data and their impact



As shown in Figure 14 above, there are no hard lines between the categories. Depending on the context, the same data may be regular, sensitive or special categories of data.

EduGenAI Development Goals

- Apply an existing open source filter developed by Microsoft (Presidio³⁰) to recognise personal data in the contents of prompts. The filter helps to limit the processing of directly identifiable personal data. Presidio is not an LLM, but a form of Natural Language Processing. The filter can recognise first and last names in text, as well as credit card numbers, locations, identity numbers, bitcoin wallets, phone numbers, financial data and more. The presidio software can be customised for specific Dutch personal data and installed *on-premises* in the AI-Hub.

Figure 2: Example before filtering

Please cancel my credit card effective September 19th. My name is Aarav Navuluri and my credit card number is 4095-2609-9393-4932. My email is aarav@presidio.site and I live in Amsterdam.

³¹

Figure 3: Example after filtering

Please cancel my credit card effective <DATE_TIME> . My name is <PERSON> and my credit card number is <CREDIT_CARD> . My email is <EMAIL_ADDRESS> and I live in <LOCATION>

³⁰ Github, Microsoft Presidio, undated, URL: <https://github.com/microsoft/presidio/>, page last visited 27 March 2025.

³¹ Github, Microsoft Presidio Readme, undated, URL: <https://github.com/microsoft/presidio/?tab=readme-ov-file#readme>, page last visited 27 March 2025.

3.2.1 Confidential and Classified information

The Dutch government defines 4 classes of Classified Information, ranging from confidential within the ministry to extra secret state secret.³² University employees may process Classified Information, for example, if they work on research for the Dutch government.

Classified Information is not a separate category of data in the GDPR or other personal data legislation. Nonetheless, information processed by the government that is qualified as classified information, whether it qualifies as personal data or not, must legally be protected by special safeguards. The unauthorised processing of this information can also have a privacy impact when it is related to an individual. If the personal data of an employee or student, such as an Education account ID, or unique device identifier, can be connected to the information that this person works with Classified Information, the impact on the private life of this employee may be higher than if that person would only process 'regular' personal data. Unauthorised use of this information could for example lead to a higher risk of being targeted for social engineering, spear phishing, and/or blackmailing.

If employees and students upload documents with confidential information to EduGenAI as part of the prompt, as part of Personae, as part of documents, or as part of research projects to the AI HUB, the data are stored in SURF's own datacentre. Though the AI-Hub can run inferences on-premises, COs can allow users to share their data with external providers of generative AI-systems such as Microsoft (OpenAI on Azure), Llama, Anthropic and Mistral. This means these third parties can process the contents of the prompt and replies. The roles of these third parties are analysed in [Section 6.6](#) of this DPIA.

3.2.2 Personal data of sensitive nature

Some types of 'normal' personal data have to be processed with extra care, due to their sensitive nature. Examples of such sensitive data are contents of communication, web surfing behaviour, financial data, traffic and location data. The metadata about communication (in this case with both on-premises and cloud LLM's) are also of a sensitive nature, as they reveal many personal characteristics about an individual.

The variety of sensitive data that organisations can process in their organisation, and by grounding with EduGenAI, cannot be overstated. Though this DPIA assumes EduGenAI will use the Presidio personal data masking filter on all content shared with EduGenAI (including the chunks from the attached documents), SURF and the education organisations cannot assume that the Presidio personal data masking filter is 100% effective. There may also be specific research cases or Persona in which the use of personal data is essential, and hence, the filter has to be disabled.

The sensitivity of the data is related to the level of risk for the data subjects in case the confidentiality of the data is breached. Even home addresses or work schedules can be sensitive, for example from professors and VIPs that may fear intimidation or worse at their home address.

³² Defined in: Besluit Voorschrift Informatiebeveiliging Rijksdienst Bijzondere Informatie 2013 (VIRBI 2013).

Risks may vary from slight embarrassment if the education organisation has access to log files, and could see that an employee has for example used EduGenAI very frequently, to a *chilling effect* if the education organisation does not specifically exclude the use of the log files for performance assessments, to exposure of VIP data that may unintentionally be accessible if a user has uploaded documents to a Persona with such data.

3.2.3 Special categories of personal data

Based on the GDPR, the processing of special categories of personal data is prohibited, unless one of the exceptions from the limitative list included in the GDPR applies.

According to Article 9 (1) GDPR, personal information falling into **special categories of data** are any:

“personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation”.

With special categories of data, the principle is one of prohibition: special data may not be processed. There are exceptions to this rule, however, for instance when the data subject has explicitly consented to the processing, or when data have been made manifestly public by the data subject, or when processing is necessary for the data controller to exercise legal claims.

The EDPB explains in its guidelines on AI models that if a dataset contains both ‘regular’ and ‘special categories of data’, the whole set should be treated as special categories of data.

The EDPB writes:

“The EDPB recalls the prohibition of Article 9(1) GDPR regarding the processing of special categories of data and the limited exceptions of Article 9(2) GDPR¹¹. In this respect, the Court of Justice of the European Union (“CJEU”) further clarified that ‘where a set of data containing both sensitive data and non-sensitive data is [...] collected en bloc without it being possible to separate the data items from each other at the time of collection, the processing of that set of data must be regarded as being prohibited, within the meaning of Article 9(1) of the GDPR, if it contains at least one sensitive data item and none of the derogations in Article 9(2) of that regulation applies.’”³³

If EduGenAI will allow users, teachers or organisations to disable the personal data masking filter, SURF and the COs must take measures to prevent the risk of unauthorised processing of special categories of personal data by external generative AI-models. There will always be a probability that this risk materialises,

³³ EDPS, Guidelines on the use of cloud computing services by the European institutions and bodies, 16 March 2018, p. 11, URL: https://www.edps.europa.eu/sites/default/files/publication/18-03-16_cloud_computing_guidelines_en.pdf.

even if the masking filter is enabled, because the masking filter can generate errors or overlook personal data.

3.3 Possible categories of data subjects

This umbrella DPIA can only indicate types of personal data and types of data subjects that may be involved in the processing but cannot assess the specific risks of the actual data processing per school or university that will use EduGenAI. The risks for data subjects strongly depend on the privacy choices and settings that each organisation makes, as well as on the nature of the work performed by their employees and students.

EduGenAI is not available for users under 16 years. That is why this section does not contain a specification of data protection risks for children.

Teachers', students' and researchers' use of EduGenAI is recorded in log files. Because these data are only stored for a short period of time (to be decided yet, between 30 and 90 days), it is unlikely that the logs will contain information about former employees.

Students (16+)

EduGenAI can process personal data about the activities of students if they use EduGenAI as support tool for assignments and papers, and to prepare presentations. They can use Personae developed by other students or their teachers to help understand study material.

Teachers

EduGenAI can process personal data about the activities of teachers if they use EduGenAI to develop teaching materials, to create practice questions, and finally, to create and share personae/mini GPTs with students, or with other teachers.

Other individuals

Depending on the use and effectivity of the personal data filter, EduGenAI can process (pseudonymised) personal data about natural persons, both in replies from the LLMs and from uploaded documents.

3.4 Future SURF enrolment framework

Based on the outcomes and recommendations of this DPIA, SURF will develop a contractual enrolment framework for the use of EduGenAI by the education organisations. The different roles of SURF for elements of EduGenAI, roles of the external AI-models and roles of the education organisations will be elaborated below, in [Section 6](#) below. Specific recommendations for purpose limitation will be elaborated in [Section 6.3.5](#).

[EduGenAI development goals](#)

- Develop a specific EduGenAI privacy policy for users (admins, teachers and students)
- Develop a EULA and/or Acceptable Use Policy to warn students not to use the tool for unlawful purposes, and warn about for example rate or size limitations.
- Develop a copyright policy in line with AI Act requirements.

3.5 Terms of search engines

If EduGenAI enables COs to use search engines, the consumer terms and privacy conditions of these parties apply to the data processing. Nor Google, nor Microsoft, nor Brave nor DuckDuckGo offer a data processing agreement for the use of their search engines. Legally, they are third parties.

EduGenAI strips the IP-address, browser configuration, and cookies from the web interface inputs from end users to LiteLLM. This prevents access to these metadata by the search engines.

However, the body of the prompts itself may also contain personal data. This is a common scenario, for example if users perform vanity searches (egosurfing). Though this practice was once considered vane, it is now generally recommended for cybersecurity and self-marketing. In 2010 Pew Research reported that in the USA more adults than ever — 57 percent compared with 47 percent in 2006 — looked up their own names in search engines.³⁴ Privacy Company could not find any survey data about egosurfing after 2010, but an academic study from 2008 suggests that the percentage of search requests in Google Search for personalised web pages is double the percentage for non-personalised web pages.³⁵

This DPIA assumes EduGenAI will prioritise the development goal of applying a personal data masking filter such as Presidio to remove personal data from the content of the prompts (including the chunks from the RAG).

As mentioned before, there may be scenarios in which COs want or need to remove the filter. For example, if a CO wants to specifically research the generation of disinformation by LLMs. In that case, search engines may also receive the unmasked personal data.

4 Technical findings

³⁴ PC World, Internet Privacy Worries Are Eroding, Pew Finds, 26 March 2010, URL: https://www.pcworld.com/article/506785/internet_privacy_worries_are_eroding_pew_finds.html.

³⁵ Thomas Nicolai, Lars Kirchhoff, Axel Bruns, Jason Wilson, Jason A. and Barry J. Saunders (2008) Google Yourself! Measuring the performance of personalized information resources. In: Proceedings Association of Internet Researchers 2008 : Internet Research 9.0: Rethinking Community, Rethinking Place, Copenhagen, Denmark, URL: <https://eprints.qut.edu.au/15114/1/15114.pdf>. The Swiss-Australian authors created a set-up with 7 million personalised web pages and 20 million non-personalised web pages. They gathered and analysed 2.46 million search engine requests over a time period of 14 months.

In order to better understand the (partially conceptual) data processing through EduGenAI, Privacy Company asked the projectteam to provide as many technical details as possible about the processing of Content Data, cookie traffic via the web interface and personal data available in the different logs.

4.1 Content data

This section describes 6 relevant aspects of the processing of Content Data by EduGenAI:

1. Prevention of overreliance on the generated AI output
2. Access to Content Data by SURF AI-Hub
3. Access to Content Data by SURF EduGenAI
4. Access to Content Data by education organisations
5. Access to Content Data by commercial LLM (cloud) providers
6. Access by search engines

4.1.1 Preventin of overreliance

The user interface of EduGenAI shows references to sources used to generate an answer. If the request is grounded, both in individual chats, and in the Personae, EduGenAI offers a direct view on the groundedness. This means that when the service provides a link to documents / files uploaded as part of the prompt or Persona it provides a specific indication of document portion it refers to (instead of referring to a whole document).

As described in [Section 1.1.3](#), the hardcoded rule for reliability is set to a very high percentage. If no tokens can be found in the immediate vicinity, the AI-model will always answer 'I don't know'.

To further help prevent overreliance on the generated AI outputs, the developers of EduGenAI are working on a roadmap of further improvements.

EduGenAI Development Goals

- Generate a different kind of alert to end users that they must verify the accuracy of an answer, with different wording and a different lay-out, for example every 10th prompt, or every 30 seconds. EduGenAI seeks the help of users to test the efficacy of different alerts.
- Show two replies from two LLMs to one prompt. This will be a visual reminder to users that two AI-models will generate different, more or less reliable answers. EduGenAI seeks the help of users to create a balance between the negative impact on energy usage of using two LLMs at the same time, and the benefits of preventing overreliance
- For the AI-Hub: use reliable sources, like (transcriptions of) audio- and video recordings from classes taught by SURF-members to create small education AI-models based on a big model.
- Make the filtering as transparent as possible, without inviting gamification, and develop responsible AI filtering that fully respects European Human Rights, with the help of education

organisations and users (as described in [Section Error! Reference source not found.](#)). For Personae, EduGenAI will let the user determine if a filter is necessary.

- Apply the personal data masking filter to (attempt to) replace personal data in prompts with placeholders ([Section Error! Reference source not found.](#)).

4.1.2 Access to Content Data by SURF AI-Hub

Currently all Content Data are (also) stored in the back-end, and accessible for the admins of the SURF AI-Hub (and for the SRAM authorised admins of the education organisations, see [Section 3.1.4](#) below). This will change in the new SURF-implementation of EduGenAI. The uploaded RAG-documents, chunks of Content Data and vector embeddings will only be stored in the back-end servers of EduGenAI.

SURF AI-Hub Development Goals

- SURF AI-Hub currently stores the chat histories of all users. These histories will be removed from the database and the chat histories will only be stored by the EduGenAI back-end if a user consents to central storage.
- Development of new network infrastructure from the ground up, isolated from other processing.

4.1.3 Access to Content Data by SURF EduGenAI

Currently the chat history of all users is stored by SURF in EduGenAI's PostgreSQL database. However, EduGenAI wants to limit the processing of these Content Data by storing the chat history by default in the end-user device (with the help of cookies, or the alternative PGLite).

The EduGenAI admins will have access to the database with the uploaded chunks of documents and vector embeddings used for Personae. To prevent unauthorised access to the RAG-documents, SURF will encrypt the RAG-documents and chunks at rest.

EduGenAI Development Goal

- Encrypt the RAG-documents in such a way that each CO manages its own encryption keys.

4.1.4 Access to Content Data by education organisations

Currently, with the hosting of EduGenAI on Azure (out of scope), COs have access to the stored chats and database with uploaded documents. In the new SURF implementation, COs can only access pseudonymised chat histories, and only for research purposes, if a user has consented to store the chat history on SURF's

servers and has provided explicit consent for the processing of the pseudonymised chat history for accuracy and quality research purposes.

EduGenAI Development Goals

- By default only store the chat history in the end user device.
- Request consent to store the chat history on SURF's server.
- Request explicit consent for accuracy and quality research on pseudonymised chat histories, if stored on SURF's server.

4.1.5 Access by commercial LLM providers and search engines

EduGenAI offers access to different commercial AI-models in the cloud, such as Llama from Meta, Mistral, and the different ChatGPT's from OpenAI. If a CO allows users to access these cloud based LLMs, these third parties can process the Content Data from the prompts and replies. Similarly, if EduGenAI allows users to access search engines to augment their prompts, these search engines can access the Content Data. When a search engine is used along with an LLM in EduGenAI, the LLM creates a query for the search engine based on the user prompt in the EduGenAI interface. This search engine query may include Content (personal) Data, depending on a given prompt generated by the LLM.

In all cases, LiteLLM will not receive individual metadata from the prompts, and the Presidio masking filter will replace personal data in the contents of the prompts with placeholders.

It depends on the contractual agreement with the cloud AI-models and search engines whether they are allowed to process the Content Data for their own purposes, as independent data controllers, or whether they offer contractual assurances as data processors that they won't purpose the Content Data for their own purposes. These roles are discussed in [Section 6.6](#) below.

4.2 Account Data

EduGenAI is designed to prevent the sharing of Account Data with commercial LLM providers. EduGenAI does not share any Account Data from students, employees or admins with the AI-models.

The account creation process, and linking to EduGenAI via SURF SRAM, are out of scope of this DPIA.

At EduGenAI, each CO can create 1 or more API keys, assign licenses, and determine the authorisations for students, teachers and researchers. EduGenAI, and SURF as the hoster of the back-end of EduGenAI, will process the name, e-mail address, role (student, teacher, admin etc.), and institution of each person that has been assigned access. SURF AI-Hub will process the API key, the SRAM username of the manager, the CO of the manager, and (possibly in the future) the email of the manager.

EduGenAI only needs access to the usage per API-key for invoicing, because it does not plan to charge for individual use. Instead, EduGenAI is considering a flat rate. Excessive usage can be monitored through the number of requests per API-key. These data can be used to determine 'fair use' and for possible future billing of excessive usage.

4.3 Diagnostic Data

EduGenAI consists of a front-end (the webapp) with a database, and a back-end (the compute and hosting of the LLMs). Both elements generate logs about user activity.

4.3.1 EduGenAI webapp Diagnostic Data

EduGenAI logs information about the usage of its service. This logging contains the following types of personal data:

- The user ID.
- The user's email in plain text. The email address is needed for authentication from other systems, e.g. the LTI integration with the digital learning environment. It is also used for the integrations with SRAM and Entra ID.

The logs contain additional data that reveal information about individual user activities on EduGenAI, including the date and time of usage, the model used, and possibly the Persona used. However, EduGenAI is designed not to log any Content Data related to identifiable users. The logs do not contain any Content Data (the prompts and replies, or names of uploaded documents).

EduGenAI also inevitably collects the IP addresses of all users. This log is representative of what may be collected from administrators and end users. EduGenAI also collects error messages.

Figure 17: Example of usage logging in EduGenAI



```
1 {
2   "userId": "658848f7758ff0119c6abd060c751944257cdd6e73a3f85",
3   "email": "d.a.vandenberg@uva.nl",
4   "date": "2025-01-29T15:56:52.569Z",
5   "isInput": false,
6   "tokenAmount": 688,
7   "costs": 0.009241904,
8   "model": "gpt4o",
9   "type": "MESSAGE_USAGE",
10  "persona": "UvA AI Chat default",
11  "id": "569d73ec-3765-49f9-b11c-1873182ed578",
12 }
```

Once EduGenAI is hosted on the SURF AI-Hub, SURF EduGenAI will log the IP addresses and usernames (provided through SURFconext) for the initial setup and backup administration tasks (choosing the AI-

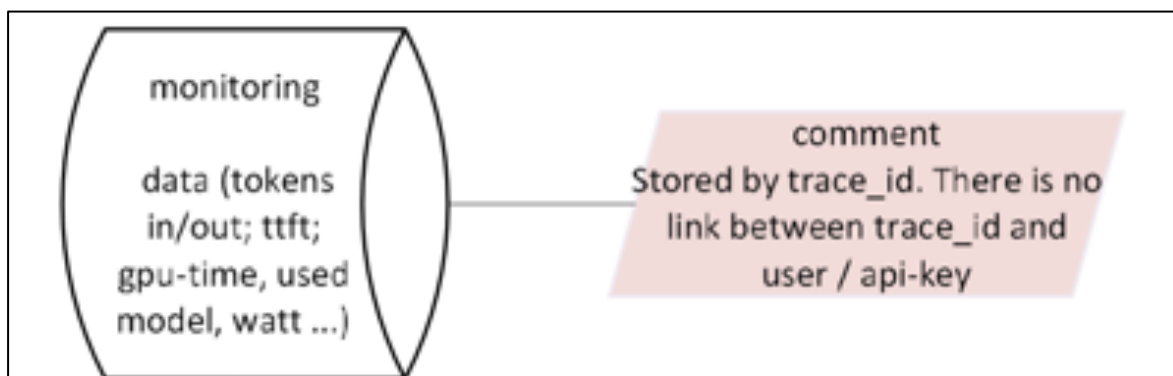
models available for the CO and end users). SURF plans to use these personal data for security monitoring and quality improvement.³⁶

4.3.2 Trace ID as linking pin

The logging of requests always contains a value called a 'Trace ID'. This value is unique to each request made to the AI-Hub through EduGenAI. Monitoring and logging by the AI-Hub is associated to this 'Trace ID', and not to an API key or username. Monitored usage is associated with an API-key. This means the monitoring happens at the organisational level, not at the level of a specific user. The Trace ID is shared from the AI-Hub's backend to EduGenAI's servers along with the results of queries.

This unique identifier, when combined with other types of logging relating to timestamps, RAG documents, and model parameters, is pseudonymous personal data.

Figure 18: Trace ID as linking pin



4.3.3 AI-Hub Diagnostic Data

The AI-Hub generates logfiles about the access by EduGenAI to the LLMs and management activities by CO admins, and stores these logs at most for 30 days. When shown to Privacy Company in March 2025, these logs still included names and usernames of admins managing the API-keys, but the AI-Hub is implementing processes to remove these directly identifying personal data from the logs.

The AI-Hub collects two primary types of logs. The first type relates to the database used for Retrieval Augmented Generation (see [Section 1.1.4](#)), the second type to the Administrator Dashboard and the AI-Hub's API endpoints.

RAG database

The AI-Hub collects the following Diagnostic Data relating to the RAG-documents and the database:

- a document ID,
- an owner ID

³⁶ E-mail SURF to Privacy Company, 27 March 2025.

- a file hash,
- a timestamp of when the document was created,
- a Boolean value that represents whether or not the indexing of a document has been completed,
- the name of the embedding model used to index a given document

The AI-Hub has explained that access to the Diagnostic Data about the logs is limited to a handful of authorised admins:

"Currently there are two groups with access to the database and logs: the core development team (now 4 people) and sysadmins. We do not give access if not needed."³⁷

Admin dashboard and API endpoints

Each implementation of EduGenAI is associated with an API key. This API key is associated with a single username within a CO or group using EduGenAI. Since all queries first pass the LiteLLM proxy stripping away metadata from end users such as their IP address, access to the API keys is registered with the single IP address from the EduGenAI webapp. This is LiteLLM's IP address (per CO or per SRAM group, depending on the configuration of LiteLLM). The (admin) usernames may however contain personal data.

The (admin) usernames of the API key holders are only visible to SRAM group managers at the CO and for the administrators at the AI-Hub. The administrators at the AI-Hub use this access to reach out to CO administrators using EduGenAI in case of an error, and, eventually, to monitor billing. The AI-Hub also uses this access to Diagnostic Data to help troubleshoot possible questions from the SRAM Group Managers. AI-Hub admins access these admin usernames through an admin dashboard. This admin dashboard is implemented using services from Grafana.³⁸

Figure 19: Example of AI Hub admin dashboard in Grafana

³⁷ E-mail AI-Hub to Privacy Company, 29 March 2025.

³⁸ Grafana, Grafana labs, undated, URL: <https://grafana.com/>, page last visited 31 March 2025.

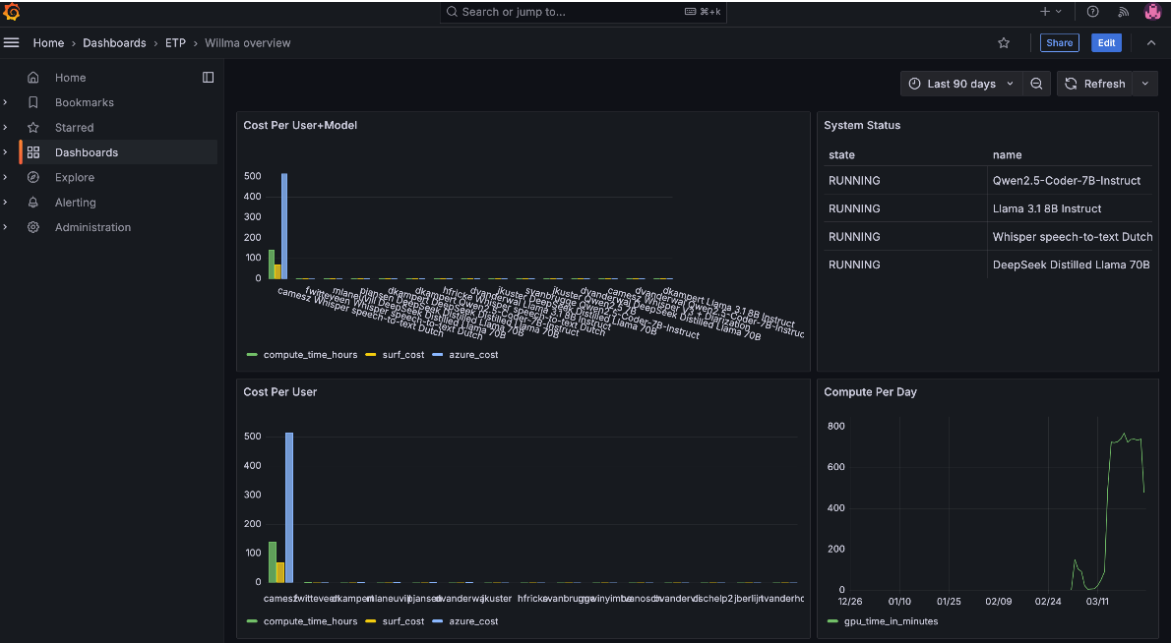
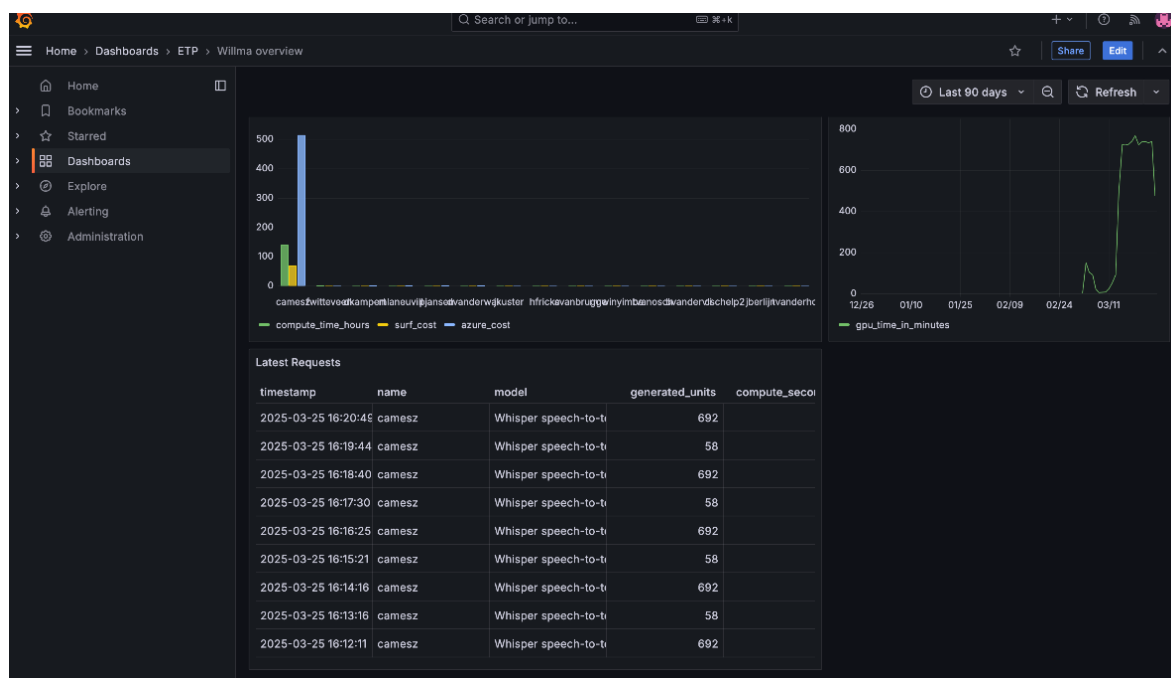


Figure 19 shows an example of this Grafana dashboard. The histogram “Cost Per User + Model” contains on the X-axis personal data in the form of the usernames of the API key owners.

Figure 20: Another example of AI Hub admin dashboard in Grafana



Responses from LLMs hosted on the AI-Hub currently include the usernames of the API key owner. The AI-Hub is going to remove these usernames in the future.

The SRAM owners within an CO have the ability to fetch API Keys, and combine these with the admin usernames they have granted access, to monitor how their organisation's EduGenAI application is being used.

The AI-Hub performs additional backend logging and monitoring, as shown in [Figure 21](#). These logs no longer contain identifiable data (since April 2025).

Figure 21: Example of (new) backend logging by AI Hub

```
2025-03-20 14:44:22,479 [INFO] willma: Session 3168459782378335837 finished by openai/whisper-large-v2 (764242b8-a74e-4996-9b47-44f4c5deae3)
2025-03-20 14:44:22,882 [INFO] willma: Currently: 0 active sessions.
2025-03-20 14:44:24,086 [INFO] willma: Received the following message: b'{"type": "kill_thread", "the_model_uid": "d3405d04-e69a-43d2-8df9-c5d0344baa2e", "payload": "Hanging Thread Found!"}'
2025-03-20 14:44:24,087 [INFO] willma: Parsed msg message: {"type": "kill_thread", "the_model_uid": "d3405d04-e69a-43d2-8df9-c5d0344baa2e", "payload": "Hanging Thread Found!"}
2025-03-20 14:44:24,087 [WARNING] willma: Message handling failed in mqtt consumer with message: {"type": "kill_thread", "the_model_uid": "d3405d04-e69a-43d2-8df9-c5d0344baa2e", "payload": "Hanging Thread Found!"}
2025-03-20 14:44:24,087 [WARNING] willma: Following error occurred: AttributeError
```

AI-Hub Development Goals.

- Remove the usernames of the API key owner from the SURF's API endpoint logging.
- Create dashboards with benchmarks for organisations, for example, to see how many tokens they have used, or what the environmental impact was.
- Develop a user friendly way to know whom to contact in the case of errors.

4.4 Support Data

Support services are not yet developed, but will consist of three layers:

1. The helpdesk from the CO, based on more extensive documentation EduGenAI will have to make available;
2. EduGenAI, for administrative support;
3. SURF AI-Hub, as third line support helping EduGenAI troubleshoot.

EduGenAI will have to exchange the following identifiers with SURF's AI-Hub in case it needs third line support:

- the Trace ID,
- the API key name (an alternative representation of the actual API key that provides protection against the API key being leaked),
- the username of the admin of a CO,
- the CO name.

4.5 Website Data

As explained in [Section 1.2](#), Website Data consist of two types of data: webserver access logs that register website visits, and Cookie Data.

SURF's AI-Hub provided Privacy Company with an example of the Apache webserver access logs relevant to the EduGenAI service. Privacy Company confirmed that the only personal data in these logs are the IP addresses of the users.

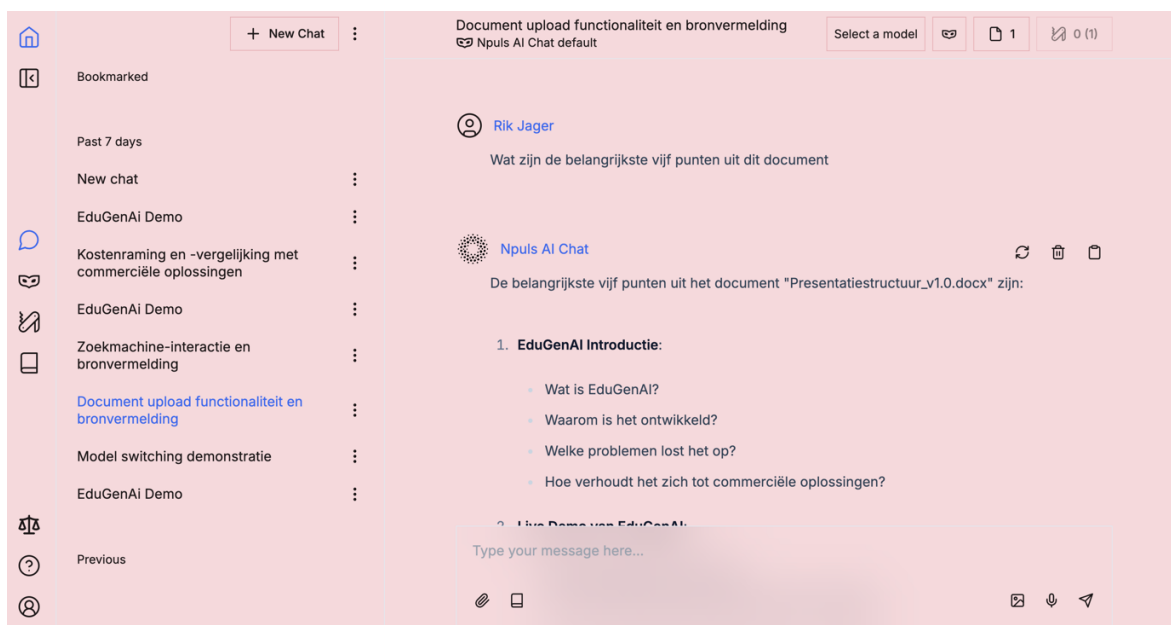
EduGenAI Development Goals

- Use cookies or the PGLite alternative to replace current chat storage in the webapp by chat storage in the end-user device. Only store the chat history on EduGenAI's servers if the user provides consent.
- Inform users about their options for local and cloud storage of their chat history.
- Draft a policy with the COs that provides the necessary information for informed consent.

4.6 Data Subject Access

End users of EduGenAI in its current version (hosted on Azure) can access the Content Data of their interactions with the service via the left sidebar, per prompt, or for example through 'Past 7 days', as shown in [Figure 22](#) below.

Figure 22: End user access to stored prompts



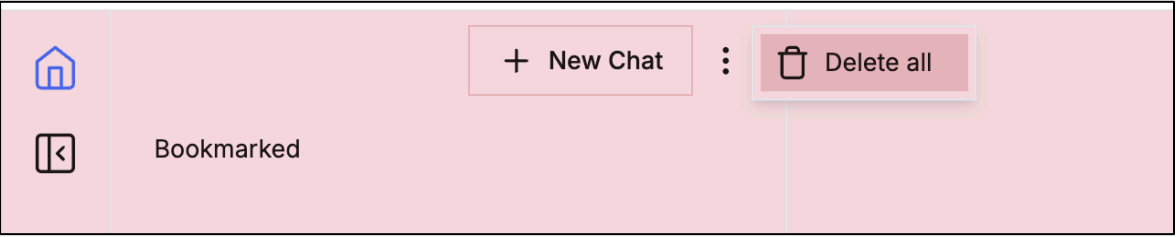
Deletion of Chat History and Uploaded Documents

User chat history (as currently hosted on Azure) is deleted 6 months after the user's last activity, unless a user has opted out of this storage. The uploaded documents are also deleted after this period.

Users can delete their chat history and uploaded documents from the database anytime, through the same button, if they choose to store the chat history on SURF's servers. In that case, users can choose to individually delete chats, or delete all chats at once. See [Figure 23](#) below.

If a user has uploaded the same document across multiple chats, the user should delete all of those chats to fully remove the document from the database. In that case, all metadata associated with these chats and documents are also deleted.

Figure 23: End user interface to delete chat history



Data Subject Access Requests EduGenAI

In the future, SURF can export Content Data (to the extent stored on SURF’s servers, and not locally in the end user device), Account and Diagnostic Data from the EduGenAI Postgres database. See [Table 1](#) below.

Table 1 - Data to be provided in reply to Data Subject Access Request

Table name	Data types	Description
User	user_id email opted_in first_message last_message	This table shows whether a user has opted in to sharing chat history.
User_Settings	user_id setting_key setting_value updated_at	This table shows the user’s settings configurations.
Persona	user_id id name description persona_message created_at published temperature topP model loading	This table shows the data associated with personae that have been built by a user.

Chat_Thread	user_id id persona_id bookmarked last_message_at created_at has_extensions name	This table shows the data associated with stored user chats (if available).
Document	doc_id persona_id chat_thread_id name VARCHAR(255) created_at	This table shows the data associated with the documents users have uploaded for the purposes of RAG.
Usage	usage_id model cost token_amount is_input date persona_id persona_name user_id	This table shows the data associated with a user's use of EduGenAI services, such the cost incurred by their requests.
Prompt	prompt_id name prompt creator_user_id created_at published	This table shows the data associated with stored user prompts (if available).
Message	chat_thread_id user_id id content created_at multimodal_image name	This table shows the data associated with stored user messages within chats (if available).

	role prompt_parent_id last_edit_at	
Citation	user_id id content chat_thread_id	This table shows the data associated with the citations EduGenAI provides along with the RAG documents (if available).
Extension	user_id id name description steps created_at headers functions published	The table shows the data associated with the custom extensions a user has created.
Extension_To_Chat- _Thread	user_id chat_thread_id extension_id	This table shows which extensions are enabled in which chat threads.
Group	group_id name description created_at start_date end_date	This table shows data associated with user groups.
Prompt_To_Group	persona_id group_id	This table shows which prompts users can use for groups.
Persona_To_Group	persona_id group_id	This table shows which personas users can use for their groups.
User_To_Group	user_id group_id role	This table shows which groups users are in.

Memory	id user_id content created_at updated_at	This table shows the data associated with content users have chosen to store in memory.
Project	project_id user_id name created_at color	This table shows the data associated with user created projects.
Relationship	relationship_id user_id parent_id child_id child_type	This table is for linking projects together.

EduGenAI Development Goals

- Create a dedicated contact method for questions and requests from users (related to the exercise of their data subjects' rights).
- Develop a DIY Data Subject Access tool that allows users to download their entire chat history from the server, and provide access to the Diagnostic Data registered in the back-end.
- Later versions of this tool should offer three options:
 - Download the chat history (if users have consented to storage in EduGenAI's back-end)
 - Download the Diagnostic Data from the Postgres database
 - Download both
- Offer an import and export tool for users that store the chat history in cookies in their browser.
- Develop export options for the Support Data.

SURF AI-Hub and admin data subject access

The AI-Hub does not process personal data relevant to end users, only the CO admins do. This is because SURF's AI-Hub only stores the IP addresses of the LiteLLM, not the IP addresses of end users, as an obfuscating measure.

CO admins have an API to manage RAG-documents when they are stored in the SURF AI-Hub, to for example complete DSAR requests from end users.

Admins can use the API to manage the documents. With the API admins can see the documents, upload documents or delete them. This is all handled at group level.

The AI-Hub has an Apache webserver access log containing information about the administration activities of the CO-admins through the API with their IP address.

SURF acknowledges it needs to develop an export option for Support Data filed by admins.

AI-Hub Development Goal

- Develop a DIY Data Subject Access tool that allows admins to download the relevant Diagnostic Data about their API usage.
- Provide access to the contents of support tickets and metadata about the Support Data in reply to a DSAR from an admin.

5 Privacy Controls for COs

SURF will offer several privacy controls to admins of COs. This section describes future options for COs to choose different models and filters. The UvA/HvA development team is simultaneously building these same options in the current set-up on Azure, but these developments are out of scope of this DPIA.

5.1 Choice of LLM

Organisations will be able to limit the amount of available AI-model choices for users, to for example only allow use of the on-premises LLMs hosted in the SURF AI-Hub.

EduGenAI Development Goal

- Instead of GPT 4.0, enable admins of COs to choose another LLM as default for the first prompt if a user logs in for the first time.

5.2 Measures against incorrect personal data

EduGenAI will apply a number of measures against incorrect personal data, as described in more detail in [Section 3.1.1](#) above. COs will be able to exercise control over the following options:

- Get access to the Presidio filtered chunks, and tweak and disable the Presidio personal data masking filter, permanently, for specific tasks, or per faculty.

- Decide on the content and frequency of alerts presented to end users that they must verify the accuracy of an answer.
- Help EduGenAI to determine the effectivity of measures such as showing two replies from two LLMs to one reply.
- Help EduGenAI to develop learning materials for prompting, ao to prevent biases.
- Create a small education AI-model based on the historical teaching materials per faculty/organisation, and use this as a Persona.
- Help EduGenAI develop responsible AI filtering that fully respects European Human Rights, Users can decide per Persona if a filter is necessary.
- Use (pseudonymised) chat histories for research purposes (only for accuracy testing, not for training), and help test accuracy following agreed benchmarks.

EduGenAI Development Goals

- Create the mitigating options for COs mentioned above.
- Develop a form for users to provide explicit consent for the use of their pseudonymised chat histories for research purposes.

5.3 Determining retention periods

EduGenAI will by default store the chat histories locally, via cookies in the browser or via PGLite in the device of the end-user. End-users themselves can then decide how long they wish to retain their conversations.

With regard to the Personae, the admins of education organisations will be able to centrally determine organisation-wide retention periods for the Persona.

6 Purposes of the processing

6.1 Purposes EduGenAI

EduGenAI processes personal data for the following 9 purposes:

1. Provide secure access to the webapp to authorised end-users, teachers and researchers.
2. Enable users to interact with different on-premises and cloud AI-models in a privacy friendly way.
3. Provide grounding, including permanent grounding via Personae.
4. Help users exercise their data subject rights.
5. Apply specific data minimisation and pseudonymisation measures to preserve the privacy of users.

6. Provide a secure and well-functioning service, including detection of unauthorised access attempts and protection against malicious actors and attacks.
7. Provide support.
8. Provide statistics to the education organisation about daily or monthly active users.
9. Perform accuracy research.

6.1.1 Access management

SURF currently provides access to EduGenAI through its existing authentication and authorisation system SURF Research Access Management (SRAM). SRAM arranges secure access for web and non-web services, using CO accounts wherever possible.³⁹ In the near future, SURF will use SURFconext for access to EduGenAI. Both SURFconext and SRAM are out of scope of this DPIA.

For the Personae, EduGenAI processes group access allocations, manages the user groups for shared personas and validates access rights to specific personae. This processing includes the management of Personae created for cross-institutional groups.

For researchers, EduGenAI will process the authentication for API access, and validate research approval. Access to the API-keys is managed through Lite LLM (See [Section 1.1.5](#) above).

6.1.2 Process user interactions

The core purpose of EduGenAI is to process the interactions of users with different on-premises and cloud AI-models.

6.1.3 Provide incidental and permanent grounding

EduGenAI offers users the option to upload incidental documents per request and create permanently grounded Personae.

6.1.4 Help users exercise data subjects rights

EduGenAI helps users exercise their data subject rights by enabling users to delete their chat history. Deletion automatically results in deletion of all Diagnostic Data. In the future, users will be able to process the chat history exclusively in their browser. EduGenAI will use cookies to maintain conversation context between sessions.

6.1.5 Preserve the privacy of users

EduGenAI processes personal data for a number of specific data minimisation and pseudonymisation measures:

1. Strip all metadata (IP-addresses, cookies, identifiers) from the user queries.
2. Apply a personal data masking filter to the contents of queries.

³⁹ SURF, About SURF Research Access Management, URL: <https://www.surf.nl/en/services/surf-research-access-management>, URL: <https://www.surf.nl/en/services/surf-research-access-management>.

3. Allow the COs to determine what LLMs can be accessed (only on-premises, or also cloud LLMs).

6.1.6 Protect against abuse

To protect the service against unauthorised access or excessive usage, the AI-Hub will take the following measures:

- Logging of costs, enabling early detection of abuse. Once the dashboards are implemented, admins of the COs can help detect such abuse.
- Apply Network Security Groups (NSGs) on subnets to restrict traffic to authorised IP addresses.
- Implement stateful firewall with route tables to enforce all outgoing traffic via inspection (implemented in new production environment).
- Protect against attacks such as SQL injection.
- Apply Rate Limiting to prevent abuse due to high load.
- Apply DDos mitigations.
- Use VLAN with its own IP-range.
- Require 2FA for sysadmins and developers, investigate the necessity for 2FA for back office users.
- Use SURF authentication and group management (SRAM).

6.1.7 Provide support

EduGenAI will primarily facilitate self-service data management by the COs.

EduGenAI will enable the education organisations to determine their preferences, and link these preferences to accounts. This includes opt-in choices relating to for example the accessible LLMs, search engines or open learning materials, and removal requests from users.

If the helpdesk of the education organisation cannot help users with questions or issues, EduGenAI will provide second line support (via the CO).

6.1.8 Provide usage statistics

EduGenAI will use personal data to provide a dashboard with statistics to each CO about the daily or monthly number of requests, and statistics about for example environmental impact.

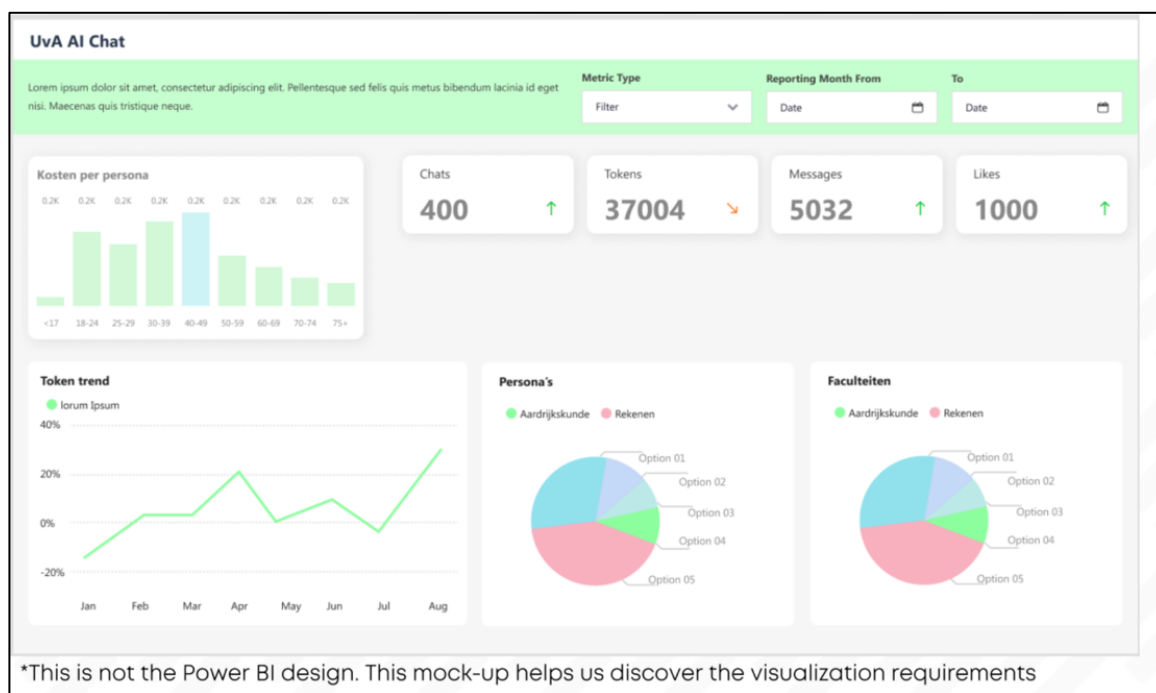
The personal data used for the reports are:

- e-mail (only to link a user to a CO, never reporting on an individually identifiable basis)
- date
- isInput
- tokenAmount
- costs
- model
- persona

The metrics will include:

- Number of chats
- Number of tokens
- Number of messages
- Number of messages with likes/dislikes
- Costs

Figure 24: Screenshot of mock-up metrics for COs (in current Azure set-up)



6.1.9 Accuracy and quality research

To ensure the effectiveness of measures to prevent overreliance on generative AI output, and to measure the quality of replies from different LLMs, EduGenAI will implement a feature that tracks 'likes' from users. These likes will be used, for example, to track the perceived quality of the model outputs by users when EduGenAI changes the default models.

Additionally, EduGenAI will process pseudonymised chat histories for accuracy research, if users have provided explicit consent for this purpose.

6.2 Purpose SURF (Hosting)

The EduGenAI web application will be hosted by SURF, but not within SURF's AI-Hub. This means SURF's root admins (but not AI-Hub's root admins) have access to all personal data, including Account, Content, Diagnostic, third line Support and Website Data.

As hosting provider, SURF should contractually agree with the education organisations that it may only process the personal data that it obtains from, about, or via the use of EduGenAI as a result of the technical hosting of the service in its own datacentre for 3 purposes:

1. Technically provide and improve the hosting service, including
 - a. Monitoring system performance, including central logging for platform management
 - b. Managing technical user sessions (with the trace ID)
 - c. Ensuring availability
 - d. Technical troubleshooting, including third line user support
2. Keep the service up-to-date, including by installing new versions of the operating system management layers and LLMs, and
3. Keep the service and web application secure, including detection of unauthorised access attempts and protection against malicious actors and attacks, as well as perimeter security incident management of data traffic to the computing cluster.

With regard to compliance with legal obligations, it is theoretically possible that a government authority orders SURF (as processor) to disclose usage data of a specific user. In that case, SURF should refer back to the CO. In the unlikely circumstance that the authority insists on information from SURF, and SURF is not allowed to inform the education organisation, SURF should commit to seek legal advice to ensure the order is legal, and commit to only comply to the extent strictly necessary.

EduGenAI Development Goal

- Include a procedure in the data processing agreement with steps SURF as provider of EduGenAI will take to prevent taking decisions about disclosure of personal data.

6.3 Purposes SURF's AI-Hub (Hosting)

To provide a secure service, SURF's AI-Hub will log technical session data, not with a user or device identifier, but with a request identifier (Trace ID).

Additionally, the data processing agreement should specify when SURF's AI-Hub necessarily has to further process some personal data for purposes that cannot be fulfilled by the education organisations themselves:

1. Create aggregated statistical, non-personal analytics from data with pseudonymized identifiers (such as usage logs containing unique, pseudonymized identifiers) amongst others, to calculate a reasonable average usage, to support billing, and to map excessive usage.
2. Send invoices to the COs, financial bookkeeping
3. Calculate statistics related to use of LLMs / compute for internal reporting and business modelling, such as technical infrastructure forecasting, and climate impact reporting.
4. Comply with legal obligations.

AI-Hub Development Goals

- Include a list of authorised further processing purposes in the data processing agreement to ensure SURF can perform these necessary data processing for these specific purposes.
- Include a procedure in the data processing agreement with steps SURF as provider of the AI-Hub will take to prevent taking decisions about disclosure of personal data to government authorities.

7 Processor or (joint) controller

This section assesses the data protection roles of SURF and education organisations in the context of EduGenAI.

7.1 Definitions

The GDPR contains definitions of the different roles of parties involved in the processing of data: (joint) controller, processor and sub processor.

Article 4(7) of the GDPR defines the (joint) **controller** as:

"the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law."

Article 26 of the GDPR stipulates that where two or more data controllers jointly determine the purposes and means of a processing, they are joint controllers. Joint controllers must determine their respective responsibilities for compliance with obligations under the GDPR in a transparent manner, especially towards data subjects, in an arrangement between them.

Article 4(8) of the GDPR defines a **processor** as:

"a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller."

A sub processor is another processor engaged by a processor that assists in the processing of personal data on behalf of a data controller.

Article 28 GDPR sets out various obligations of processors towards the controllers for whom they process data. Article 28(3) GDPR contains specific obligations for the processor. Such obligations include only processing personal data in accordance with documented instructions from the data controller and cooperating with audits by a data controller. Article 28(4) GDPR stipulates that a data processor may use sub processors to perform specific tasks for the data controller but only with the prior authorisation of the data controller.

When data protection roles are assessed, the formal contractual division of roles is not leading nor decisive. The actual role of a party must primarily be determined on the basis of factual circumstances.

7.2 Education organisations as data controllers

Education organisations that decide to give their employees and students access to EduGenAI can exercise some influence over the personal data processing, by providing AI-literacy training, providing guidance to users what files they should and shouldn't upload, by choosing the LLMs they make available, and by allowing or disabling access to the internet via one or more search engines.

COs can set sharing rights for prompts with the consent of the participants. These sharing rights are applied within EduGenAI. COs can also delete personal licenses and manage general access through SRAM groups.

COs will be able to influence what services LiteLLM uses for the pre processing of documents stored in the AI-Hub or the front-end database for Personae for Retrieval Augmented Generation (See [Section 1.1.4](#)). For example, EduGenAI and the AI-Hub intend to implement on-premises LLM for this preprocessing. The COs also can change the system prompt (See [Section 1.1.3](#)).

While COs can take organisational measures, such as drafting policies to warn users not to share personal data and not disabling the personal data masking filter, such organisational measures are less effective than technical measures. COs depend on EduGenAI for technical measures such as the development of privacy preserving functionalities, modalities to prevent overreliance and reporting about the quality and accuracy of the service and the different LLMs. The interactive development of features between SURF and the COs points to a joint controllership between the COs and SURF for the key features of EduGenAI.

As a sidenote: COs also cannot influence the available information in the LLMs, including the personal data used as training data. The providers of these AI-models have to be qualified as third parties (independent data controllers), or as sub processors of SURF's AI-Hub (if SURF negotiates a data processing agreement with such a third party). This part of the data processing is out of scope of this DPIA.

7.3 SURF as data processor

As quoted in [Section 5.1](#), SURF as technical hoster of EduGenAI back-end in the AI-Hub in its own data centre should act as data processor for the COs. SURF can process four of the five categories of personal data as data processor: Account, Diagnostic, Support and Website Data. For the processing of Content Data a role as joint controller is more plausible. This will be elaborated in [Section 6.4](#) below.

7.3.1 Account Data

With access managed by SRAM and SURFconext, SURF acts a data processor for the Account Data of the COs. The Account Data are central to the exercise of data subjects' rights. As data processor, SURF must assist the COs with the exercise of data subjects' rights. If COs can comply with the obligation to help data subjects' rights will be assessed in [Section 16](#) of this DPIA.

7.3.2 Diagnostic Data

EduGenAI processes Diagnostic Data about the usage of EduGenAI for all three data processor purposes. As part of providing the service, SURF also provides access to usage statistics based on the usage metadata (including message ID, trace ID, user ID).

7.3.3 Support Data

SURF also acts as a data processor for the COs for the processing of Support Data. The COs should offer first line support to their users and only escalate to EduGenAI in case they cannot resolve an issue themselves. The COs can ask EduGenAI to manage settings, access rights for users and groups, and troubleshoot in relation to user support requests filed at the CO helpdesk. EduGenAI in turn can escalate to SURF's AI-Hub as third line support. The AI-Hub already generates dashboards (as shown in [Figure 15](#) and [Figure 16](#)) that provide the necessary input for a solution.

7.3.4 Website Data

As part of the security purpose, SURF will process some Website Data relating to the EduGenAI webapp for security purposes, to detect unauthorised access attempts.

7.3.5 Contents of future data processing agreement

By offering a data processing agreement to the COs, SURF can enable the organisations to instruct SURF to only process the identified four categories of personal data for three authorised main purposes (with the specific sub purposes detailed in [Table 1](#)) and only when proportional.

1. Technically provide and improve the hosting service (with the sub purposes identified in [Section 5](#))
2. Keep the service up-to-date, and
3. Keep the service secure.

To provide effective control to the COs over the data processing by SURF as processor, Privacy Company recommends that the data processing agreement also includes a prohibition on further processing for purposes determined by SURF as hoster of the AI-Hub, with a list of specifically excluded types of further processing:

- Profiling users
- Monitoring individual user behaviour
- Analysing the content of files uploaded to the database for chunking
- Construction of user behavioural profiles
- Sharing of data with AI model providers if the LLM is hosted on-premises
- Marketing or commercial purposes

However, formal contractual roles are not decisive. To better distinguish between SURF's role for the hosting, and SURF's role as provider of the AI-system to the COs, this DPIA assesses to what extent SURF in practice determines the purposes and means of the processing. [Section 6.4](#) below analyses when the COs and SURF

have to be qualified as joint controllers (for the Content Data). [Section 6.5](#) below analyses when SURF necessarily has to act as an independent data controller, by further processing specific personal data for specific purposes that cannot be influenced by the COs.

7.4 SURF and the education organisations as joint controllers

According to three judgments of the European Court of Justice⁴⁰ parties can factually become joint controllers, even if the roles are unevenly distributed, and also if the party that is the customer does not have access to the personal data processed by the party that supplies a service.

This Section analyses when there is an inextricable link between decisions of the two parties about the nature and volume of the data processing, including taking data minimisation measures. Additionally, the determination of the retention periods is an important decision on the means of the processing, but the topic of data retention is separately addressed in [Section 11](#) of this DPIA.

EduGenAI is developed and designed as a service for education organisations to provide privacy-friendly access to multiple LLMs (both on-premises and in third party clouds) and enable users to ground their prompts in a transparent and controlled way, while preventing overreliance on AI. To achieve these central purposes of the data processing, the education organisations have to take decisions about both the means and the purposes of the data processing, complementing the decisions already made by the EduGenAI developers. As the EDPB writes:

“Decisions can be considered as converging on purposes and means if they complement each other and are necessary for the processing to take place in such manner that they have a tangible impact on the determination of the purposes and means of the processing.”⁴¹

For example, this means the intended key purposes of the processing cannot be achieved without both parties’ participation in decision-making about the purposes and means.

7.4.1 Content Data

As outlined in the introduction SURF and the COs both take decisions about the processing of Content Data through EduGenAI. As described in [Section 6.2](#) the COs exercise control over the purposes of the processing by deciding which users are allowed to create a Persona and who can access the Persona. By granting them a license, the COs enable end-users and teachers to decide what Content Data they upload as part of the grounding. While EduGenAI offers a personal data masking filter to help protect the privacy of users that are part of the dialogue and RAG, COs can decide to disable personal data masking for specific SRAM-

⁴⁰ European Court of Justice, C-40/17, 29 July 2019, Fashion ID GmbH & Co. KG v Verbraucherzentrale NRW eV, ECLI:EU:C:2019:629, C210/16, 5 June 2018, Unabhängiges Landeszentrum für Datenschutz Schleswig-Holstein versus Wirtschaftsakademie Schleswig-Holstein GmbH, ECLI:EU:C:2018:388. See in particular par. 38-43. Also see: C-25/17, 10 July 2018, Tietosuoja-valtuutus versus Jehovah’s Witnesses — Religious Community, ECLI:EU:C:2018:551, par. 66-69.

⁴¹ EDPB guidelines 2020/7.

groups. Additionally, SURF and the COs jointly determine the processing of 'likes' for accuracy and quality research.

The COs and EduGenAI share responsibility for the use of the LLMs, search engines and LTIs. While SURF as developer of EduGenAI decides on the catalogue of available LLMs and search engines, and the contractual arrangements with these third parties, each CO can decide which of the potentially available LLMs and search engines their employees and students can access.

The COs and EduGenAI also jointly determine the means by which they preserve the privacy of users and prevent the use of inaccurate personal data. They can jointly apply the following measures:

Apply effective warnings

EduGenAI aims to collaborate with the COs on the development of innovative new warning mechanisms to alert users to the risk of overreliance. Additionally, COs share the responsibility for the processing of accurate personal data, and will have to take additional (organisational) measures. For example, by providing AI awareness trainings and drafting policies to ensure that users do not use EduGenAI for inappropriate tasks.

Determine when to show answers from two different LLMs

The web app design of the service enables EduGenAI to show two answers to a prompt, from two different LLMs. This may be too costly, also in view of the environmental impact for each prompt, but it is technically possible to create an extra layer in EduGenAI that makes smart suggestions for end users, based on statistical analysis of the best achieving model per type of prompt, in relation to the specific CO.

Train users in better prompting

The user interface currently contains 4 suggestions for types of prompts a user may use. This is very minimalistic. SURF and the COs should together create learning materials about the art of prompting, and instructions to recognise and minimise bias.

Decide about the use of personal data masking filter, develop filter mechanisms that respect European Human Rights and decide on the use of Microsoft's in-built RAI filter for the OpenAI LLMs

As described in [Section 6.2](#) above, COs can change the system prompts, and disable RAI-filtering. Decisions about the filtering of prompts and replies involve decisions about the processing of personal data. These shared decisions about the accuracy of the personal data processing make the COs joint controllers with EduGenAI. Together with SURF as manager of EduGenAI the COs should research the best filtering and warning measures against overreliance on AI, and jointly define rules for responsible AI filtering.

Both COs and EduGenAI take decisions on the means to jointly achieve the purpose of providing privacy friendly access to LLMs in a way that complement each other. That's why the processing in the intended way (to achieve the described purposes) would not be possible without both parties' participation in the means.

As Advocate General Bot noted in his Opinion to the ECJ in the case about the use of Facebook Pages by the Schleswig Holstein Wirtschaftsakademie, parties can become joint controllers if they make the data processing possible. And their joint controllership is further evidenced by the fact that they can also decide to terminate the processing:

“By making the processing of the personal data of users of the fan page possible, the administrator is adhering to the system put in place by Facebook. (...) Inasmuch as he agrees to the means and purposes of the processing of personal data, as predefined by Facebook, a fan page administrator must be regarded as having participated in the determination of those means and purposes. Moreover, just as a fan page administrator has a decisive influence over the commencement of the processing of the personal data of people who visit his fan page, he also has power to bring that data processing to an end, by closing the page down.”⁴²

The COs can stop using EduGenAI altogether, or delete Personae, and withdraw individual licenses. Hence, they can take decisions to bring the data processing to an end.

7.5 SURF as independent data controller

The use of EduGenAI results in five types of data processing by SURF as provider of EduGenAI and as manager of the AI-Hub that cannot be part of the instructions of the COs to SURF as data processor, and also, cannot be part of a joint controller agreement. This section identifies 5 specific purposes for which SURF necessarily has to process personal data without any influence from the COs.

1. Use of a cookie or PGLite to enable local storage of the chat history.
2. Usage analytics.
3. Billing.
4. LLM usage statistics for technical forecasting, to calculate a reasonable average usage, to support billing, and to map excessive usage.
5. Compliance with legal obligations.

SURF should act as independent data controller for the use of a cookie (or the PGLite alternative) that allows users to keep their chat history in their own device. Without such a legal independence construction, the COs could demand access from SURF (as processor, or as joint controller) to individual chat histories stored in the EduGenAI database.

SURF also cannot be a data processor or joint controller for some other purposes such as invoicing. If SURF were a processor, a CO could instruct SURF to stop processing for this purpose. SURF can also not be qualified as a joint controller with the COs for the four remaining purposes, because SURF unilaterally has to take these decisions to be able to offer this service in a commercially sustainable way, and to comply with the law.

⁴² CJEU, Opinion of Advocate General Bot, Case C-210/16, ECLI:EU:C:2017:796, par. 56.

7.5.1 Use of a cookie for local chat history

As explained in [Section 1.2](#), EduGenAI will set a cookie in the future to allow users to store the chat history exclusively in their browser (and not in the EduGenAI database).

7.5.2 Non-personal usage analytics

SURF needs to process usage logs from EduGenAI with pseudonymised identifiers to create aggregated statistical, non-personal analytics to calculate a reasonable average usage, to support billing, and to map excessive usage.

7.5.3 Billing

SURF needs to send invoices to the COs, and keep financial records in accounting with aggregate usage records per CO (from the AI-Hub logs).

7.5.4 LLM usage statistics

SURF needs to calculate statistics related to use of LLMs and compute capacity for internal reporting and business modelling, such as technical infrastructure forecasting, and AI-Hub climate impact reporting.

7.5.5 Compliance with legal obligations

As explained in [Section **Error! Reference source not found.**](#) SURF may incidentally be forced by law enforcement, authorities or courts to provide some personal data. Once EduGenAI has implemented the development goal to only store the chat history locally, in the users' browser, SURF and root admins generally can no longer be compelled to provide Content Data to government authorities from SURF servers. However, SURF EduGenAI root admins will still be able to access all other personal data, and all Content Data in the RAG-documents and their vectors, and also to some chat histories but only if the users have consented to share those with EduGenAI, and these pseudonymised data can be reidentified.

If SURF has verified that the order is legitimate, and SURF must comply, it has to take the decision to disclose as independent data controller, not as a data processor.

The EDPS explained this joint controllership in its report about the use of Microsoft 365 by the European Commission:

"When Microsoft processes personal data in order to comply with its legal obligations, such processing cannot be considered as effectively falling within the provision of online services and is not carried out on the Commission's behalf."⁴³

Table 2 - Overview of roles and purposes

⁴³ Ibid.

SURF processor hosting EduGenAI webapp and AI-Hub	SURF EduGenAI joint controller	SURF independent controller
Provide and improve the hosting service - Monitoring system performance, including central logging for platform management - Managing technical user sessions (with the trace ID) - Ensuring availability - Technical troubleshooting, including second and third line user support - Usage statistics and CO2 exhaust metrics	Access management (through Conext/SRAM)	Use a cookie to enable local chat history
	Enable users to interact with different <i>on-premises</i> and cloud AI-models in a privacy friendly way.	EduGenAI usage analytics
	Prevent overreliance on AI	
Keep the service up to date Installing new versions of the operating system management layers and LLM	Enable incidental and permanent grounding	Billing
Keep the service secure - Protect against attacks such as SQL injection. - Apply Rate Limiting to prevent abuse due to high load. - Apply DDos mitigations. - Security incident management of data traffic to the computing cluster. - Protect against abuse.	Preserve the privacy of users	LLM usage statistics for forecasting
		Comply with legal obligations
Help exercise data subjects' rights	Perform accuracy and quality research	Reply to data subjects' rights requests

7.6 Roles of LLMs and search engines

If EduGenAI includes access to commercial cloud LLMs, that LLM may either be a processor or an independent data controller. Microsoft offers a data processing agreement for the use of OpenAI in a private Azure tenant. Microsoft assures that OpenAI will not be able to 'learn' from the dialogues.

One of the future development goals of EduGenAI is to include access to the French Mistral cloud LLM. It is not clear if Mistral offers a data processing agreement for this access.

Similarly, it is not clear under what conditions Anthropic offers access to Claude, or Meta to the (cloud version of) Llama.

If SURF uses an open source LLM and deploys it on-premises, SURF offers access to this LLM as a processor, and cannot use any of the Content Data to retrain the model. EduGenAI and SURF's AI-Hub are both in agreement that data provided by end users and COs will not be used for further training of LLMs without a formal agreement with a CO. If a specific department/faculty in a CO explicitly asks SURF to retrain their pseudonymised Content Data to retrain (a specific smaller version of) an existing model, SURF will become a joint controller for those data with the CO.

8 Interests in the data processing

This paragraph outlines the interests of SURF and of the Dutch Education sector in the data processing by privacy friendly generative AI services. The interests of Dutch education organisations may align with the interests of their employees and students, or the interests of the population at large (whose personal data may be processed by EduGenAI as part of the prompts or the grounding). However, this paragraph does not go into the fundamental data protection rights and interests of data subjects. How their rights relate to the interests of SURF and the Dutch education organisations will be analysed in part B of this DPIA.

8.1 Interests SURF

SURF agrees with the aspiration of the Dutch government to be a front-runner in Europe with the adoption of responsible generative AI:

"The Netherlands aspires to be a front-runner within Europe in the application and regulation of safe and just generative AI and promotes a strong AI ecosystem in the Netherlands and the EU, in which responsible generative AI can thrive."⁴⁴

In a presentation for the management board, SURF has formulated its own ambition as follows:

"In the transformative period of 2022-2027, SURF will lead the Dutch education and research sectors into a new era of digital excellence powered by Artificial Intelligence. As an IT cooperative with deep technical roots and a strong community focus, we will pioneer innovative AI applications that not only enhance academic endeavours and education standards but also set benchmarks and guidelines for responsible use. Our vision is to foster a robust AI ecosystem that is accessible,

⁴⁴ Dutch government-wide vision on generative AI of the Netherlands, 17 January 2024.

sustainable, and forward-thinking, delivering state-of-the-art services and infrastructure while empowering our members through a shared knowledge base and collaborative innovation."⁴⁵

SURF has an ethical interest to support research with innovative but GDPR and AI Act compliant AI technologies.

For GDPR and AI-Act compliance reasons SURF wants to promote safe and responsible AI integration in education. As part of the interest in safe and responsible AI, SURF has already commissioned a DPIA on Microsoft 365 Copilot.

SURF strives to have control over the guardrails, and wants to work with the COs develop a commonly accepted responsible AI-filter that complies with European human rights. A content filter shouldn't only protect against biases, but also, prevent over filtering due to stricter norms in non-EU countries about ethical topics such as self-harm, euthanasia, gender and sexual orientation, or abortion.

SURF is in the process of structuring a statement on the use of generative AI by education organisations. This statement will be based on three key insights:

1. Generative AI should be helping students and the education and research organisations.
2. SURF and the education and research organisations have strong responsibilities for their use and development
3. Digital sovereignty and the relation to 'big-tech' are big challenges.

SURF attaches great value to digital sovereignty, and writes:

"To achieve a digital environment based on public values, it is necessary to have digital sovereignty. This enables you to direct or influence. It allows you to weigh the desired balance of public values per context. This translates into conditions for commercial suppliers, choice of open source for (in-house) proprietary IT and agreements for cooperative facilities through SURF and/or other consortia."⁴⁶

With EduGenAI, SURF can flexibly integrate multiple AI models, both on-premises and with access to existing commercial cloud services. This architectural choice enables SURF to rapidly respond to requests from COs to geopolitical developments, and for example expand the EduGenAI service with extra on-premises LLMs.

8.2 Interests education organisations

Like SURF, Dutch education organisations, as part of the public sector, have a vested interest in compliance with legal obligations, specifically, to safeguard the security and privacy of users of the tools they offer for education purposes. According to statistics from the national statistics bureau CBS, half of the people in the

⁴⁵ E-mail from SURF to Privacy Company, 18 July 2024.

⁴⁶ E-mail SURF to Privacy Company, 18 July 2024.

Netherlands aged 18 to 25 years used generative AI in 2024.⁴⁷ The number may even be higher amongst students. According to Microsoft, 75% of employees already use AI at work.⁴⁸ The rapid increase in use of generative AI services and the wide adoption by students necessitate that Dutch education organisations familiarise themselves with generative AI-tools.

The education organisations have an interest in providing equal access to AI tools to authorised users.

If education organisations do not offer GDPR-compliant AI-services to employees and students, the odds are high that they will use consumer services from third party providers (at work or at home), services without an education agreement. If employees use such non-contracted AI-services for work purposes, they will likely violate internal policy rules related to privacy and security. In fact, most education organisations take all kinds of security measures to prevent use of shadow IT, like the use of consumer data transfer services. Use of consumer generative AI-tools could easily lead to personal data breaches and security incidents if users share confidential information with the chatbots, or sensitive personal data about themselves or other persons. Therefore, organisations have a strong security interest to negotiate licenses for GDPR-compliant services.

Many generative AI services claim that use of their services can lead to significant efficiency improvements, if employees have to spend less time on daily tasks such as creating summaries and drafting texts. Privacy Company has not been able to find objective research that supports this claim. In fact, the CEO of Microsoft recently explained there is no business value in AI yet.⁴⁹ Such research would also have to measure the time spent on carefully reading the replies to detect inaccuracies, and time spent to restyle and rewrite to prevent banalities.

However, improved access to internal curricular documents can help students retrieve and interact with learning materials available within a faculty or group, or even from other education organisations teaching similar topics. Such information may currently be poorly accessible for students due to poor design of the intranet, or because the relevant bits are snowed in under piles of irrelevant data. The inclusion in EduGenAI of 'Personae', mini-GPT's based on information extracted from documents a user has uploaded, can potentially save students and teachers time.

Education organisations have clear financial (budgetary) interests in getting more work done faster by fewer people, without having to pay significantly higher costs for access to commercial generative AI-services.

⁴⁷ CBS, Bijna kwart Nederlanders gebruikt kunstmatige intelligentie zoals ChatGPT, 3 September 2024, URL:

<https://www.cbs.nl/nl-nl/nieuws/2024/36/bijna-kwart-nederlanders-gebruikt-kunstmatige-intelligentie-zoals-chatgpt>.

⁴⁸ Microsoft and LinkedIn, 2024 Work Trend Index Annual Report, 8 May 2024, URL: <https://www.microsoft.com/en-us/worklab/work-trend-index/ai-at-work-is-here-now-comes-the-hard-part>.

⁴⁹ Futurism, Microsoft CEO Admits That AI Is Generating Basically No Value, 22 February 2025, URL: <https://futurism.com/microsoft-ceo-ai-generating-no-value>.

Finally, education organisations with more than 1.000 users are legally required to report their CO2 exhaust based on EU climate law.⁵⁰ Smaller education organisations also have moral interests in sustainability, and have committed to contribute to the goals from the Paris accord. Many education organisations already measure and monitor their CO2-exhaust and energy usage, and publish annual accounts, such as the University of Amsterdam.⁵¹

9 Transfer of personal data outside of the EU

EduGenAI is designed with the purpose to allow education COs to prevent personal data transfers outside of the Netherlands. Starting in September 2025, SURF will gradually offer access to the EduGenAI service hosted in SURF's own data centre, with access to open source LLMs hosted in that same data centre.

If COs allow such access, users can also access different cloud LLMs, such as Mistral in France, but also from OpenAI as hosted by Microsoft on Azure. To support COs in their own due diligence when enabling access to cloud LLMs, this section provides an analysis of data transfer considerations pertinent to the use of one of the prominent cloud LLM options, OpenAI on Microsoft Azure.

9.1 Locations OpenAI on Microsoft Azure

Microsoft explains that the data processing by Azure is part of its EU Data Boundary commitment and that the scope of the EU Data Boundary includes both Customer Content Data and personal data:

"The EU Data Boundary is a geographically defined boundary within which Microsoft has committed to store and process Customer Data and personal data for our Microsoft enterprise online services, including Azure, Dynamics 365, Power Platform, and Microsoft 365. Professional Services Data will be stored at rest for these services. These commitments are subject to limited circumstances where Customer Data, personal data, and Professional Services Data will continue to be transferred outside the EU Data Boundary."⁵²

All customer data at rest are stored in the Geo selected by the customer. Customers can additionally choose a DataZone for the Content Data (queries and replies).

Microsoft offers some region specific data zone choices, such as France, Germany, Italy, Spain, Sweden and Poland, but not a region choice for the Netherlands. Dutch customers can for example choose

⁵⁰ Directive (EU) 2022/2464 of the European Parliament and of the Council of 14 December 2022 amending Regulation (EU) No 537/2014, Directive 2004/109/EC, Directive 2006/43/EC and Directive 2013/34/EU, as regards corporate sustainability reporting (Text with EEA relevance), URL: <https://eur-lex.europa.eu/eli/dir/2022/2464/oj/eng>.

⁵¹ UvA, Hoe de CO2-voetafdruk van de UvA is opgebouwd, 21 maart 2023, URL: <https://www.uva.nl/content/nieuws/nieuwsberichten/2023/03/hoe-de-co2-voetafdruk-van-de-uva-is-opgebouwd.html>.

⁵² Microsoft, What is the EU Data Boundary?, 26 February 2025, URL: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-learn>.

westeurope as zone.⁵³ In that case, the content data can be processed in all EU instances of OpenAI on Azure for inferencing or fine-tuning. Microsoft also explains:

*"When a 'Global' or 'DataZone' deployment type is selected for fine-tuned models, the training data, validation data, and/or custom model weights may be stored temporarily outside the selected Geo."*⁵⁴

SURF will use the Azure policy to prohibit use of global deployment.⁵⁵

The EU Data Boundary is not absolute, but contains a list of exceptions. Microsoft explains:

"There are scenarios where Microsoft will continue to transfer data out of the EU Data Boundary to meet cloud service operational requirements, where data stored in the EU Data Boundary will be accessed remotely by personnel located outside the EU Data Boundary, (...)." ⁵⁶

Microsoft describes continuing data transfers for all services, and provides a service-specific list of continuing, temporary, incidental and structural exceptions.

As shown in [Figure 25](#) below, Microsoft describes 10 types of structural exceptions to the EU Data Boundary. Only the first, third and fourth purpose are relevant: (i) remote access by Microsoft personnel based in third countries to personal data, (ii) Professional (Support) Services and (iii) structural transfer of pseudonymised log data, and sometimes Content Data for different security purposes.

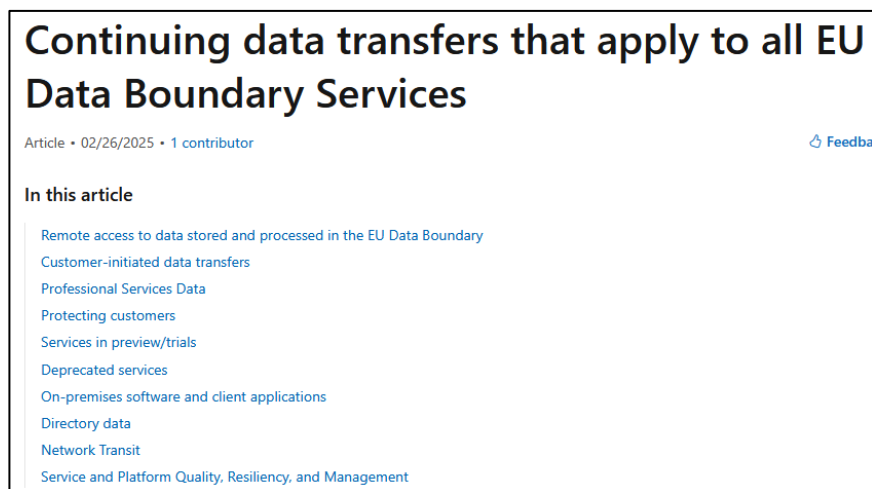
⁵³ Microsoft, Azure OpenAI Service models, 14 April 2025, section Data Zone Standard Model Availability, URL: <https://learn.microsoft.com/en-us/azure/ai-services/openai/concepts/models?tabs=datazone-standard%2Cstandard-chat-completions#data-zone-standard-model-availability>.

⁵⁴ Microsoft, Data residency in Azure, More information on customer data location , undated, URL: <https://azure.microsoft.com/en-us/explore/global-infrastructure/data-residency/?msocid=2d494b1b376e691736c8580636d4689e#more-information>, page last visited 15 April 2025.

⁵⁵ Microsoft, How to disable access to global deployments in your subscription, 24 January 2025, URL: <https://learn.microsoft.com/en-us/azure/ai-services/openai/how-to/deployment-types#how-to-disable-access-to-global-deployments-in-your-subscription>.

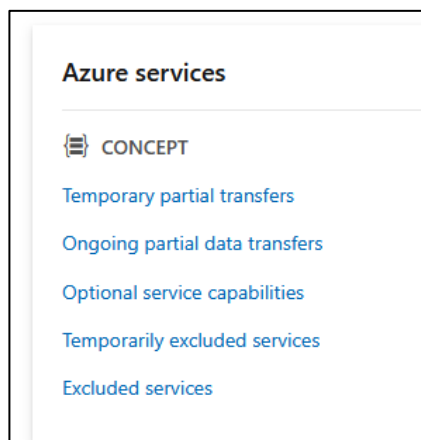
⁵⁶ Microsoft, Continuing data transfers that apply to all EU Data Boundary Services, 26 February 2025, URL: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-transfers-for-all-services>.

Figure 25: General EU Data Boundary exceptions⁵⁷



Additionally, Microsoft describes specific exceptions to the EU Data Boundary per service. For Azure, Microsoft describes 5 exceptions.

Figure 4: Specific Azure exceptions to the EU Data Boundary⁵⁸



There appear to be two relevant exceptions for the use of Azure OpenAI: the 'optional service capability' exception, and the use of the Azure Content Delivery Network.

Below, an attempt is made to summarise the information from Microsoft about the relevant exceptions for incidental and ongoing transfers of personal data from the Azure OpenAI service, for the Content Data, the Account Data, the pseudonymised Diagnostic Data, and the Support Data.

⁵⁷ Idem.

⁵⁸ Microsoft, Continuing data transfers out of the EU Data Boundary for specific services, undated, URL: <https://learn.microsoft.com/en-us/privacy/eudb/landing> (page last visited 30 March 2025).

SURF AI- HUB Development Goal

- If Microsoft were to offer a Dutch data zone for the data processing and storage of data processed by OpenAI on Azure, SURF can consider choosing this option.

9.1.1 Incidental remote access to data stored in the EU

Microsoft explains that personal data (described in this DPIA as Account, Content, Diagnostic and Support Data) can incidentally be transferred out of the EU in 2 circumstances:

1. *"(...) where data stored in the EU Data Boundary will be accessed remotely by personnel located outside the EU Data Boundary, and*
2. *where a customer's use of EU Data Boundary Services will result in data transfer out of the EU Data Boundary to achieve the customer's desired outcomes."*⁵⁹

The first scenario includes both reactive responses to support requests, and proactive troubleshooting. Microsoft uses the term 'personnel' to include both its own employees and staff hired from subcontractors. Microsoft writes:

*"These personnel are part of our global workforce, which is made up of both employees of Microsoft and its subsidiaries and staff we obtain via contract with third party organizations to assist Microsoft employees."*⁶⁰

Legally, personal data cannot be 'transferred' to Microsoft's employees, as they cannot be qualified as controllers or processors. Such access may be a technical transmission of personal data but not a 'transfer' as defined in Section 5 of the GDPR. The explanations below are limited to data transfers to (staff hired by) subcontractors (third party entities that are sub processors of Microsoft).⁶¹

The second scenario is largely under control of the customer. For example: if organisations allow their employees to access the OpenAI LLM on Azure while the employees or students are physically abroad.

When Microsoft needs to access Content and Diagnostic Data for support and troubleshooting, the data stay in the EU (including the support tickets).

⁵⁹ Microsoft, Continuing data transfers that apply to all EU Data Boundary Services, 2 January 2024, URL: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-transfers-for-all-services>.

⁶⁰ Microsoft, Locations of Microsoft Online Services Personnel with Remote Access to Data, 11 November 2024, URL: <https://learn.microsoft.com/en-gb/microsoft-365/enterprise/personnel-loc/m365-personnel-location?view=o365-worldwide>.

⁶¹ In the framework contract with Microsoft for Online Services, SURF is the exporter and Microsoft Corporation in the USA is the importer. Privacy Company assumes SURF can use this same contract for the use of OpenAI in Azure.

“When Microsoft personnel need to access Customer Data or pseudonymized personal data stored on Microsoft systems inside the EU Data Boundary from outside the boundary (considered a transfer of data under European privacy law although the data remains within Microsoft datacentre infrastructure in the EU Data Boundary) we rely on technology that ensures this type of transfer is secure, with controlled access and no persistent storage at the remote access point. When such a data transfer is required, Microsoft uses state-of-the-art encryption to protect Customer Data and pseudonymized personal data at rest and in transit.”⁶²

If EduGenAI uses Professional Services for Azure, SURF can choose to store the data in the EU if they configure the Azure Resource Manager to the EU Data Boundary.⁶³ However, different from other Big Tech service providers, Microsoft does not offer customers an option to choose an EU-based helpdesk.⁶⁴ Even with a Professional Services Contract, customers cannot ask Microsoft to have the tickets exclusively answered by personnel physically located within the EU.⁶⁵

Since July 2024, Microsoft publishes an overview of locations from where Microsoft personnel may remotely access personal data from customers. Microsoft publishes two tables: relating to its own staff, and relating to contractors. The list of countries with contract staff includes 30 so called ‘third countries’ without adequacy decision from the European Commission.⁶⁶

The third countries are: Armenia, Australia, Bolivia, Brazil, China, Costa Rica, Dominican Republic, Ecuador, Egypt, El Salvador, Georgia, Ghana, Guatemala, Honduras, Hong Kong, India, Jamaica, Malaysia, Mexico, Panama, Paraguay, Peru, Philippines, Qatar, Serbia, Singapore, South Africa, Taiwan, Trinidad and Tobago, and Turkey.⁶⁷

Figure 27: Locations of Microsoft contract staff⁶⁸

⁶² Idem.

⁶³ Microsoft, Configuring Azure non-regional services for the EU Data Boundary, 26 February 2025, URL: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-configure-azure-nonregional-services#azure-resource-manager>.

⁶⁴ See the public DPIAs on Zoom and Google published by SURF at https://www.surf.nl/multi-site-search?q=DPIA&size=n_20_n and AWS published by SLM Rijk at <https://www.slm-microsoftrijk.nl>.

⁶⁵ Microsoft reply to part A of the SURF DPIA on Microsoft 365 Copilot, 17 December 2024, URL: <https://www.surf.nl/files/2024-12/20241218-dpia-microsoft-365-copilot.pdf>.

⁶⁶ Microsoft, Locations of Microsoft Online Services Personnel with Remote Access to Data, 11 November 2024, URL: <https://learn.microsoft.com/en-gb/microsoft-365/enterprise/personnel-loc/m365-personnel-location?view=o365-worldwide>.

⁶⁷ Idem.

⁶⁸ Ibid.

Contract Staff Personnel Locations			
Argentina	Egypt	Japan	Serbia
Armenia	El Salvador	Korea	Singapore
Australia	Finland	Malaysia	South Africa
Austria	France	Mexico	Spain
Belgium	Georgia	Netherlands	Sweden
Bolivia	Germany	New Zealand	Switzerland
Brazil	Ghana	Norway	Taiwan
Bulgaria	Guatemala	Panama	Trinidad and Tobago
Canada	Honduras	Paraguay	Türkiye
China	Hong Kong SAR	Peru	United Kingdom
Costa Rica	Hungary	Philippines	United States
Czech Republic	India	Poland	Uruguay
Denmark	Ireland	Portugal	
Dominican Republic	Italy	Qatar	
Ecuador	Jamaica	Romania	

Microsoft uses two different types of infrastructure for access to personal data from and about customers:

1. Secure Admin Workstations (SAWs) for access to Content Data (which Microsoft calls Customer Data), and
2. Virtual Desktop Infrastructure (VDI) for access to pseudonymised Diagnostic Data.

Microsoft writes that personnel can only access Content Data via secure admin workstations (SAWs) that are protected against export of the data.

*"For example, Microsoft personnel working on SAWs have restricted access to the internet on such devices and are unable to access external or removable media because those capabilities are blocked in the SAW implementation."*⁶⁹

Microsoft also explains that all access to Content Data from customers is logged and monitored, and compliance checked in audits.

*"Access to Customer Data is also logged and monitored by Microsoft. Microsoft performs regular audits to review and confirm that access management measures are working in accordance with policy requirements, including Microsoft's contractual commitments."*⁷⁰

Microsoft finally states that the probability is very low that Microsoft personnel outside of the EU can access Content Data:

⁶⁹ Ibid.

⁷⁰ Microsoft, How Microsoft protects Customer Data, 26 February 2025, URL: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-transfers-for-all-services#how-microsoft-protects-customer-data>.

*"In rare cases when a service is within the EU Data Boundary, including Customer Data. There's no default access to Customer Data; access is provided to Microsoft personnel only when a task requires it."*⁷¹

Microsoft employees use a virtual desktop infrastructure (VDI) to access pseudonymized personal data in the EU Data Boundary. Microsoft explains:

*"As with SAWs, the list of utilities that are allowed on the VDIs are limited and are subject to rigorous security tests before being certified to run on the VDIs. When a VDI is used, pseudonymized personal data in the EU Data Boundary is accessed through virtual machines that are hosted on a physical machine located in the EU Data Boundary and no data persists outside of the EU Data Boundary."*⁷²

To better understand the probability of remote access from third countries Microsoft explained that there are three relevant fractions. First of all, problems are generally resolved by service automation. Secondly, if an engineer has to manually intervene, the odds are very small that specific Dutch education data are part of the data accessed by that engineer. And thirdly, the probability that a government agent will patiently wait next to an engineer until such data appear and will then compel disclosure, is extremely small.

"When service automation is unable to resolve issues, engineering personnel assigned to the service capabilities experiencing such issues are auto-notified to take action."

[...]

*The probability of any single user or customer event potentially being reflected in logs relevant to an incident is roughly defined by either (a) for the case of a single user - the fraction the numerator of which is a single user and the denominator of which is the total number of users of the service in the infrastructure in the EU data boundary, or (b) for the case of a customer tenancy - the fraction the numerator of which is the total number of users of the service in a customer tenancy divided by the total number of users of the service in the infrastructure in the EU data boundary. Given the total number of service users of Microsoft 365 services, this probability is low for even the largest and most active customer tenancies."*⁷³

9.1.2 Systematic transfers of personal data

Next to the two types of incidental data transfers described above (for troubleshooting through remote access, and for data transfers that can be controlled by customers), an unknown amount of personal data is systematically transferred to, and stored in the United States for security purposes. Microsoft explains:

⁷¹ Idem.

⁷² Microsoft, How Microsoft protects pseudonymized personal data in system-generated logs, 26 February 2025, URL: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-transfers-for-all-services#how-microsoft-protects-pseudonymized-personal-data-in-system-generated-logs>.

⁷³ Microsoft reply quoted in the SURF DPIA on Microsoft 365 Copilot.

“only Personal Data confidently deemed relevant to a security investigation is transmitted for SecOps. Currently, such data is transmitted only within the EU or to the United States. Such data may be transferred via remote access to other countries where security personnel are located, for the purposes described above. Hopefully this addresses the lack of clarity and apparent contradiction noted above.”⁷⁴

Microsoft personnel in the USA and in third countries can access Content Data and pseudonymised Diagnostic Data either stored in the USA, or stored in the EU Data Boundary for three closely intertwined security purposes:

1. to ‘detect and investigate early indicators of malicious activity or breach’ (threat hunting)
2. to ‘monitor, investigate, and respond to threats facing the platforms customers rely on for their daily operations’ (operational security)
3. Security threat intelligence (including malicious nation state activities).

For threat hunting, two types of Diagnostic Data are transmitted or accessed: pseudonymised service generated server logs and service configuration information (and in rare situations, Content Data).⁷⁵ Microsoft explains:

“the usage is restricted to security purposes, including detecting, investigating, mitigating, and responding to security incidents.”⁷⁶

Microsoft has assured SURF that its USA based security teams do not have standing access to Diagnostic Data stored within the EUDB, but as quoted above, Microsoft does transmit an unknown amount of Diagnostic Data to the USA. On its public information page about the EUDB, Microsoft mentions storage of security data in the USA, with onward transfers.

“Included pseudonymized data [from system-generated logs and service configuration information, addition Privacy Company] and Professional Services Data is consolidated and stored primarily in the United States but may include other data centre regions worldwide for threat detection work as described previously.”⁷⁷

Microsoft describes that for operational security purposes it transfers pseudonymized personal data ‘to any Azure region worldwide’. Microsoft explains:

“This enables Microsoft’s security operations, like the Microsoft Security Response Center (MSRC), to provide security services 24 hours a day, 365 days a year in an efficient and effective manner in response to worldwide threats. The data is used in monitoring, investigations, and response to

⁷⁴ Microsoft reply quoted in the SURF DPIA on Microsoft 365 Copilot.

⁷⁵ Microsoft, Continuing data transfers that apply to all EU Data Boundary Services, subsection ‘Protecting Customers’, 26 February 2025, URL: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-transfers-for-all-services#protecting-customers>.

⁷⁶ Ibid.

⁷⁷ Ibid.

security incidents within Microsoft's platform, products, and services, protecting customers and Microsoft from threats to their security and privacy."⁷⁸

In reply to questions about the amount of data that are physically transmitted out of the EU, Microsoft explained:

"When Microsoft transfers limited pseudonymized personal data, and in rare situations, limited Customers Data outside of the EU for Security Operations ("SecOps") purposes, it is for the limited and specific security purpose of protecting and defending Microsoft and its customers against cybersecurity threats and attacks. There is no default access to Customer Data; access is provided to Microsoft SecOps personnel only when a task requires it. (...)

*The specific data and amount of data will vary depending on the nature of the security threat or issue involved, impacted users and other considerations, therefore we cannot generalize or commit to a specific percentage of data that may be transferred. (...)"*⁷⁹

9.1.3 Azure Front Door and Content Delivery Network

Microsoft explains that it always uses its global Content Delivery Network for all content hosted on Azure. Microsoft writes:

"Azure Front Door and Content Delivery Network are non-regional services that can be used to bring customers' static and dynamic content closer to their end users all over the world. To help accelerate global requests, Azure Front Door and Azure CDN cache data at global edge locations on behalf of the customer. Both services use a networking technique called anycast to direct traffic between customer end users and point of presence (PoP) locations using the fastest possible route. Due to the nature of this routing mechanism and in order to serve our customers' requirements to push data around the world, not all traffic will stay within the EU Data Boundary. Cached content duration can be changed based on a customer's configuration within the AFD or CDN profile settings."

In total, Microsoft describes 11 structural exceptions to the EU Data Boundary. However, due to the design of EduGenAI, the only personal data Microsoft can process outside of the EU Data Boundary are the Content Data in prompts and replies - to the extent the personal data masking filter hasn't worked or was disabled, and the Account and Diagnostic Data from the EduGenAI administrator. Microsoft can only monitor these data in real time.

In total, Microsoft describes 11 structural exceptions to the EU Data Boundary. However, due to the design of EduGenAI, the only personal data Microsoft can process outside of the EU Data Boundary are the Content Data in prompts and replies - to the extent the personal data masking filter hasn't worked or was disabled,

⁷⁸ Ibid., subsection Security Operations, URL: <https://learn.microsoft.com/en-us/privacy/eudb/eu-data-boundary-transfers-for-all-services#security-operations>.

⁷⁹ Microsoft reply to questions SLM Rijk, 25 November 2024, as quoted in the SURF DPIA on Microsoft 365 Copilot.

and the Account and Diagnostic Data from the EduGenAI administrator. Microsoft can only monitor these data in real time.

Table 2 below describes the purposes of the transfer, the types of personal data and the locations where the data are transferred to.

As described in Section 6.6, Microsoft generally acts as data processor for these purposes. However, Microsoft acts as controller for purpose no. 5, when it creates aggregated statistics about for example daily active users for financial purposes (highlighted in soft yellow).

Table 3 - Systematic transfers of personal data (not controlled by customers)

NO	Purpose	Type of personal data	Transfers
1	Protecting against global cybersecurity threats: Threat hunting	Limited Customer Data (queries processed by OpenAI) and cross-geo boundary pseudonymised personal data, including pseudonymised system-generated logs and service configuration information (all relating to the EduGenAI admin)	Primarily accessed in the USA, unknown quantity of data transferred to the USA with onward transfers
2	Protecting against global cybersecurity threats: Operational security	Pseudonymised personal data from the EduGenAI admin and limited Customer Data (queries processed by OpenAI).	Accessed from any Azure region worldwide
3	Protecting against global cybersecurity threats: Threat intelligence	Pseudonymized personal data in globally consolidated system-generated logs, limited Customer Data (queries processed by OpenAI)	Accessed from any Azure region worldwide where analyst teams work
4	Azure Front Door and Content Delivery Network	Pseudonymised personal data from the EduGenAI admin and limited Customer Data (queries processed by OpenAI).	No information provided
5	Creation of global real-time quality metrics and financial reporting about daily and monthly active users	Pseudonymised system-generated logs with object IDs and the unique ID of the EduGenAI administrator.	No information provided
6	Network Transit incl. load balancing by proxy servers	All personal data	Globally – but out of scope DPIA as they are

part of functional routing data.

9.2 GDPR rules for transfers of personal data

The GDPR contains specific rules for the transfer of personal data to processors or controllers in third countries without an adequate level of protection. The adequacy can be determined in a number of ways: a multinational may adopt Binding Corporate Rules, apply the EU Standard Contractual Clauses (SCC) or only transfer to countries for which the European Commission has taken a so-called adequacy decision (such as the USA since June 2023).

Microsoft relies on two transfer mechanisms with the Dutch Education sector (for the use of OpenAI on Azure):

1. The EU Standard Contractual Clauses (Microsoft as processor);
2. Microsoft's participation to the EU US Data Privacy Framework (Microsoft as controller).

As described in [Section 8.1](#) above, even though Azure services are part of Microsoft's EU Data Boundary commitment, education organisations that wish to use this generative AI service still have to assess the transfer risks of incidental and structural access to personal data from the USA and third countries. As shown in [Table 3](#) above, these data transfers are minimal. Only the personal data from the EduGenAI admins are transmitted (not from the end users), and if COs do not disable the personal data masking filter in the contents of queries, the transfer of personal data as part of the chat history should be limited.

Privacy Company did not receive information from SURF about the transfer mechanism other providers of cloud AI-models wish to rely on (such as Meta and Anthropic).

9.2.1 Data Transfer Impact Assessment

Even though the USA are deemed to have an adequate level of protection since July 2023, by decision of the European Commission, this status may change rapidly. If the European Commission or the European Court of Justice suspend or invalidate the adequacy decision, Dutch organisations can still rely on the SCC, but will have to assess the data protection risks of transfers to the USA in a Data Transfer Impact Assessment (DTIA).

The requirement to perform a DTIA is not limited to the risks of (un)lawful access⁸⁰ by government agencies in the USA. Similar risks may occur in the third countries where personnel from providers of AI-models (or

⁸⁰ Though for Microsoft compliance with government requests could be lawful, for the Dutch education organisations such access by a government authority in a third country would be unlawful access, in breach of the GDPR.

their subcontractors) can incidentally and structurally access (some) Content and (pseudonymised) Diagnostic Data.

If all personal data were exclusively processed and stored in the EU, performance of a DTIA would not be necessary to assess the probability of a disclosure order from a foreign government authority that exercised cross-boundary jurisdiction.

The EDPS has explained in its decision about Cisco Webex that the mere risk of an order for compelled disclosure for data stored in the EU cannot be qualified as a data transfer:

“However, in the EDPS opinion, the mere risk that remote access by third country entities to data processed in the EEA may take place, does not constitute a transfer subjected to Chapter V of the Regulation.

The EDPS considers that transfers resulting from unauthorised access by third country entities, which are merely potential and in no way foreseeable in light of the content or purpose of a contract or another stable relationship between the parties, do not fall under the scope of Chapter V of the Regulation. The unlikely and unplanned character of such risks of such unauthorised access renders them unsuitable to be ex ante subjected to regime of Chapter V of the Regulation. It follows that for such potential and unplanned transfers a transfer tool under that Chapter is not required.”⁸¹

10 Techniques and Methods of the Data Processing

10.1 Components of trained LLMs

A trained LLM consists of a few important components:

1. A tokenizer that can cut a piece of text in chunks that are more manageable to process by an LLM. The tokenizer can also convert the chunks back to text.
2. An embeddings model that can translate a series of tokens in a list of vectors (the embedding). The model is trained to have vectors correlate to semantic meaning. That means that two pieces of text that are closely related in meaning should translate to vectors that are relatively close to each other. This process is also reversible: vectors can also be translated back into tokens.
3. A transformer model that uses the tokeniser and their embeddings to predict one or more tokens that are likely to follow a given list of tokens. This transformer model is sometimes

⁸¹ EDPS Decision on the Court of Justice of the EU’s request to authorise the contractual clauses between the Court of Justice of the EU and Cisco Systems Inc. for transfers of personal data in the Court’s use of Cisco Webex and related services 13 July 2023 (Case 2023-0367), par 34 and 35, URL: https://www.edps.europa.eu/system/files/2023-07/2023-07-13-edps-cjeu-cisco-decision_en.pdf.

crudely summarized as a text autocomplete model, comparable to the functionality on smartphones.

This model must contain information about correlations on a short distance. For example, that it's likely that the text "Mark" is followed by "Rutte". But also correlations over slightly longer distances, for example, that the text "Given his many roles in successful movies, the actor Mark" is much more likely to be followed by "Ruffalo" or "Wahlberg" than "Rutte" or "Zuckerberg". This means that the model contains information about objects, events, persons, etc., and their relationships to other things based on how they are referred to in the training data. This effectively allows the model to generate text that contains factual statements and opinions about a variety of topics, including people. Repeatedly predicting the most likely options for the next token, choosing one of the options based on a probability and repeating the process allows the LLM to produce longer outputs. This process has a configurable balance between repeatability (only picking the single most likely prediction), and more variation (increasing the probability of choosing one of the next possible options). In practice this means LLMs from OpenAI, Meta, DeepSeek, Google, Mistral and Anthropic can reproduce factual pieces of personal data that match personal data from the training data, generate plausible sounding but inaccurate statements about existing people or generate statements about entirely fictive persons.

There are two widely published examples of (extremely) negative privacy impact from such inaccurate statements in consumer generative AI tools. Microsoft Copilot accused a German court reporter of being the perpetrator of the crimes he wrote about⁸² and ChatGPT accused a Norwegian father of killing his two children.⁸³

In relation to the speech to text LLM Whisper, research from Cornell and Virgin university on short audio recordings in Talkbank shows that if Whisper hallucinated (in 1% of the cases), almost 40% of these hallucinations were alarming, and could have grave consequences, for example medical misdiagnosis. Other users report a much higher number of hallucinations in longer audio recordings, up to 100%.⁸⁴

Table 4 - Two examples of dangerous hallucinations in Whisper⁸⁵

Audio	Transcription
He, the boy, was going to, I'm not sure exactly, take the umbrella	He took a big piece of a cross, a teeny, small piece ... I'm sure he didn't have a terror knife so he killed a number of people."

⁸² NOS, Kunstmatige intelligentie beschuldigt onschuldige journalist van kindermisbruik, 23 augustus 2024, URL: <https://nos.nl/artikel/2534266-kunstmatige-intelligentie-beschuldigt-onschuldige-journalist-van-kindermisbruik>.

⁸³ BBC, Man files complaint after ChatGPT said he killed his children, 21 March 2025, URL: <https://www.bbc.com/news/articles/c0kgvdkr516o>.

⁸⁴ AP, Researchers say an AI-powered transcription tool used in hospitals invents things no one ever said, 26 October 2024, URL: <https://apnews.com/article/ai-artificial-intelligence-health-business-90020cdf5fa16c79ca2e5b6c4c9bbb14>.

⁸⁵ Allison Koenecke, Anna Seo Gyeong Choi, Katelyn X. Mei, Hilke Schellmann, Mona Sloane, Careless Whisper: Speech-to-Text Hallucination Harms, 5 June 2024, published in the FaccT 2024 Proceedings, p. 1672-1681, URL: <https://doi.org/10.1145/3630106.3658996>.

two other girls and one lady.

two other girls and one lady, um, which were Black.”

EduGenAI applies an (on-premises) personal data masking filter to remove personal data from prompts and RAG-documents. However, this DPIA assumes that the filter will make mistakes. Additionally, the filter can only filter text that has been extracted from audio and images, not audio and images themselves.

EduGenAI Development Goals

- Develop a procedure for end users and teachers to report inaccurate personal data relating to them.
- Forward reports about inaccurate data to the LLMs, and agree on a procedure with the LLMs that they prevent regeneration of reported inaccurate personal data.
- Perform quality and accuracy research with the COs, and develop guidance on the best type of model for specific tasks.
- Help COs develop mini GPTs based on accurate personal data, and help COs fine-tune those models in case of inaccurate personal data.
- Use available tooling to adjust pre-made RAI filters to the needs of EduGenAI users.
- Develop a specialised RAI that is implemented through the LiteLLM proxy.
- SURF’s AI-Hub is developing guardrails/content filters that will be hosted on-premises and will be configurable by EduGenAI. In these filters AI-Hub and EduGenAI can also add data masking techniques. EduGenAI should make use of these tools when they are available and incorporate them into the filtering done through the LiteLLM proxy

10.2 LLMs and personal data

There is no doubt that OpenAI has processed personal data when processing the training data to create its LLMs.⁸⁶ OpenAI itself writes:

“Is personal information used to teach ChatGPT?”

A large amount of data on the internet relates to people, so our training information does incidentally include personal information. We don’t actively seek out personal information to train our models (...)

⁸⁶ OpenAI, How ChatGPT and our language models are developed, URL: <https://help.openai.com/en/articles/7842364-how-chatgpt-and-our-language-models-are-developed>.

Our models may learn from personal information to understand how things like names and addresses fit within language and sentences, or to learn about famous people and public figures. This makes our models better at providing relevant responses.

We also take steps to reduce the processing of personal information when training our models. For example, we remove websites that aggregate large volumes of personal information and we try to train our models to reject requests for private or sensitive information about people.”⁸⁷

OpenAI also responds to GDPR objection requests. OpenAI writes:

“We respond to objection requests and similar rights. As a result of learning language, ChatGPT responses may sometimes include personal information about individuals whose personal information appears multiple times on the public internet (for example, public figures). Individuals in certain jurisdictions can object to the processing of their personal information by our models or make other data subject rights requests through our Privacy Portal.”⁸⁸

There is no consensus if an LLM itself ‘contains’ personal data. Even though OpenAI implies it processes personal data by honouring correction requests from individuals, both the Hamburg⁸⁹ and the Danish Data Protection Authority⁹⁰ argue that the LLM itself does not contain personal data.

On the other hand, the Swiss lawyer David Rosenthal substantiates that the LLM can contain personal data. He takes a relative approach, and argues that the qualification as personal data depends on the type of prompts created by end users.

Rosenthal explains that the LLM applies a very ‘lossy’ type of compression to the training data:

“in the case of GPT3, a compression by a factor of 128 took place when looking at it from a purely mathematical point of view, whereby the focus was on the preservation of linguistic knowledge, not factual knowledge.”⁹¹

He also refers to attacks to ‘retrieve’ personal data from the training data:

⁸⁷ Idem.

⁸⁸ Idem. In November 2024 OpenAI additionally wrote: " Individuals also may have the right to access, correct, restrict, delete, or transfer their personal information that may be included in our training information". This sentence has since been removed from this Q&A.

⁸⁹ The Hamburg Commissioner for Data protection and freedom of information, Discussion Paper: Large Language Models and Personal Data, URL: https://datenschutz-hamburg.de/fileadmin/user_upload/HmbBfDI/Datenschutz/Informationen/240715_Discussion_Paper_Hamburg_DPA_KI_Models.pdf.

⁹⁰ Datatilsynet, Offentlige myndigheders brug af kunstig intelligens, October 2023, In Danish, URL: <https://www.datatilsynet.dk/Media/638321084132236143/Offentlige%20myndigheders%20brug%20af%20kunstig%20intelligens%20-%20Inden%20i%20g%C3%A5r%20i%20gang.pdf>.

⁹¹ Vischer, part 19 Part 19: Language models with and without personal data, 17 July 2024, URL: <https://www.vischer.com/en/knowledge/blog/part-19-language-models-with-and-without-personal-data/>.

“The literature repeatedly refers to studies and methods (...) that make it possible to determine whether certain information - including personal data - has been used to train a model (usually referred to as “membership inference attacks”). It is emphasised that these attack methods pose a risk to data protection because they can be used to extract training content. This overlooks the fact that in the models in question, the training content can be found in the output even without an “attack” if the input is suitable, because the model has “seen” it sufficiently often during training; it is the phenomenon of “memorization”, i.e. the model remembers a particular content seen during the training, such as Donald Trump’s date of birth. In terms of data protection law, corresponding personal data is therefore contained in the model anyway if corresponding inputs are to be expected.”

According to Rosenthal, providers of LLMs such as OpenAI that make their generative AI widely available, or providers of chatbots such as ChatGPT, DeepSeek and Copilot have to

“expect a correspondingly broad variety of prompts and therefore assume that a corresponding broad amount of personal data will be generated by the model and (...) will have to assume that its users will ask the chatbot about public figures.”⁹²

Rosenthal summarises:

“Whether or not personal data is contained in a large language model (and whether such a model produces such data) must be assessed from the perspective of those who formulate the input and those who have access to the output.”⁹³

For this DPIA on EduGenAI, it is not relevant if the different on-premises and cloud LLMs already include personal data, based on the training data used to build the LLM, or can generate personal data. This DPIA only addresses the personal data in the Content Data, the prompts and replies, including augmentation with self-selected sources.

11 Additional legal obligations

This Section describes additional legal obligations from the ePrivacy Directive, but starts with a short description of the current political debate about digital sovereignty.

Due to the limited scope of this DPIA, other legal obligations or policy rules (for example the security guidelines from the SURF Security Expertise Centre)⁹⁴, are not included in this report.

SURF has also requested not to address specific AI-act obligations in this DPIA. The AI Act distinguishes between providers and deployers of AI-systems (such as the COs), and has different rules for providers of

⁹² Idem.

⁹³ Idem.

⁹⁴ SURF Security Expertise Centre, Controls, URL: <https://sec.surf.nl/controls/>.

‘normal’ General-Purpose AI Models (GPAIs)⁹⁵, and GPAIs with systemic risk. SURF will conduct a separate assessment of these obligations later in time.

11.1 Digital Sovereignty

As government funded public sector organisations education organisations take cues from the National Cloud Strategy for the central Dutch government. This strategy was adopted in October 2022, with detailed guidelines published in January 2023.⁹⁶ According to this strategy, government organisations could start using public cloud services, after a risk assessment, and under conditions.

For geostrategic reasons, dependency on foreign powers for the provision of essential infrastructure and government services to citizens has always been considered undesirable. The desire for digital sovereignty took a prominent place on the national political agenda in 2024, and became even more urgent in 2025, as a result of the rapidly changing relationship from the EU with the USA.

Reports from Institute Clingendael⁹⁷, the Rekenkamer⁹⁸ and legislative initiatives and motions from members of Parliament⁹⁹ raised alarm bells about the factual dependencies. In reply, Minister Beljaarts of Economical Affairs announced a tightening of the government cloud policy by mid 2025.¹⁰⁰

11.2 ePrivacy Directive

The act of reading or placing information (through cookies or similar technology) triggers the applicability of Article 5(3) of the ePrivacy Directive, regardless of who places or reads the information, and regardless of whether the content is personal data or not.

⁹⁵ The AI Act defines General-Purpose AI Models as such:

“general-purpose AI model” means an AI model, including where such an AI model is trained with a large amount of data using self-supervision at scale, that displays significant generality and is capable of competently performing a wide range of distinct tasks regardless of the way the model is placed on the market and that can be integrated into a variety of downstream systems or applications, except AI models that are used for research, development or prototyping activities before they are placed on the market”

European Union, REGULATION (EU) 2024/1689 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL, 13 June 2024, URL: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>.

⁹⁶ Ministerie van Binnenlandse Zaken en Koninkrijksrelaties, Implementatiekader risicoafweging cloudgebruik, versie 1.1, 5 januari 2023, URL: <https://open.overheid.nl/documenten/ronl-734f947ec6465e4f75a56bed82fe64a1135f71a8/pdf>.

⁹⁷ Clingendael Institute, Too late to act? Europe’s quest for cloud sovereignty, 1 March 2024, URL: <https://www.clingendael.org/publication/too-late-act-europes-quest-cloud-sovereignty>.

⁹⁸ In Dutch only, Rekenkamer, Het Rijk in de cloud, Donkere wolken pakken samen, 15 January 2025, URL: <https://www.rekenkamer.nl/publicaties/rapporten/2025/01/15/het-rijk-in-de-cloud>.

⁹⁹ In Dutch only, Initiatiefnota Wolken aan de Horizon, GroenLinks PvdA en NSC, juni 2024, URL: <https://groenlinkspvda.nl/wp-content/uploads/2024/06/24.06.14-Wolken-aan-de-horizon.pdf>. See also: Informatie Professional, Tweede Kamer wil kijken naar eigen ‘rijkscloud’, 21 March 2025, URL: <https://informatieprofessional.nl/tweede-kamer-wil-kijken-naar-eigen-rijkscloud/>.

¹⁰⁰ In Dutch only, Security.nl, Kabinet gaat cloudgebruik Rijk aanscherpen, onderzoekt overheidscloud, 18 januari 2025, URL: <https://www.security.nl/posting/872893/Kabinet+gaat+cloudgebruik+Rijk+aanscherpen%2C+onderzoekt+overheidscloud>.

Based on article 3(1) of the GDPR, because the data processing takes place in the context of the activities of data controllers (the Dutch education organisations, with SURF as joint controller for EduGenAI, the GDPR applies to all phases of the processing of these data.

Applicability of the GDPR rules does not exclude applicability of the ePrivacy rules or vice versa. The European Data Protection Board writes:

*“Case law of the Court of Justice of the European Union (CJEU) confirms that it is possible for processing to fall within the material scope of both the ePrivacy Directive and the GDPR at the same time. In *Wirtschaftsakademie*, the CJEU applied Directive 95/46/EC notwithstanding the fact that the underlying processing also involved processing operations falling into the material scope of the ePrivacy Directive. In the pending *Fashion ID* case, the Advocate General expressed the view that both set of rules may be applicable in a case involving social plug-ins and cookies.”¹⁰¹*

Article 5(3) of the ePrivacy Directive was transposed in article 11.7a of the Dutch Telecommunications Act. The consequences of the cookie provision are far-reaching, since it requires clear and complete information to be provided *prior* to the data processing, and it requires consent from the user, unless one of the legal exceptions applies. The consent is identical to the consent defined in the GDPR.

It follows from [Section 2.3](#) in this report that SURF creates a trace ID for each request in the web app, and sends this trace ID back to the user’s browser with the reply to the prompt. However, this Trace ID is not read from the browser.

Once EduGenAI meets its roadmap goal to exclusively store the chat history in the browser of the end user, a cookie is necessary to remember the chat history. From that moment onwards, EduGenAI will have to comply with the information obligation from article 11.7a. If a user wishes to retain their chat history, the cookie is necessary to perform a service explicitly requested by a user. Therefore, consent is not required, as long as the cookie is set by EduGenAI as a first party cookie, and the cookie cannot be used for tracking purposes.

The withdrawal by the European Commission of the proposed new ePrivacy Regulation in March 2025 means SURF and the education organisations will have to comply with the current ePrivacy rules in the next few years.

12 Retention Periods

¹⁰¹ EDPB, Opinion 5/2019 on the interplay between the ePrivacy Directive and the GDPR, in particular regarding the competence, tasks and powers of data protection authorities, adopted on 12 March 2019 Paragraph 30. URL: https://edpb.europa.eu/sites/edpb/files/files/file1/201905_edpb_opinion_eprivacydir_gdpr_interplay_en_0.pdf In footnotes the EDPB refers to: CJEU, C-210/16, 5 June 2018, C-210/16, ECLI:EU:C:2018:388. See in particular paragraphs 33-34 and the Opinion of Advocate General Bobek in *Fashion ID*, C-40/17, 19 December 2018, ECLI:EU:C:2018:1039. See in particular paragraphs 111-115.

This section describes the retention periods SURF applies in its role as data processor, and as joint data controller (for the Content Data).

12.1 Chat history

In the future, EduGenAI will only store the chat history in the back-end servers if the user consents, and only retain a pseudonymised chat history for research purposes if the users explicitly consents. SURF will retain the chat history for 6 months after a user has become inactive. The COs will have to determine the retention period for the research purposes, in line with research verification obligations.

12.2 RAG-documents, chunks and vector-embeddings

SURF has to determine an appropriate retention period for the storage of Content Data in EduGenAI's back-end server. The proposed bandwidth is between 13 and 24 months after a user has become inactive. Additionally, COs and end users can actively delete these Content Data by deleting their chat history.

12.3 Logs SURF AI-Hub

SURF AI-Hub retains the CO admin logs with the Trace ID and API Key at most 30 days.

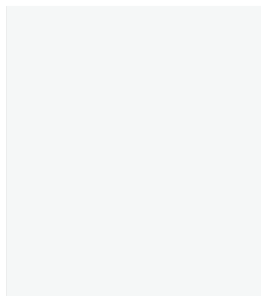
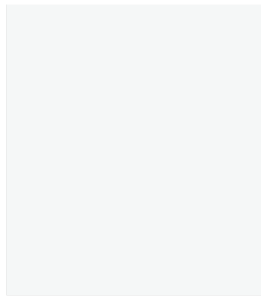
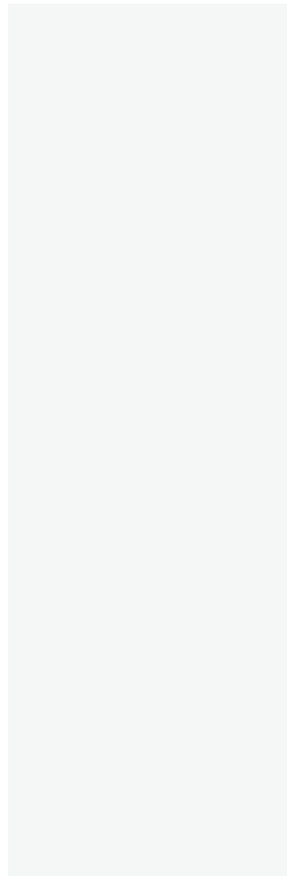
12.4 Logs SURF EduGenAI

The developers of EduGenAI are developing a lifecycle policy for the logs with personal data. They need more experience with troubleshooting and support requests from the COs to determine the maximum retention period. They currently assume they need a retention period of minimum 30 and maximum 90 days.

EduGenAI Development Goals

- By default store the chat history exclusively in the device of the user, but ask users for consent to store the chat history on EduGenAI servers for a period of 6 months after the last user activity.
- Enable the COs to determine a retention period for the pseudonymised chat history for research purposes, in line with research verification obligations.
- After having had some practice with the logs, determine the necessary retention period for the logs from EduGenAI.

PART B



13 Introduction

The second part of the DPIA assesses the lawfulness of the data processing. This part contains a discussion of the legal grounds, an assessment of the necessity and proportionality of the processing, and of the compatibility of the processing in relation to the purposes.

14 Legal Grounds

To be permissible under the GDPR, processing of personal data must be based on one of the grounds mentioned in Article (6) (1) GDPR. Essentially, for processing to be lawful, this article demands that the data controller bases the processing on the consent of the user, or on a legally defined necessity to process the personal data.

The assessment of available legal grounds (sometimes called 'lawful bases') is tied closely to the principle of purpose limitation. The EDPB notes that

*"The identification of the appropriate lawful basis is tied to principles of fairness and purpose limitation. [...] When controllers set out to identify the appropriate legal basis in line with the fairness principle, this will be difficult to achieve if they have not first clearly identified the purposes of processing, or if processing personal data goes beyond what is necessary for the specified purposes."*¹⁰²

Thus, in order to determine whether a legal ground is available for a specific processing operation, it is necessary to determine for what purpose(s), the data was or is collected and will be (further) processed. There must be a legal ground for each of these purposes.

The appropriate legal ground furthermore depends on the role of EduGenAI as (joint) controller, or as processor.

As described in [Section 1.2](#), EduGenAI, SURF's AI-Hub and the COs processes five relevant categories of personal data

1. Content Data (including Feedback via thumbs)
2. Account Data
3. Diagnostic Data
4. Support Data

¹⁰² EDPB, Guidelines 2/2019 on the processing of personal data under Article 6(1)(b) GDPR in the context of the provision of online services to data subjects - version adopted after public consultation, 16 October 2019, URL: https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-22019-processing-personal-data-under-article-61b_en.

5. Website Data (cookie)

The sections below discuss the appropriate legal ground for the processing per purpose, for each category of personal data, from the perspective of the COs. They have to rely on a different legal ground when SURF acts as processor or controller for the AI-Hub, and when they are joint controllers with EduGenAI. [Table 4](#) and [Table 5](#) below show the different purposes per category of personal data, first by the AI-Hub, and second by EduGenAI.

Note: [Table 5](#) does not show the additional purposes COs may have for the use of EduGenAI, such as for example saving time by helping students create summaries. These purposes have to be assessed by each CO itself, discussed internally with the privacy officers and DPO, and added to the CO-specific version of this umbrella DPIA.

Additionally, the COs have to analyse the compatibility of further processing of personal data by the external cloud LLMs, if they permit access to those models, with or without applying a personal data masking filter.

Table 5 - Types of personal data processing per purpose by SURF as hosting provider

Category of personal data	Hosting of back-end in the AI-Hub and hosting of Webapp by SURF	Processor purposes	Controller purposes
Content Data	Currently: all Content Data (chat history, uploaded documents and the databased of encrypted chunks). Future: no chat history	Technically provide and improve the hosting service.	Comply with legal obligations (incl. data subject rights).
		Keep the service up to-date.	
		Keep the service secure.	
		Help exercise data subject rights.	
Account Data	SRAM accounts of admins (group managers): username, e-mail address, CO, API-key.	Help exercise data subject rights	Billing, financial bookkeeping.
			Comply with legal obligations (incl. data subject rights).
			Create aggregated statistical, non-personal analytics from usage logs with pseudonymised identifiers to calculate a

			reasonable average usage, to support billing, and to map excessive usage.
		Detect unauthorised access attempts, protect against malicious actors and attacks	Calculate statistics related to use of LLMs and compute for internal reporting and business modelling, such as technical infrastructure forecasting, and AI-Hub climate impact reporting.
Diagnostic Data	TraceID, API key, timestamps, tokens in/out, ttft, gpu-time, used model, wattt.	Detect unauthorised access attempts, protect against malicious actors and attacks	Calculate statistics related to use of LLMs and compute for internal reporting and business modelling, such as technical infrastructure forecasting, and AI-Hub climate impact reporting.
Support Data	The (admin) usernames of the API key holders for EduGenAI + content of support request	Provide second and third line support to admins of SRAM groups.	Not applicable
Website Data	IP-addresses + technical access data	Keep the web application secure / protect against malicious actors and attacks.	Prevent central storage of chat history with a cookie.

Table 6 - Types of personal data processing per purpose by SURF as joint controller

Category of personal data	EduGenAI webapp and SQL database	Joint controller purposes
Content Data	Currently: chat history and uploaded chunks of documents and vector embeddings used for Personae in the SQL front-end database	Enable users to interact with different <i>on-premises</i> and cloud AI-models in a privacy friendly way.
		Enable incidental and permanent grounding.
		Prevent overreliance on AI.

		Apply specific data minimisation and pseudonymisation measures to preserve the privacy of users.
		Perform accuracy and quality research.
Account Data	Name, e-mail address, role (student, teacher, admin etc) + CO of each person with access	Access management.
		Apply specific data minimisation and pseudonymisation measures to preserve the privacy of users.

Below, only the potentially valid legal grounds for education organisations will be discussed. The legal ground of vital interest (Article 6 (1) (d) GDPR) is not discussed, since nor SURF nor the COs have a legal obligation or a vital (lifesaving) interest in processing personal data via EduGenAI.

14.1 Legal grounds for education organisations

Below the five potentially applicable legal grounds are discussed for different purposes of the processing, both when education organisations act as independent data controllers that give instructions to SURF as data processor, and when they act as joint controllers with SURF.

When students include other students' data in their grounding, chats or Personae, they don't need a legal ground, as this falls under the household exception (Article 2(2) sub c of the GDPR). Only if a CO decides to let students or teachers share a Personae more widely than beyond the class, the CO needs a legal ground for this processing of personal data.

14.1.1 Consent

Article 6 (1) (a) GDPR reads: *"the data subject has given consent to the processing of his or her personal data for one or more specific purposes"*

Education organisations generally should not ask for consent from the persons whose personal data may be processed or generated through EduGenAI, because they cannot predict what personal data EduGenAI will generate. As outlined in [Section 2.3](#), data subjects can be students, teachers, researchers and any other individual whose data are included in the training data for an LLM, or whose personal data are part of the grounding, or whose personal data are generated by EduGenAI.

But even if COs could in some limited circumstances identify the persons whose personal data they plan to process (for example, personal data included in a dataset used for grounding or as a stack of interviews to be summarised), the fact that education organisations are public sector organisations makes it difficult to rely on consent. In the context of Recital 43 of the GDPR, the EDPB explains:

"whenever the controller is a public authority, there is often a clear imbalance of power in the relationship between the controller and the data subject. It is also clear in most cases that the data subject will have no realistic alternatives to accepting the processing (terms) of this controller. The

EDPB considers that there are other lawful bases that are, in principle, more appropriate to the activity of public authorities.”¹⁰³

In their role as independent data controllers (with SURF as data processor), COs can ask users of EduGenAI for their consent for the storage of their chat history in the (database behind the) webapp. To ensure users are free to give or withhold consent, EduGenAI has to meet the development goal of storing the chat history by default in their own browser (locally) and explain the privacy benefits and risks of server-side storage in a clear and unambiguous way. Additionally, they have to take into account that the chat history and RAG-documents are likely to contain sensitive and special categories of data. See Section 13 below. Once the storage choice option has technically been implemented, EduGenAI can also create a form to ask for informed and explicit consent for the further processing of pseudonymised chat histories (voluntarily stored in the webapp database by users) for quality and accuracy research purposes.

14.1.2 Necessary for the performance of a contract

Article 6 (1) (b) GDPR reads: “processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract.”

As data controllers education organisations may require employees to use EduGenAI to carry out the tasks included in their job description (and not use any other commercial cloud LLM). As described in Section 7.1, Dutch education organisations may have various potential interests in using generative AI-services, including efficiency reasons. Additionally, the creation of Personae can help make specific information in a research group, faculty or organisation more accessible. To be able to successfully invoke the legal ground of ‘performance of a contract’ with respect to end users (employees), the processing of the personal data via EduGenAI has to be strictly necessary for the performance of the contract with each individual data subject (employee). This means a general availability of EduGenAI licenses for all employees is less likely to meet the necessity bar. Maybe organisations can rely on this legal ground in specific cases, if they assign individual licenses to employees for whose specific work tasks use of EduGenAI can be qualified as necessary.¹⁰⁴

It is less plausible that use of EduGenAI is strictly necessary for students to perform their study tasks as part of the curriculum. It is up to the individual schools and universities to substantiate if they can rely on this legal ground.

14.1.3 Necessary for compliance with a legal obligation

If users wish to exercise their rights to access, correction, deletion or data portability, the COs as data controllers have to (instruct SURF to) reply in line with the legal obligations from articles 15-20 of the GDPR. To this data processing the legal ground of article 6(1)c of the GDPR applies.

¹⁰³ EDPB, *Guidelines on consent*, paragraph 3.1.1.

¹⁰⁴ See: Microsoft, Understand licensing requirements for Microsoft 365 Copilot, 19 November 2024, URL: <https://learn.microsoft.com/en-us/copilot/microsoft-365/microsoft-365-copilot-licensing>.

Similarly, SURF and the COs are required by the GDPR and other specific security rules to secure data. They may rely on the legal ground of Article 6(1) c of the GDPR for the processing of the EduGenAI and SURF AI-Hub Diagnostic Data, including storing these data for the period necessary *“to ensure a level of security appropriate to the risk”* (Article 32 GDPR).

14.1.4 Necessary for a task in the public or a legitimate interest

Article 6 (1) (e) GDPR reads: *“processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller”*.

Article 6 (1) (f) GDPR reads: *“processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.”*

Public sector organisations are excluded from relying on legitimate interest when processing personal data for public services. The last sentence of Article 6 (1) of the GDPR explains: *“Point (f) of the first subparagraph shall not apply to processing carried out by public authorities in the performance of their tasks.”* This excludes the application of the legitimate interest ground for processing carried out by public sector organisations in the performance of their tasks.

However, the choice to use EduGenAI is generally secondary to the performance of public tasks by education organisations. Therefore, use of EduGenAI can be considered as a task primarily exercised under private law, allowing the COs to invoke their legitimate interest as a valid legal ground for the processing.

Both legal grounds (public interest and legitimate interest) require an assessment by each CO of the necessity of the personal data processing, of the proportionality and availability of alternative, less infringing means to achieve the same legitimate purposes (subsidiarity).

Based on an assessment of the use of another generative AI-service, the Norwegian DPA offers helpful questions for COs to assess if they can rely on article 6(1) e of the GDPR for purposes related to effectiveness [as rephrased by Privacy Company]:

- Is EduGenAI suitable to fulfil the CO’s educational purposes in a better way?
- How much better does the CO achieve the purpose(s) of the processing if it uses EduGenAI?
- Are there other ways the CO can reasonably achieve its purpose(s) just as well?
- How much more invasive are the new processing operations to the data subjects' privacy-related rights and freedoms?
- Are there measures the CO can take to make processing with EduGenAI less invasive?¹⁰⁵

¹⁰⁵ Datatilsynet, ‘Copilot med personverbriller på’ (informally translated by Privacy Company as Copilot with safety glasses on), 27 November 2024, p. 14.

According to the Norwegian DPA, education organisations may also rely on the necessity for their legitimate interest, per article 6(1) f of the GDPR, for self-determined purposes related to efficiency. The DPA specifies that NTNU must meet the following conditions:

- *“the processing is not carried out in the performance of a task carried out by a public authority,*
- *the new purpose is compatible with the original purpose if, as will often be the case, the personal data to be processed was collected for a different purpose, cf. Article 6(4) of the GDPR,*
- *The CO conducts a new and updated balancing of interests that comes out in the CO’s favour,*
- *The CO complies with all other obligations in the GDPR.*¹⁰⁶

Depending on these answers, as joint controllers for the Content Data COs can invoke either 6(1)e or 6(1)f, or if they ground with data collected for other purposes, if the further processing is compatible with the original purposes (6(4)) for the following four purposes:

1. Incidental and permanent grounding (the Diagnostic Data and the personal data in the Content Data),
2. Enable users to interact with different on-premises and cloud AI-models in a privacy friendly way,
3. Prevent overreliance on AI (through accuracy and quality research),
4. Preserve the privacy of users.

As independent data controllers (with SURF as data processor), COs can invoke the legal ground of necessity for their legitimate business interest for the data processing of the other categories of personal data by SURF to provide an up-to-date and secure service, including access management and logging, the provision of support, provision of usage statistics and protection against abuse

14.2 Legal grounds for SURF as independent data controller

As described in Section 6.5, SURF processes personal data for 5 specific purposes as independent data controller.

These 5 purposes are:

1. Use of a cookie to store chat history in browser
2. Usage analytics to determine average usage
3. Billing
4. LLM usage statistics for technical forecasting, to calculate a reasonable average usage, to support billing, and to map excessive usage.
5. Compliance with legal obligations, including replying to requests from data subjects relating to personal data SURF processes as independent data controller.

¹⁰⁶ Idem.

The legal ground for the use of the cookie is consent, as long as users can also choose to store their chat history in the (database behind the) webapp. See [Section 12.1.1](#) above.

The legal ground for purposes 2 to 4 is the necessity for the legitimate business interest of SURF as hosting provider for the LLMs and administrator/developer of the AI-Hub. The processing of limited personal data for these purposes is strictly necessary to be able to create a viable and structurally funded service for the COs. To ensure the proportionality of the processing for these purposes, SURF will aggregate the logs with the pseudonymised identifiers to the level of a CO, never per user, to prevent reidentifiability.

Finally, for the fifth purpose SURF is able to invoke the legal ground of compliance with a legal obligation. If SURF receives a request for disclosure of personal data from a government authority, SURF first needs to establish without a trace of doubt that it has to comply with a specific legitimate order and is prohibited from redirecting the order to the CO. For the data processing to be necessary, SURF also needs to establish procedures to ensure that only strictly necessary data are disclosed.

15 Special categories of personal data

Special categories of data are *"data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health, data concerning a natural person's sex life or sexual orientation"* (Art. 9(1) GDPR).

Additionally, based on Article 10 GDPR, the processing of personal data relating to criminal convictions and offences or related security measures is even more restricted.

As described in [Section 3.3](#), EduGenAI will not process any Content Data as part of the Diagnostic Data. As explained in [Section 2.2](#) of this DPIA, the Content Data may contain a wide variety of pseudonymised sensitive and special categories personal data by grounding with EduGenAI.

One of the development goals for EduGenAI is to perform quality and accuracy research of the different LLMs based on the pseudonymised chat histories. EduGenAI and the COs will use the outcomes to develop a Responsible AI-filter that respects European human rights. The filter will apply normative values to prevent processing of special categories of personal data for unlawful discrimination, and promote respect for rights such as equality.

The use of EduGenAI, including (voluntary) server-side storage of the chat history, pseudonymisation through the personal data masking filter (including the chunks from the attached documents), and processing for research purposes, is likely to involve processing of special categories of data. The pseudonymisation doesn't change the legal status of the special categories of personal data. This means EduGenAI and the COs need to be able to rely on a legal exception on the prohibition of the processing of special categories of data.

For the voluntary storage, EduGenAI and the COs can rely on the explicit consent from end users (Article 9(2) sub a GDPR). However, if the data processing involves special categories of data about persons whom the COs do not have a relation with and cannot ask for consent, COs can only rely on the exception of the necessity for research purposes, in accordance with the requirements from Article 89 of the GDPR (as defined in Article 9(2) sub j GDPR, and defined in Article 24 of the Dutch implementation act of the GDPR, the UAVG). When assessing the exception under Article 89, EduGenAI and COs must ensure that safeguards such as pseudonymisation are properly implemented. The default application of the Presidio filter is an important measure to safeguard the fundamental rights and the interests of the data subject.

The Dutch GDPR implementation allows data controllers to invoke six of the general exceptions from Article 9 GDPR for the processing of criminal data, including explicit consent, data manifestly made public by the data subject, and research purposes.¹⁰⁷

Even if an exception to the prohibition on the processing of special categories of personal data and criminal data applies, SURF and the COs still need to have a legal ground for the processing in Article 6 of the Regulation. See [Section 12](#) of this DPIA.

16 Purpose limitation

The principle of **purpose limitation** is that data may only be “collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes shall, in accordance with Article 89(1), not be considered to be incompatible with the initial purposes” (Article 5 (1) (b) GDPR). Essentially, this means that the controller must have a specified purpose for which he collects personal data, and can only process these data for purposes compatible with that original purpose.

Data controllers must be able to prove, based on Article 5(2) of the GDPR, that they comply with this principle (accountability). As explained in [Section 6.3](#) of this report, only data controllers may take decisions about the purposes and means of the data processing, including the decisions to process the data for additional purposes. By performing this DPIA in an early stage of the development of EduGenAI, SURF has been able to identify specific purposes for the processing in the different roles, as processor, as joint controller and as independent data controller.

As listed in [Table 5](#) in [Section 12](#), the COs can authorise SURF as processor to process personal data for five specific purposes, depending on the category of personal data:

1. Technically provide and improve the hosting service.
2. Keep the service up to date.
3. Keep the service and web application secure, including detection of unauthorised access attempts and protection against malicious actors and attacks.

¹⁰⁷ See Article 32 UAVG, *Algemene uitzonderingsgronden inzake gegevens van strafrechtelijke aard*.

4. Help exercise data subject rights.
5. Provide second and third line support to admins of SRAM groups.

Table 6 above lists six different purposes when the COs and SURF operate as joint controllers (for decisions about the Content Data. These purposes are:

1. Enable users to interact with different on-premises and cloud AI-models in a privacy friendly way.
2. Enable incidental and permanent grounding.
3. Prevent overreliance on AI.
4. Apply specific data minimisation and pseudonymisation measures to preserve the privacy of users.
5. Perform accuracy and quality research.
6. Access management.

Finally, Section 12.2 lists 5 purposes for which SURF has to process as independent data controller:

1. Use of a cookie to store chat history in browser
2. Usage analytics to determine average usage
3. Billing
4. LLM usage statistics for technical forecasting, to calculate a reasonable average usage, to support billing, and to map excessive usage.
5. Compliance with legal obligations

SURF can list these purposes in the future Data Processing Agreement and joint controllership agreement with the COs, specifically exclude certain purposes of the data processing (as mentioned in Section 6.3.5), and include steps assuring the COs that SURF will prevent disclosure to government authorities. If SURF also applies technical and organisational measures to ensure that EduGenAI and AI-Hub employees only access the personal data for the authorised purposes, the COs can rely on these contractual guarantees and privacy controls to prevent any personal data from being processed beyond the authorised purposes.

As noted in the introduction of Section 12, this section cannot list the possible additional purposes COs may have for the use of EduGenAI, such as for example saving time by helping students create summaries. These purposes have to be assessed by each CO itself, discussed internally with the privacy officers and DPO, and added to the CO-specific version of this umbrella DPIA.

17 Necessity and proportionality

17.1 The concept of necessity

The concept of necessity is made up of two related concepts, namely proportionality and subsidiarity. The personal data which are processed must be necessary for the purpose pursued by the processing activity. Proportionality means the invasion of privacy and the protection of the personal data of the data subjects is proportionate to the purposes of the processing. Subsidiarity means that the purposes of the processing cannot reasonably be achieved with other, less invasive means. If so, these alternatives have to be used.

Proportionality demands a balancing act between the interests of the data subject and the data controller. Proportionate data processing means that the amount of data processed is not excessive in relation to the purpose of the processing. If the purpose can be achieved by processing fewer personal data, then the controller needs to decrease the amount of personal data to what is necessary.

Therefore, essentially, the data controller may only process the personal data that are necessary to achieve the legitimate purpose but may not process personal data he or she may do without. The application of the principle of proportionality is thus closely related to the principles of data protection from Article 5 GDPR.

This umbrella DPIA offers a preview of future functionality of EduGenAI, and of the mitigating measures, listed as 'development goals' in asides throughout this DPIA. SURF will update this DPIA after the launch of EduGenAI, but education organisations also have to conduct or document their own assessment for their intended use-cases.

17.2 Assessment of the proportionality

The key questions are: are the interests properly balanced? And does the processing not go further than what is necessary?

To assess whether the processing is proportionate to the interest pursued by the data controller(s), the processing must first meet the principles of Article 5 of the GDPR. Data controllers have to comply with this legal conditions to make the data protection legitimate. Below, these conditions are elaborated in four subsections:

1. Lawfulness, Fairness and Transparency
2. Data minimisation and privacy by design
3. Accuracy
4. Storage limitation

17.2.1 Lawfulness, Fairness, and Transparency

Data must be 'processed lawfully, fairly and in a transparent manner in relation to the data subject' (Article 5 (1) (a) GDPR). This means that data subjects must be informed about the processing of their data, that all the legal conditions for data processing are adhered to, and that the principle of proportionality is respected.

Lawfulness

As assessed in [Section 9.2](#) Large Language Models are trained on vast amounts of data, including vast amounts of personal data. As OpenAI puts it: “A large amount of data on the internet relates to people.” As the EDPB writes in its Opinion for the Irish DPC on the use of generative AI: “For example, the use of web scraping in the development phase may lead - in the absence of sufficient safeguards - to significant impacts on individuals, due to the large volume of data collected, the large number of data subjects, and the indiscriminate collection of personal data.”¹⁰⁸ The LLMs are not transparent what sources they have used, or how legitimate this further processing of personal data is. They may become more transparent when specific new obligations of the AI Act enter into force.

The Irish DPC specifically asked the EDPB what the consequences are of unlawful processing of personal data in the development phase of an AI model on the subsequent processing or operation of the AI model. The EDPB replied that the controllers (in this case SURF and the COs as joint controllers for the processing of the Content Data) should conduct an

“appropriate assessment, as part of its accountability obligations to demonstrate compliance with Article 5(1)(a) and Article 6 GDPR, to ascertain that the AI model was not developed by unlawfully processing personal data. (...) The controller should assess at least the following criteria: “the source of the data and whether the AI model is the result of an infringement of the GDPR, particularly if it was determined by a SA or a court, so that the controller deploying the model could not ignore that the initial processing was unlawful.”¹⁰⁹

Absent public guarantees about lawful data processing from any of the publicly available LLMs that SURF considers using, with the possible future exception of GPT-NL, SURF cannot exclude that the GDPR has been infringed by these LLMs.

However, thanks to the use of the personal data masking filter, the option to exclude LLMs if a supervisory authority or court rules the processing unlawful, and measures to strip identifying data from queries before sharing prompts with the LLMs, SURF and the COs can demonstrate their compliance with the principle of lawfulness. As assessed in [Sections 12 and 13](#) of this DPIA, COs have a legal ground for the processing of ‘regular’ and special categories of data through EduGenAI.

Fairness

Fairness is an overarching principle which requires that personal data shall not be processed in a way that is detrimental, discriminatory, unexpected, or misleading to the data subject.¹¹⁰ Since EduGenAI is work-

¹⁰⁸ EDPB, Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models, adopted on 17 December 2024, URL: https://www.edpb.europa.eu/system/files/2024-12/edpb_opinion_202428_ai-models_en.pdf.

¹⁰⁹ Idem, par. 129.

¹¹⁰ EDPB Guidelines 4/2019 on Article 25 Data Protection by Design and Default, version 2.0, adopted on 20 October 2020, p. 16, URL: https://edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_201904_dataprotection_by_design_and_by_default_v2.0_en.pdf.

in-progress, this DPIA cannot yet assess if EduGenAI and the COs will be able to comply with the principle of fairness.

However, as part of this DPIA, SURF has identified several design measures to prevent misleading data subjects, such as showing different warnings, and showing them replies from two different LLMs to a single prompt, to prevent users from confusing the chat with the results of a search engine. SURF and the COs will have to learn from research what the most effective measures are.

EduGenAI and the COs will also have to jointly work on a content filter that respects European human rights.

Transparency

The principle of transparency not only ensures that consent must be informed but that controllers can ensure full transparency of data practices and rights to users.

One of SURF's identified development goals is to provide an exhaustive list of all the Diagnostic Data it processes through EduGenAI's webapp, and through the AI-Hub. SURF can use the lists provided in [Sections 3.3, 3.5 and 3.6](#).

Additionally, SURF will have to create a Cookie Policy and an explanation about the current hard-coded filter and future content filter to end-users. With these publications, SURF can help the COs comply with their obligations to inform users about the processing of personal data in conformity with Article 13 GDPR.

17.2.2 Data minimisation and privacy by design

The [principles of data minimisation and privacy by design](#) require that the processing of personal data be limited to what is necessary. The data must be 'adequate, relevant and limited to what is necessary for the purposes for which they are processed' (Article 5(1)(c) of the GDPR). This means that the controller may not collect and store data that are not directly related to a legitimate purpose. According to this principle, the default settings for the data collection should be set in such a way as to minimise the data collection by using the most privacy friendly settings. Three relevant measures are mentioned in [Section 5.1.5](#):

1. Strip all metadata (IP-addresses, cookies, identifiers) from the user queries.
2. Apply a personal data masking filter to the contents of queries.
3. Allow the COs to determine what LLMs can be accessed (only on-premises, or also cloud LLMs).

Additionally, the choice to store the chat history by default in cookies in the browser on the end user device, and not centrally on SURF's servers, is a good example of the application of privacy by default.

17.2.3 Accuracy

The [principle of accuracy](#) requires that the personal data be accurate and, where necessary, kept up to date. "[E]very reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay" (article 5 (1) (d))

GDPR). According to the EDPB, the controller should consider this principle “in relation to the risks and consequences of the concrete use of data.”¹¹¹

The Norwegian DPA notes in a report about a DPIA on Microsoft Copilot, another generative AI service:

“If the M365 Copilot generates incorrect personal data about someone, firstly, it may be difficult for the user to verify whether the response contains errors, and secondly, it may pose a high risk to the rights of the data subject.”¹¹²

And

“It therefore makes sense to consider which areas or tasks are not suitable for the use of generative AI tools. This could, for example, be some tasks within HR or the exercise of public authority, which require a high degree of precision and accuracy and where the consequences of errors can be serious.”¹¹³

EduGenAI can generate plausibly sounding but inaccurate statements about people. The consequences of such inaccurate personal data can be severe for the affected data subjects, as illustrated with examples in [Section 9.1](#).

Below, this section addresses two issues with the accuracy of generated personal data: (i) the fact that data may be incorrect or outdated and (ii) overreliance on AI.

Incorrect personal data

The LLMs used by EduGenAI may generate Content Data about data subjects that are inaccurate. The generation of incorrect data about data subjects is a common issue across all LLMs. [Section 9](#) describes two origins of incorrect personal data in generative AI responses:

1. The large language models are trained on publicly available data, and the training data may contain inaccurate or outdated data.
2. The models may deterministically output incorrect data.

EduGenAI is designed to augment prompts with additional content from RAG-documents uploaded by users. This can lead to two more sources of inaccuracy:

3. RAG-documents may themselves contain inaccurate personal data.

¹¹¹ EDPB, Guidelines 4/2019 on Article 25 Data Protection by Design and by Default – version adopted after public consultation, 20 October 2020, URL: https://www.edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_201904_dataprotection_by_design_and_by_default_v2.0_en.pdf.

¹¹² Datatilsynet, ‘Copilot med personverbriller på’ (informally translated by Privacy Company as **Copilot with safety glasses on**), 27 November 2024, p. 22.

¹¹³ Idem.

4. EduGenAI may introduce inaccuracies during the process of pseudonymisation.

The ability to correct inaccurate personal data is a fundamental right under the GDPR. While EduGenAI provides organisations with the ability to remove uploaded RAG documents that contain inaccurate data, or are leading to incorrect outputs, EduGenAI does not yet have the ability to prevent third party LLMs (both on-premises and in third party clouds) from regenerating inaccurate personal data. EduGenAI has the ability to add a hardcoded meta prompt to reduce the risk of hallucination.

As described in in [Section 9.2](#) one of EduGenAI's development goals is to offer a procedure to end users and teachers to report inaccurate personal data relating to them. Other identified development goals to address the risk of inaccurate personal data are:

- Forward reports about inaccurate data to the LLMs, and agree on a procedure with the LLMs that they prevent regeneration of reported inaccurate personal data.
- Perform quality and accuracy research with the COs, and develop guidance on the best type of model for specific tasks.
- Help COs develop mini GPTs based on accurate personal data, and help COs fine-tune those models in case of inaccurate personal data.
- Implement guardrails/content filters that will be hosted on-premises and will be configurable by EduGenAI. In these filters AI-Hub and EduGenAI can also add anonymisation techniques.

Additionally, COs must develop standards what type of documents and data can be used for grounding.

Overreliance on AI

Overreliance on AI is a fundamental new problem affecting the proportionality of the data processing. It is hard for end users to grasp the nature of a chatbot as a tool that does not have intelligence, but predicts the next logical word based on logic. End users may also confuse the chatbot with a search engine that retrieves information. To help prevent overreliance, EduGenAI has taken and identified 9 different technical measures. These are:

1. Change the warning text about inherent inaccuracy risks to users every 30 seconds or every 10 prompts: different text, different font and colours etc.
2. Show two replies to a prompts from two different LLMs to visually remind users that they are not using a search engine, but a text completion engine.
3. Show the snippets of text used by the AI-model when referring to sources uploaded by the user (RAG) (instead of referring to the entire document).
4. Apply the (on-premises) Presidio filter to mask personal data before sharing prompts and RAG-documents with cloud LLMs and search engines. Allow COs to disable this filter if necessary for specific tasks.
5. Hardcoded filter for reliability set to a very high percentage. If no tokens can be found in the immediate vicinity, the AI-model will always answer 'I don't know'.

6. Strip all metadata from prompts before sharing the prompts with third parties, only use a pseudo randomly generated trace ID per request (not per user). This step can assist users to look up more recent data in search engines without incurring new data protection risks.
7. Intention to develop and check the adequacy of a Responsible AI filter that complies with European Human Rights together with the COs. Allow COs to disable the content filter for specific tasks.
8. Enable users to file reports about inaccurate personal data relating to them.
9. Ask users to consent to store their chat histories and use the pseudonymised chat histories for accuracy and quality research. Based on the outcomes of the research, SURF can recommend specific LLMs for specific use cases

17.2.4 Storage limitation

The principle of **storage limitation** demands that personal data are only retained as long as necessary for the purpose in question. Data must be *“kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed”* (article 5 (1) (e), first sentence GDPR). *This principle therefore demands that personal data are deleted as soon as they are no longer necessary to achieve the purpose pursued by the controller. The text of this provision goes on to clarify that “personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) subject to implementation of the appropriate technical and organisational measures required by this Regulation in order to safeguard the rights and freedoms of the data subject”* (article 5 (1) (e), second sentence, GDPR).

By default EduGenAI will not store the chat history. If users consent to storage on SURF’s servers, EduGenAI will retain the chat history for a period of 6 months after the last user activity. This period does not seem disproportionately long, as students may want to retrieve their history to verify sources in a paper or thesis.

As described in [Section 11](#) SURF applies short retention periods to the Diagnostic Data from the AI-Hub and from EduGenAI. The EduGenAI developers and AI-Hub intend to store the admin logs for 6 months and logs of interactions with the system for 30 days to achieve legitimate purposes such as monitoring application performance, ensuring availability, technical troubleshooting, providing support and protection against abuse. These logs are stored by the AI-Hub per API key, per institution. This falls within and well below the recommendation from the French data protection authority CNIL to retain logs between 6 and 12 months.¹¹⁴

In sum, based on the SURF’s development goals to ensure lawfulness, fairness and transparency of the data processing, as well as privacy by design measures, the long list of measures to prevent overreliance

¹¹⁴ CNIL, 18 November 2021 (in French), La CNIL publie une recommandation relative aux mesures de journalisation, URL: <https://www.cnil.fr/fr/la-cnil-publie-une-recommandation-relative-aux-mesures-de-journalisation>.

on AI and the short retention periods, the data processing via EduGenAI will comply with the proportionality requirements.

17.3 Assessment of the subsidiarity

The key question is whether the same goals can be reached with less intrusive means.

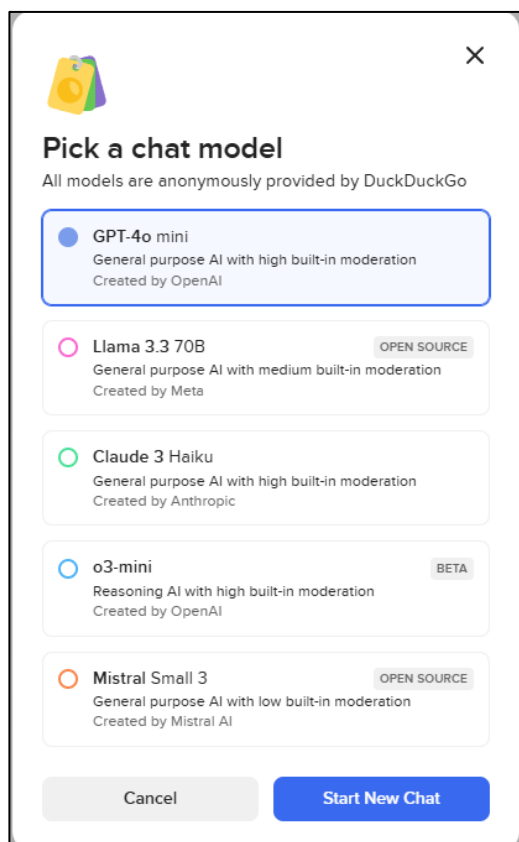
EduGenAI was designed to overcome many of the identified data protection risks related to the use of generative AI services. SURF has published a DPIA on the use of Microsoft 365 Copilot in December 2024.¹¹⁵ This DPIA identifies 4 high and 7 low data protection risks. It follows from SURF's most recent update that these risks have not yet been mitigated.¹¹⁶ Absent other public DPIAs on other providers of generative AI-systems, even if they offer paid access to Education licenses with a data processing agreement, it is unlikely that such alternatives are more compliant with the GDPR.

However, there is one alternative solution with a similar privacy friendly approach as EduGenAI, from the US American company DuckDuckGo. The website Duck.ai promises anonymous access to different popular LLMs. Duck.ai stores the chat history in the browser of the user, and does not share any personal data from *users with the LLMs other than the Content Data users choose to provide as part of their prompt*.

¹¹⁵ DPIA on Microsoft 365 Copilot for Education commissioned by SURF, Public version, 17 December 2024, URL: <https://www.surf.nl/files/2024-12/20241218-dpia-microsoft-365-copilot.pdf>.

¹¹⁶ SURF Update DPIA Microsoft 365 Copilot, 17 April 2025, URL: <https://vendorcompliance.surf.nl/en/update-dpia-microsoft-365-copilot/>.

Figure 28: Duck.ai choice between different cloud LLMs



Duck.ai also writes it has agreements in place with all LLM providers

“that further limit how they can use data from these anonymous requests, including not using Prompts and Outputs to develop or improve their models, as well as deleting all information received once it is no longer necessary to provide Outputs (at most within 30 days, with limited exceptions for safety and legal compliance).”¹¹⁷

However, different from EduGenAI, DuckDuckGo does not offer Education licenses as data processor, does not offer grounding, and does not apply the other privacy friendly measures such as the data masking filter. This means DuckDuckGo receives the prompts and replies as an independent data controller. COs also have to assess the risks of data transfer to third countries. DuckDuckGo explains:

“we have servers across the world and while your device will typically try to automatically connect to regional servers (e.g., European servers in Europe, U.S. servers in the U.S.), you could be using a VPN from another country. Additionally, DuckDuckGo team members are also distributed worldwide, and while we have robust security and access controls in place, authorized team members access

¹¹⁷ Duck AI Privacy Policy, last updated 8 May 2025, URL: <https://duckduckgo.com/duckai/privacy-terms>.

DuckDuckGo servers as necessary to operate our services. In such scenarios, if any cross-border transfers are necessary, we will follow applicable legal requirements.”

18 Rights of data subjects

The GDPR grants data subjects the right to information, access, rectification and erasure, object to profiling, data portability and file a complaint. It is the data controller's obligation (in this case, a Dutch Education organisation) to provide information and to duly and timely address these requests. If the data controller has engaged a data processor, the GDPR requires the data processing agreement to include that the data processor will assist the data controller in complying with data subject rights requests.

As summarised in [Section 14](#) SURF qualifies as joint controller with the COs for the processing of the Content Data through EduGenAI, as processor for the other 4 categories of data, and as independent data controller for very specific authorised 'further processing' purposes of all categories of personal data.

When SURF and the COs act as joint data controller, they have to contractually agree (per Article 26 of the GDPR) how data subjects can exercise their rights. As EduGenAI is work-in-progress, this contract has yet to be drafted.

18.1 Right to information

Data subjects have a right to information. This means that data controllers must provide people with easily accessible, comprehensible and concise information in clear language about, inter alia, their identity as data controller, the purposes of the data processing, the intended duration of the storage and the rights of data subjects.

One of the purposes of this umbrella DPIA is to help COs that wish to use the EduGenAI to better inform their employees and students about the agreed scope and purposes of the data processing. As identified in [Section 2.4](#), SURF needs to develop and publish a specific EduGenAI privacy policy for users, a EULA and/or Acceptable Use Policy and a copyright policy in line with AI Act requirements. Additionally, as assessed in [Section 15.2.1](#) above, SURF must publish an exhaustive list of all the Diagnostic Data it processes through EduGenAI's webapp, and through the AI-Hub, a Cookie Policy, and explanations about the current hard-coded filter and future content filter.

In sum, SURF needs to develop and publish the documentation described above to assist the COs with their obligations as (joint) controllers to provide their employees and students with adequate information about all purposes of the data processing.

18.2 Right to access

Secondly, data subjects have a (fundamental) right to access personal data concerning them. Upon request, data controllers must inform data subjects whether they are processing personal data about them (directly, or through a data processor). If this is the case, they must provide data subjects with a copy of the personal

data processed, together with information about the purposes of processing, recipients to whom the data have been transmitted, the retention period(s), and information on their further rights as data subjects, such as filing a complaint with the Data Protection Authority.

When SURF is a processor, it must enable the COs to help users exercise their rights. As a processor SURF will develop a Do It Yourself data access and download tool for the Diagnostic Data via EduGenAI, and for the admins, to the Diagnostic Data relating to them from the AI-Hub. This DPIA has already identified the personal data EduGenAI and the AI-Hub can and will provide.

EduGenAI currently offers end users an option to access (and delete) their historical chats. However, in the near future, the chat history will be stored in users' browsers by default, and not on SURF's servers. As joint controllers, SURF and the COs have to agree how EduGenAI will process data subject access requests for Content Data when these requests are filed by end users. The proposed local storage in cookies may lead to inadvertent deletion, if users erase all cookies in their browser. Additionally, export of the chat history from cookies may not be user friendly enough. SURF and the COs must clearly educate users about the possible negative consequences of storing the chat history in the browser. In order to help users create an archive of their chat history that they can export to a (secure) server, one of EduGenAI's development goals is to offer a simple way for end users to export and import data from cookies (See [Section 3.6](#)). Another important goal is to create a dedicated contact method for additional questions and requests from users.

When SURF is authorised to further process some personal data for its own legitimate business purposes, SURF itself must answer requests.

The controller (be it the COs and/or SURF) must also provide detailed reasoning to users if they cannot provide access, because the data are no longer available, or no longer identifiable, and when they withhold access to protect the rights of others, including themselves.

As the EDPB explains in its Guidelines on restrictions under Article 23:

*"Any restriction shall respect the essence of the right that is being restricted. This means that restrictions that are extensive and intrusive to the extent that they void a fundamental right of its basic content, cannot be justified. In any case, a general exclusion of data subjects' rights with regard to all or specific data processing operations or with regard to specific controllers would not respect the essence of the fundamental right to the protection of personal data, as enshrined in the Charter. If the essence of the right is compromised, the restriction shall be considered unlawful, without the need to further assess whether it serves an objective of general interest or satisfies the necessity and proportionality criteria."*¹¹⁸

¹¹⁸ EDPB , par. 14.

In sum, if SURF implements the development goals identified in this Section, and the COs provide adequate information to their students and employees, the COs should be able to comply with their obligation to provide comprehensible access to the personal data relating to the use of EduGenAI if they receive a DSAR.

18.3 Right of rectification and erasure

Thirdly, data subjects have the right to have inaccurate or outdated information corrected, incomplete information completed and - under certain circumstances - personal information deleted or the processing of personal data restricted.

As assessed in [Section 15.2.3](#) there are 2 reasons why generative AI-systems can generate inaccurate personal data, and 2 more reasons why EduGenAI can generate inaccurate personal data, as a result of incorrect data in RAG-documents, and as a result of the pseudonymisation filter.

For the first two reasons, SURF and the COs have to rely on LLMs to rectify or erase inaccurate data. Other than that, SURF and the COs can take 4 measures to help data subjects correct inaccurate personal data relating to them. Additionally, users of EduGenAI can delete RAG-document with inaccurate personal data. Finally, users can delete parts of the chat history with inaccurate personal data. The effectivity of these measures will have to be tested in practice.

It does not make sense for COs to allow users to remove specific interaction data from the very limited usage logs generated by EduGenAI, as they may want to access these logs to detect violations of their generative AI policy.

In sum, SURF and the COs can comply with the right of rectification and erasure in EduGenAI, but not in the external LLMs.

18.4 Right to object to profiling

Fourthly, data subjects have the right to object to an exclusively automated decision if it has legal effects.

SURF commits to contractually guarantee that it does not use the personal data from the COs (admins or end users) for profiling purposes.

Therefore, this specific right of objection does not apply in this case.

18.5 Right to data portability

Employees have a right to data portability if the processing of their personal data is carried out by automated means and is based on their consent or on the necessity of a contract. As explained in [Section 12.1](#) the processing of personal data by EduGenAI on behalf of COs should generally be based on the necessity for the performance of a public task or necessity for a legitimate business interest of the COs. This means the right to data portability doesn't apply. However, if a user decides to consent to storage of their chat history on SURF's servers, the right does apply. Once SURF has achieved the development goal of building a Do It

Yourself data access tool, it should be relatively easy to ensure that the data are exported in a ‘structured, commonly used and machine-readable format’ (Article 20 GDPR).

Even if the right to data portability applies, COs may decide to invoke an exception from Article 23 of the GDPR. For example, in case the CO relies on the legal ground of necessity for the fulfilment of the (job) contract with teachers for the creation of a Persona, the exercise of the right to data portability is problematic in relation to Education-internal documents and data. And similarly with students’ chat histories (if stored on SURF’s servers), the right to data portability cannot be used to export confidential data and personal data relating to other data subjects.

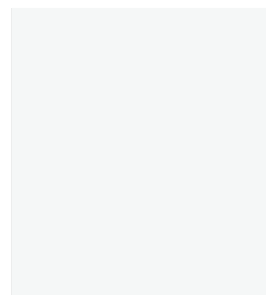
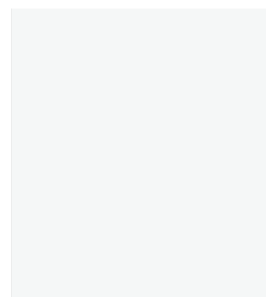
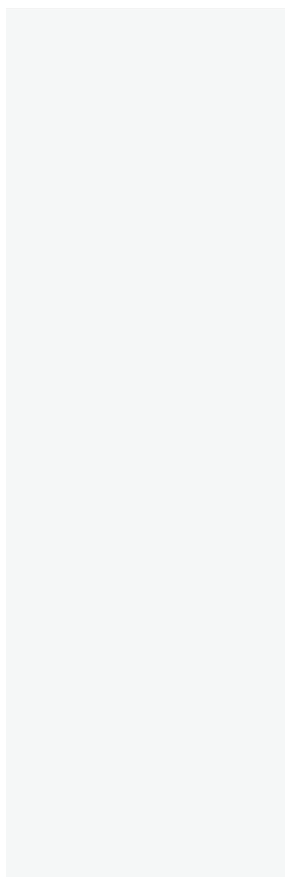
In sum, whether data subjects have a right to data portability, depends on the legal ground and assessment by the CO.

18.6 Right to file a complaint

Finally, education organisations as controllers must inform their employees and students about their right to complain, internally to their Data Protection Officer (DPO), and externally, to the Dutch Data Protection Authority (Autoriteit Persoonsgegevens). This should be part of the development goal of drafting a general Privacy Policy for EduGenAI.

In sum, based on the identified development goals for EduGenAI and for the A-Hub, COs will be in a position to honour the rights of data subjects. The right to correct inaccurate personal data is the hardest problem to solve for generative AI, but this is not unique for EduGenAI. As long as SURF and the COs commit as joint controllers to continuously evaluate and adopt any identified effective measures to correct incorrect data, they can arguably demonstrate compliance with their obligations to honour data subjects’ rights.

PART C



19 Introduction

This part concerns the description and assessment of the risks for data subjects. This part starts with an overall identification of the risks to the rights and freedoms of data subjects as a result of the processing of the five categories of personal data (Content, Account, Diagnostic, Support and Website Data). The risks will subsequently be classified according to the likelihood they might occur, and the impact on the rights and freedoms of the data subjects when they do.

20 Risks

20.1 Identification of risks

Below, a general distinction is made between the risks of the processing of metadata on the one hand, and the Content Data on the other hand. Subsequently, 12 specific data protection risks are identified, of which 10 relate to the Content Data, and 2 to the other categories of personal data.

Generally speaking, data protection risks can appear in the following categories:

- inability to exercise rights (including but not limited to privacy rights)
- inability to access services or opportunities
- loss of control over the use of personal data
- discrimination
- identity theft or fraud
- financial loss
- reputational damage
- physical harm
- loss of confidentiality
- re-identification of pseudonymised data or
- any other significant economic or social disadvantage¹¹⁹

These risks have to be assessed against the likelihood of the occurrence of these risks (the probability) and the severity of the impact.

The UK data protection commission ICO provides the following guidance:

¹¹⁹ ICO, How do we do a DPIA?, Step 5: How do we identify and assess risks?, URL: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/accountability-and-governance/data-protection-impact-assessments-dpias/how-do-we-do-a-dpia/>.

“Harm does not have to be inevitable to qualify as a risk or a high risk. It must be more than remote, but any significant possibility of very serious harm may still be enough to qualify as a high risk. Equally, a high probability of widespread but more minor harm might still count as high risk.”¹²⁰

In order to weigh the severity of the impact, and the likelihood of the harm for these generic risks, this report combines a list of specific risks with specific circumstances of the specific investigated data processing.

20.1.1 Risks requiring further assessment or specific contextual evaluation

This DPIA identifies core data protection risks related to the EduGenAI service. However, the broader societal impact of using generative AI, including risks of bias, discrimination, fairness, and potential 'function creep' (unintended expansion of use), requires ongoing attention. COs are advised (see Part D, risk 1) to conduct specific Human Rights Impact Assessments (HRIAs) or similar ethical reviews for their intended applications and regular audits of usage.

20.2 Assessment of risks

20.2.1 Loss of control through overreliance on accuracy personal data

EduGenAI, like all services that provide access to LLMs, puts users at risk of becoming overly reliant on the output of the LLMs to create text and references to correct/existing sources of information. This is a risk inherent to all generative AI-models, as described in SURF's public DPIA on Microsoft Copilot 365.¹²¹

EduGenAI's proposed design and development goals will include nine elements that can help prevent overreliance.

1. Change the warning text about inherent inaccuracy risks to users every 30 seconds or every 10 prompts: different text, different font and colours etc.
2. Show two replies to a prompts from two different LLMs to visually remind users that they are not using a search engine, but a text completion engine.
3. Show the snippets of text used by the AI-model when referring to sources uploaded by the user (RAG) (instead of referring to the entire document, which may be hallucinated).
4. Apply the (on-premises) Presidio filter to mask personal data before sharing prompts and RAG-documents with cloud LLMs and search engines. Allow COs to disable this filter if necessary for specific tasks.
5. Set the hardcoded filter (TopP) for reliability to a very high percentage (See [Section 1.1.9](#)). If no tokens can be found in the immediate vicinity, the AI-model will always answer 'I don't know'. EduGenAI will offer a user in the personalisation settings the option to change this filter, but by default it will be set to a high reliability.

¹²⁰ Idem.

¹²¹ SURF, DPIA Microsoft 365 Copilot for Education, Public version, 17 December 2024, URL: <https://www.surf.nl/files/2024-12/20241218-dpia-microsoft-365-copilot.pdf>.

6. Strip all metadata from prompts before sharing the prompts with third parties, only use a pseudo randomly generated trace ID per request (not per user). This step can assist users to look up more recent data in search engines without incurring new data protection risks.
7. Develop and check the adequacy of a Responsible AI filter that complies with European Human Rights together with the COs. Allow COs to disable the content filter for specific tasks.
8. Enable users to file reports about inaccurate personal data.
9. Ask users to consent to store their chat histories and use the pseudonymised chat histories for accuracy and quality research. Based on the outcomes of the research, SURF can recommend specific LLMs for specific use cases

Even though the impact of inaccurate personal data through overreliance on AI can be high, these mitigating measures ensure that the probability of occurrence is reduced to low. This means the risks for data subjects can be qualified as low.

20.2.2 Inability to exercise subject access rights Diagnostic Data

As described in [Section 3.6](#) and assessed in [Section 16.2](#) EduGenAI and SURF's AI-Hub have not yet implemented a procedure or tool to provide for data subject access to logs with Diagnostic Data.

Absent such a procedure, the probability of occurrence of incomplete access to the Diagnostic Data is highly likely. The impact of an access limitation is high, because access to personal data is a fundamental right. Data subject access is a building block of the GDPR as starting point for data subjects to exercise their other rights.

However, based on this DPIA SURF has identified the relevant personal data it has to provide access to. SURF plans to provide all data listed in [Table 1](#) relating to the use of EduGenAI in reply to a DSAR. SURF also plans to provide access to the Diagnostic Data relating to the RAG documents and the database in the AI-Hub, with the metadata such as owner ID about the uploaded documents. As described in [Section 3.3.3](#) the AI-Hub only processes the API-key, and no longer the names of the admins in the dashboard with usage/cost information. The AI-Hub also has access to identifying data of the CO managers, but as described in [Section 3.2](#) the processing of these Account Data is out of scope of this DPIA, because the processing depends on the CO implementation and the use of SRAM. Therefore this processing is not relevant for the analysis of the ability of admins to exercise their right to data subject access.

This DPIA assumes SURF will follow the identified development goals to (1) develop a DIY Data Subject Access tool that allows users to download their chat history (if donated to EduGenAI), and provide access to the Diagnostic Data registered in the back-end and (2) provide a dedicated contact method for additional questions and requests from users. Once SURF has implemented these measures, the probability of a data access limitation will be remote. Even though the impact on data subjects of such a limitation would be high, the risks for data subjects can be qualified as low.

20.2.3 Inability to delete or correct inaccurate Content Data

As assessed in [Section 15.2.3](#) the LLMs used by EduGenAI may generate Content Data about data subjects that are inaccurate. The generation of inaccurate data about data subjects is a common issue across all LLMs. Section 9 describes two origins of incorrect personal data in generative AI responses:

1. The large language models are trained on publicly available data, and the training data may contain inaccurate or outdated data.
2. The models may deterministically output incorrect data.

EduGenAI is designed to augment prompts with additional content from RAG-documents uploaded by users. This can lead to two more sources of inaccuracy:

3. RAG-documents may themselves contain inaccurate personal data.
4. EduGenAI may introduce inaccuracies during the process of pseudonymisation.

The ability to correct inaccurate personal data is a fundamental right under the GDPR. While EduGenAI provides organisations with the ability to remove uploaded RAG documents that contain inaccurate data, or are leading to incorrect outputs, EduGenAI does not yet have the ability to prevent third party LLMs (both on-premises and in third party clouds) from generating inaccurate personal data. EduGenAI also does not have the ability to change the outputs of LLMs to represent accurate data.

As concluded in [Section 9.2](#), one of EduGenAI's development goals is to include an inaccuracy reporting option for end users and teachers if they discover inaccurate personal data.

As described above, in [Section 17.2.1](#), EduGenAI and the COs have to take many measures to prevent overreliance from the users on the accuracy of the outputs of generative AI-models. These measures can effectively prevent users from blindly copying inaccurate personal data in their work or study tasks.

To further lower the probability of the use of incorrect personal data, EduGenAI can take four mitigating measures.

1. Forward reports about inaccurate data to the LLMs, and agree on a procedure with the LLMs that they prevent regeneration of reported inaccurate personal data.
2. Perform quality and accuracy research with the COs, and develop guidance on the best type of model for specific tasks.
3. Help COs develop mini GPTs based on accurate personal data, and help COs fine-tune those models in case of inaccurate personal data.
4. Find or develop a capable content filter for Dutch language that can run on premises.

The COs must inform end users about the options to correct personal data, and must also set standards for the preprocessing of RAG-documents.

The right to correct inaccurate data is a fundamental part of the GDPR, and the impact of incorrect data may be very high (see the examples in [Section Error! Reference source not found.](#)). However, if EduGenAI

applies the recommended measures, the probability that incorrect personal data are further processed outside of the EduGenAI dialogue can be lowered to remote. If the COs also actively instruct users to work with the best practices guide, the risks for data subjects can be qualified as low.

20.2.4 Loss of control through overreliance on personal data masking filter

EduGenAI proposes to use the (on-premises) Presidio filter to remove identifiable personal data from prompts and RAG documents, as described in [Section 1.1.7](#). However, this filter is not completely effective and COs should combine this filter with additional organisational measures. It is plausible that end users share sensitive and special categories of data through prompts and RAG-documents. Even if the filter effectively removes the name of a user, certain unique characteristics related to special categories of data may make that person identifiable, such as the only person in a data collection with one leg.

If a CO exclusively relies on the Presidio filter to mitigate all data protection risks, and does not implement additional measures, it is highly likely that the COs inadvertently let SURF and third party LLMs process sensitive and special categories of data in the Content Data.

However, both SURF and the COs can take mitigating measures.

SURF can create a procedure for end users to report inadequate masking, perform research on the effectivity, and publish guidance for the COs about common masking mistakes.

This can be accomplished with the measures described as EduGenAI development goals in [Section 1.1.7](#):

- Alert users to report inadequate masking to EduGenAI.
- Adopt a policy to prevent processing of sensitive and special categories of data in RAG-documents if not necessary for research purposes.
- Help SURF improve the adequacy of the Presidio filter based on research on the CO's own filtered chunks.

Assuming the COs and SURF will take these additional measures, the probability of a loss of control can be lowered to remote. Even though the impact of unintended reidentification can be high, the risks for data subjects can be qualified as low.

20.2.5 Loss of control due to aggressive personal data masking filter

EduGenAI uses Microsoft's Presidio filter to attempt to remove personal data from user prompts and uploaded documents. This filter has options to replace personal data with anonymous identifiers such as '<PERSON>'.

Application of such a filter has clear data protection benefits, but automatic replacement may also introduce a new data protection risk. The automatic replacement may lead to a lower quality output if names are unnecessarily converted to <PERSON>. For example, if every name is converted to the same identifier, then the user can no longer recognise different data subjects with different characteristics in the output.

COs may want to actively disable filtering for specific research purposes, for example, if a teacher wants to have a collection audio interviews transcribed and used to create prompts, or if they try to assess disinformation effects or biases based on the training data in LLMs.

As joint controllers for the application of the personal data masking filter, EduGenAI and the COs have to develop documentation and settings. The impact of incorrect pseudonymisation can be very high, if EduGenAI users do not detect wrong or wrongfully missing personal data in generated texts such as summaries, or if they attribute quotes or papers to incorrect authors because of the pseudonymization process.

Assuming SURF and the COs will develop adequate documentation and warnings, and allow COs to tweak or disable the Presidio filter in specific circumstances where identifiability may be necessary, the probability of occurrence of this loss of control is remote. Therefore the risks for data subjects can be qualified as low.

20.2.6 Loss of control due to content-filtering (LLMs and EduGenAI)

All providers of popular Language Models apply some kind of content filtering to prevent generation of harmful or unlawful content. Even though Microsoft allows Education customers to disable the filtering to detect and prevent the output of harmful content, Microsoft still applies some other filters (see Figure 9). These filters are opaque, and providers do not publish accuracy measurement reports. The filtering can lead to the omission of essential data, or, if ineffective, to a negative impact from harmful content. Due to the lack of transparency the COs cannot assess if the content filters from the LLM-providers comply with European human rights.

SURF and the COs can lower the probability of this loss of control by disabling content filters where possible, and by applying a self-developed content filter. SURF and the COs should collaborate to perform regular quality and accuracy measurements to continue to improve the filtering. SURF should also make the content filtering as transparent as possible for end users, without inviting users to gamify. To prevent over filtering, SURF should give COs the option to disable content filtering for specific Personae.

If SURF and the COs take these mitigating measures, such as a self-developed and continuously audited content filter, they can lower the probability of incorrect content-filtering to remote. Even though the risks of incorrect RAI-filtering can be very high, in the form of discrimination or the lack of bias-detection, the risks for data subjects can be qualified as low.

20.2.7 Loss of control through unauthorised access to Content Data by cloud LLMs

EduGenAI can enable end users to send prompts to LLMs in third party clouds. These services involve data transfers to Microsoft's Open AI on Azure and to other services, such as Claude from Anthropic, Llama from Meta or the French Mistral. As explained in [Section 8.1](#) use of OpenAI on Azure involves a data transfer of Content Data to the USA and potentially 30 third countries. Data transfers for the other LLMs that may become accessible as cloud LLMs such as Claude and Llama, are unknown, but are likely to include transfers to the USA.

If the adequacy decision between the EU and the USA is annulled or invalidated, COs cannot take adequate transfer risk mitigating measures such as encrypting the data with a self-controlled key. However, EduGenAI is designed to allow COs to choose and change the available LLMs. COs can decide to limit access to EU-based cloud LLMs and, or exclusively to the on-premises models hosted in SURF's AI-Hub (as soon as SURF makes these available).

Even though EduGenAI offers a choice to only use the on-premises models, in practice most COs may still want to use cloud models. Until GPT-NL (or a similar initiative) offers tools for COs to use the Dutch language, COs need to assess if Llama and other open-source models provide sufficiently good results in Dutch for specific use cases, compared to those offered by third parties such as ChatGPT.

COs and EduGenAI also need to assess for specific use cases if the performance of the on-premises Llama models is satisfactory for the Dutch language. Llama cannot officially support content filtering in Dutch, and thus EduGenAI must currently rely on RAI filtering by Microsoft. The AI-Hub prioritises finding an alternative content filter to the RAI filter that supports the Dutch language and can be run on-premises.

If the COs allow use of cloud LLMs, they should instruct users to only access these services for very specific, non-sensitive queries in Dutch.

Assuming COs will apply the recommended technical measure of disabling access to LLMs provided by providers in third countries (potentially including all providers from the USA), and in case the use of a cloud LLM is nonetheless inevitable, choose an EU-based LLM, or warn students, the probability of unauthorised access in third countries can be lowered to remote. Even though the impact of such access to personal data in Content Data may be very high, the risks for data subjects can be qualified as low.

20.2.8 Loss of control through unspecified retention periods

As hosting provider of EduGenAI and as the hosting provider of the local LLMs SURF will process personal data in a role as data processor for most of the personal data, except for the Content Data, when SURF and the COs will be joint controllers.

As processor, SURF has to ask the COs for instructions about the retention period for the different types of logs with Diagnostic Data (related to end user activities in the EduGenAI back-end, and related to admin activities in SURF's AI-Hub). As quoted in [Section 11.1](#) SURF's AI-hub developers have determined a maximum retention period of 30 days for the CO admin logs. As described in [Section 11.2](#) SURF has to determine if it needs to store the EduGenAI logs with end user activities for 30 or for 90 days to achieve legitimate purposes such as monitoring application performance, ensuring availability, technical troubleshooting, providing support and protection against abuse. However, if users delete a dialogue or all chats, the relating Diagnostic Data are also immediately deleted (see [Section 3.3.1](#)). This is an important mitigating measure that puts control in the hands of end-users. As analysed in [Section 15.2.4](#) even a maximum retention period of 90 days falls well below the recommendation from the French data protection

authority CNIL to retain logs between 6 and 12 months.¹²² Hence the impact on data subjects of the maximum data retention period of 90 days on data subjects can be qualified as low.

As processor, SURF also has to determine an adequate retention period for both types of support tickets: related to EduGenAI and related to the AI-hub. SURF also has to determine an adequate retention period for the cookie set by EduGenAI that will be used to help users exclusively store the chat history in their browser. Absent a specified retention period, a long retention period can have some impact on users. The impact of loss or unauthorised access (for example, if the end user device breaks down or is hacked) becomes higher if the data are retained for a longer period, because the dataset increases over time.

As joint controllers, SURF and the COs have to determine an adequate retention period for the storage of some of the Content Data, in particular for the RAG-documents uploaded to Personae, and the storage of (voluntarily provided) pseudonymised chat histories for quality and accuracy research. There is a reasonable probability that the RAG-documents include sensitive and special categories of data. These data may become inaccurate over time, or the CO may no longer have a valid legal ground for the data processing. Absent a defined storage period, the impact of such processing is high. As explained in Section 1.1.9, the COs can determine the lifetime of a Persona. Both users and admins can delete RAG-documents uploaded to a Persona. However, if the COs do not create and apply a retention policy for the Personae and the documents uploaded to a Persona, EduGenAI will store these documents indefinitely, until the CO terminates the contract with SURF.

Since the specification of specific retention periods is essential for compliance with the GDPR principle of data minimisation, this DPIA assumes that SURF and the COs will determine and enforce adequate retention periods before roll-out. This measure will reduce the probability of loss of control due to excessive data retention to remote. Therefore, the risks for data subjects can be qualified as low.

20.2.9 Loss of control through processing by SURF as independent controller

As listed in Section 5.3 and explained in Section 6.5 SURF necessarily has to process some personal data it obtains as data processor in a role as controller. This applies to five purposes:

1. Use a cookie to prevent central storage of the chat-history.
2. Create aggregated non-personal analytic data from data with pseudonymized identifiers to calculate a reasonable average usage, to support billing, and to map excessive usage.
3. Send invoices to the COs, financial bookkeeping
4. Calculate statistics related to use of LLMs / compute for internal reporting and business modelling, such as technical infrastructure forecasting, and climate impact reporting.
5. Comply with legal obligations.

¹²² CNIL, 18 November 2021 (in French), La CNIL publie une recommandation relative aux mesures de journalisation, URL: <https://www.cnil.fr/fr/la-cnil-publie-une-recommandation-relative-aux-mesures-de-journalisation>.

With regard to the first four purposes, SURF must ensure that data subjects are informed what data SURF processes for what purposes, for how long, and provide available data in reply to a DSAR.

With regard to the fifth purposes, there is a reasonable possibility that SURF will be compelled to disclose personal data related to the use of EduGenAI usage to government authorities. For example, in the context of a suicide attempt or (hate) crime committed by a person that may have asked EduGenAI for advice. If a user has chosen to store the chat history on SURF's servers, EduGenAI may be requested to disclose.

As recommended in [Section 12.2](#) SURF needs to establish without a trace of doubt that it has to comply with a specific legitimate order and cannot redirect the order to the CO. For the data processing to be necessary, SURF also needs to establish procedures to ensure that only strictly necessary data are disclosed.

Even though the AI-Hub does not process identifiable data from end users, SURF needs to take the risk into account that a specific user from a CO may be reidentifiable for the CO based on the user id, uploaded RAG documents and a unique pattern of usage based on time and model settings. Hence, even if a user only stores the chat history in cookies in the browser, this cannot completely prevent data processing by SURF.

SURF can provide assurances to the COs that as a processor it will use all avenues to prevent disclosure, by including the suggested specific list of authorised further processing purposes in the data processing agreement. Privacy Company recommends including the procedure for legal process in the data processing agreement, to ensure SURF as a processor will not take decisions about disclosure, and to commit to publishing statistics about the number of received and denied requests for disclosure.

Assuming SURF will commit to take the recommended steps, the probability of occurrence of unauthorised disclosure can be lowered to remote. In that case, the risks for data subjects can be classified as low, in spite of the potentially very high impact.

20.2.10 Loss of control by unauthorised access in third countries

The current version of EduGenAi relies on the use of Microsoft Azure hosting services. This includes services such as the OpenAI LLMs hosted on Azure, the preprocessing of the RAG documents, and the storage of other Content Data, besides the Account, Diagnostic, Support and Website Data.

As described in [Section 8.1](#) Dutch Education customers from Azure can choose to store Content Data in the EU (in Microsoft Azure data centres in Amsterdam and Ireland). Microsoft ensures that it will also process the Diagnostic Data in the same region, as well as Professional Services Data. SURF can also choose westeurope as zone for the processing of the OpenAI prompts and replies on Azure. Microsoft calls these choices for European data residency the EU Data Boundary.

However, in spite of this EU Data Boundary, Microsoft continues to transfer personal data from Azure, including OpenAI on Azure, in three ways: (i) incidentally, when an engineer has to manually solve a problem or when a customer files a support request, (ii) structurally to the USA, for three closely related security purposes, and (iii) because of the use of a global Content Delivery Network.

Based on Microsoft's participation to the EU US Data Privacy Framework, SURF and the COs can currently rely on an adequate level of data processing in the USA. The EU US DPF also applies to (incidental) onward data transfers by Microsoft to its sub processors in 30 so called 'third countries' without adequacy decision from the European Commission and to the global CDN. Legally, based on the adequacy decision from the European Commission, the impact of disclosure should be qualified as low to medium (not in practice though). Even if the probability of disclosure was high (and Microsoft provides many assurances to the contrary), the current risks of the data transfer for data subjects whose personal data are part of the Content Data processed by OpenAI LLMs on Azure have to be qualified as low.

However, in view of measures taken and announced by the new president of the United States, SURF and the COs have to seriously consider the probability that the EU US Data Privacy Framework will be annulled or suspended. In that case as joint controllers SURF and the COs have to perform a Data Transfer Impact Assessment for the use of the OpenAI models on Azure.

If the USA becomes a third country, SURF and the COs cannot rely on the SCC they already have in place with Microsoft. They will have to analyse the probability that Microsoft is forced to disclose personal data in the Content Data to government authorities, in contravention of the GDPR. Based on the guidance of the EDPB, they have to take encryption measures that prevent Microsoft or any third party from accessing the personal data. There are only two known technical measures: anonymisation or encryption with an exclusively self-controlled key. These measures are not available for dialogue with the OpenAI LLMs (or for other US based LLM providers such as Meta and Anthropic).

SURF and the COs need to anticipate a potential high data transfer risk in case the EU US DPF is annulled or invalidated. Based on the guidance from the EDPB, the impact of disclosure of personal data to government authorities in third countries has to legally be assessed as (very) high, especially in case of sensitive and special categories of personal data. Since there are no known mitigating measures available to reduce the probability to remote, the risk of the transfer of Content Data via Microsoft if the EU US DPF is annulled will likely be high.

20.2.11 Loss of control through lack of backups / inability to exercise data portability

Chat history and RAG documents are the primary forms of Content Data processed by EduGenAI. The RAG documents are stored on EduGenAI servers or within the SURF AI-Hub (as discussed in [Section 1.1.4](#), the documents will not be stored in both locations at once). However, the chat history will be stored by default on the end user device (in cookies). Users will have the option to ask SURF to store the chat history remotely, on SURF's EduGenAI servers, and additionally, provide consent to SURF to store the pseudonymised chat history for quality and accuracy research purposes.

If users choose to store the chat history in their browser, they are fully in control over the retention period, and can exercise their right to data portability. SURF will not be able to create backups of the chat history, unless a user explicitly consents to store a copy on SURF's servers for research purposes.

The choice EduGenAI made to store the chat history in the browser by default, and not on EduGenAI's servers is a fundamental privacy by design choice, following the analysis that the chat history is likely to

contain sensitive and special categories of data. However, this design choice can also have negative consequences. The end users controls for data in cookies are generally limited: delete all stored cookies at once, or manually browse through a long list of historical cookies. It is highly likely that the majority of users never uses browser controls. If users decide to clean up their browser, it is plausible that they will clear all cookies at once, across all websites and services. Such a clean-up would also (unintentionally) remove their chat history.

The use of a cookie as key mechanism to give users control over their chat history may hence also have the opposite effect of incentivising them to avoid clearing tracking cookies to avoid losing their chat histories. For privacy aware users that wish to prevent the use of a cookie, the alternative is to store their chat histories on EduGenAI servers, which in turn opens the end users' chat history to scrutiny by administrators and EduGenAI developers. A second incentive for central storage is security: browsers on end user devices are generally much less secure/less monitored than central cloud servers.

This means the user's need for data confidentiality (chat history inaccessible for CO admins and possibly teachers in case of Persona usage), conflicts with the user's ability to ensure data integrity and availability.

As described in [Section 1.1.2](#) SURF and the COs must clearly educate users about the possible negative consequences of the default choice to only store the chat history in the browser. To comply with the right to data portability, without preventing users from deleting all cookies from their browser, EduGenAI needs to help users export the chat history from their cookies to a (secure) server (see [Section 3.6](#)).

If SURF and the COs take these two measures, the probability of the loss of data can be reduced to remote. The (unintentional) deletion of the chat history stored in cookies may have some impact on users if they for example cannot reproduce a dialogue to convince their teacher that they have only used the dialogue for inspiration. Privacy Company cannot think of examples where deletion of a chat history leads to serious harm in the context of EduGenAI. Users should still have access to their RAG-documents, or original audio or video recordings, and can theoretically ask EduGenAI to perform the same tasks. This means the deletion does not make the personal data unavailable. Even though there may be some impact of unintentional deletion, if EduGenAI applies the recommended measure, the risks for data subjects can be qualified as low.

20.2.12 Loss of control due to orphan RAG-documents

As explained above, in [Section 17.2.10](#), EduGenAI plans to implement local storage of the chat history in browser cookies. Different from server-side retention, where all RAG-documents (outside of Personae) will automatically be deleted if a users chooses to 'delete all chats', it is unclear what happens with the RAG-documents after cookie-deletion. They may turn into orphan-documents that will be stored for 6 months after the user last signed in.

Documents uploaded as RAG as part of the individual chat history are likely to contain sensitive and special categories of data. The impact of a loss of control (other than deletion) would automatically be high.

EduGenAI already provides explicit controls for end users to delete RAG documents. SURF can further lower the probability of occurrence of this risk to remote by realising two combined development goals:

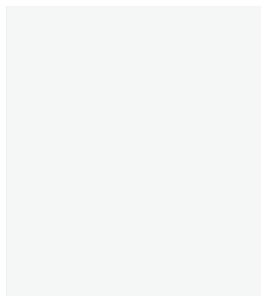
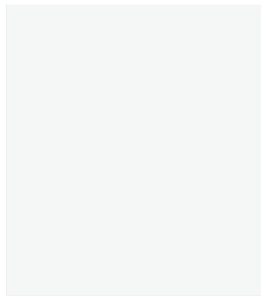
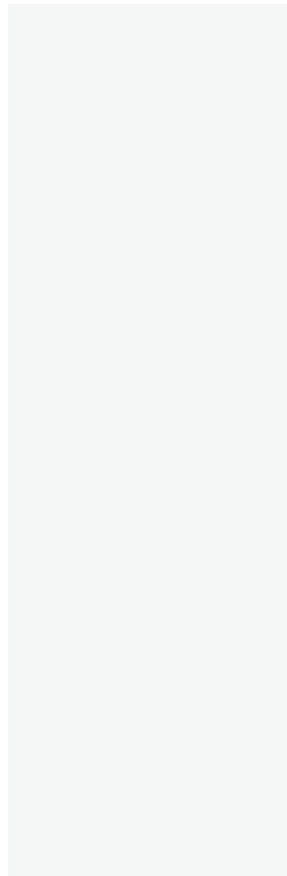
- 1. Clearly educating users about the downsides of local cookie-storage.
- 2. Offering an easy import and export of the chat history in the cookie.

The AI-Hub can facilitate these development goals by providing EduGenAI with an endpoint that can be used to delete RAG documents.

If EduGenAI takes the recommended measures, the risks for data subjects can be qualified as low.

Severity of impact			Low risk 1, 2. 3. 4. 5. 6. 7. 8. 9. 10	High risk	High risk
Some impact			Low risk 11	Medium risk	High risk
Minimal impact			Low risk	Low risk 12	Low risk
Likelihood of harm (occurrence)			Remote	Reasonable possibility	More likely than not

PART D



21 Introduction

The following section contains a table of the mitigating technical, organisational and legal measures that need to be taken by SURF and/or the COs to reduce or solve the identified risks. This DPIA was written in an early development stage of EduGenAI. During the DPIA many development goals were identified and discussed to mitigate any potential high risks.

The risks are calculated by multiplying the probability of occurrence with the impact on end users if the risk were to materialise. However, if SURF and the COs apply the recommended measures, the probability of occurrence is zero or very low. The first 10 risks would cause serious harm to users. Risk no. 11 would cause some impact, while risk no. 12 would only have minimal impact. In all cases, when the impact is multiplied by the probability of occurrence, the outcome is a low risk.

22 Risk mitigating measures

22.1 Measures to be taken to mitigate risks

No	Risk	Measures EduGenAI	AI-Hub	Measures COs
1.	Over reliance on EduGenAI	Apply the (on-premises) data masking filter to mask personal data before sharing prompts and RAG-documents with cloud LLMs and search engines. Allow users to disable this filter for Persona if necessary for specific tasks.	N/A	Decide when users can disable the personal data masking filter for Personae.
		Change the warning text about inherent inaccuracy risks to users every 30 seconds or every 10 prompts: different text, different font and colours etc.		Decide on the content and frequency of alerts presented to end users that they must verify the accuracy of an answer.
		Show two replies to a prompts from two different LLMs to visually remind users that they are not using a search engine, but a text completion engine.		
		Continue to show the snippets of text used by the AI-model when referring to sources uploaded by the user (RAG) (instead of referring to the entire document).		Inform users about the consequences if they change the default setting of a high reliability of the answers, by changing the 'Temperature' and TopP for Personae.
		Set the filter for reliability by default to a very high percentage. If no tokens can be found in the immediate vicinity, the AI-model will always answer 'I don't know'.		
		Develop and check the adequacy of a Responsible AI filter that complies with European Human Rights together with the COs. Allow COs to disable the content filter for specific tasks.		Perform a HRIA or FRAIA to assess risks for human rights in relation to the use of generative AI (such as bias/discrimination)

		Strip all metadata from prompts before sharing the prompts with third parties, only use a pseudo randomly generated trace ID per request (not per user). This step can assist users to look up more recent data in search engines without incurring new data protection risks.		
		Develop a procedure for end users and teachers to report inaccurate personal data relating to them.		
2.	Inability to exercise data subject access rights Diagnostic Data	Implement a dedicated contact method for data subject questions and requests from users.	Allow CO admins to export their personal activity data.	Inform end users about the logging and how to request access to their Diagnostic Data.
			Prevent logging of the username of the API key owner.	
		Implement a Download Your (Diagnostic) Data tool.	Develop a user friendly way to know whom to contact in the case of errors.	
			Create dashboards with benchmarks for the COs to show many tokens they have used, or what the environmental impact was.	
3	Inability to correct inaccurate Content Data	Apply the measures to prevent overreliance on AI, to lower the probability that inaccurate personal data are blindly copied.	N/A	Inform users about the procedure to request correction of personal data relating to them.
		Ask users for consent to centrally store their chat histories, and separate consent to use the pseudonymised chat histories for accuracy and quality research.		Allow users to request review and potential deletion of Personae that process inaccurate personal data relating to them.
		Forward reports about inaccurate data to the LLM providers, and agree on a procedure with the LLM providers that they prevent regeneration of reported inaccurate personal data.		Set standards what type of documents and data can be used for grounding.
		Perform quality and accuracy research with the COs, and develop guidance on the best type of model for specific tasks.		Inform users about procedure to report inadequate masking.
		Implement additions to the content filter that consist of the following set of escalating steps for a given scenario: 1. Add corrections in the system prompt 2. Add a filter process to remove incorrect data		

		3. Fine-tune models to correct inaccurate data.		
		Create a procedure for end users to report inadequate masking.		
4	Loss of control through overreliance on personal data masking filter	Perform research on the effectivity of the (locally hosted) Presidio data masking filter: consider the use of other tools.	N/A	Adopt a policy to prevent the processing of sensitive and special categories of personal data in RAG-documents if not necessary for research purposes.
		Enable COs to upload documents, disable the data masking filter for specific tasks, and get access to the filtered chunks in human-readable form.		Adopt a policy to prevent the processing of sensitive and special categories of personal data in RAG-documents if not necessary for research purposes.
		Enable COs to tweak the filter, relating to the typical data they process which may not be adequately recognised by the data masking filter.		Adopt a policy to prevent the processing of sensitive and special categories of personal data in RAG-documents if not necessary for research purposes. Help SURF improve the adequacy of the Presidio filter based on research on the COs own filtered chunks.
		Publish guidance for the COs about mistakes the filter can make, based on the research.		
		Work with the COs to develop documentation and settings for the masking filter.		Work with SURF to develop documentation and settings for the masking filter.
				Use future options to tweak the filter
				Work with SURF to develop documentation and settings for the masking filter.
5	Loss of control due to aggressive personal data masking filter	Take the relevant measures to prevent overreliance on AI (especially the first 3).	N/A	Draft a policy when users can disable the content filter for specific Personae.
		Develop a content filter with the COs that fully respects European Human Rights.		Draft a policy when users can disable the content filter for specific Personae.
6	Loss of control due to content filtering (LLMs and EduGenAI)	Make the content filtering as transparent as possible, without inviting gamification.	Be responsive to requests to disable content filtering where relevant.	Help SURF develop the content filter based on regular quality and accuracy measurements.
		Allow users to disable the content filter per Persona.		Select locally hosted models as the default for the CO.
		Develop a content filter that respects European human rights with the COs.		Select locally hosted models as the default for the CO.
7	Unauthorised access to Content Data by cloud LLMs and search engines	Select locally hosted models as the default for the CO.	Add more on-premises open source models (next to Llama).	Select an EU-based LLM if the quality of the local LLMs for the Dutch language is not high enough.
		By default store the chat history in the browser of the user, unless users consent to storage on SURF's servers.	Enable COs to choose to send requests to embedding endpoints to on-premises models.	Help SURF develop a content filter that respects European human rights

			Convert documents into embeddings on-premises.	Determine a retention policy for Personae and associated RAG-documents (SURF will delete after 13-24 months inactivity).
		Implement RAG without the use of third party services by sending embeddings back to COs to manage text search themselves, and compute embeddings with on-premises LLMs.	Use a local instance of a personal data masking filter (such as the open source Presidio) for the removal of personal data from prompts and uploaded documents	Determine a retention policy for Personae and associated RAG-documents (SURF will delete after 13-24 months inactivity).
		Choose privacy friendly search engines such as Ecosia, DuckDuckGo or in the future eu-searchperspective.com.	Add access to GPT-NL when available and affordable.	Determine a retention policy for Personae and associated RAG-documents.
			Locally host the content filter.	
8	Loss of control through unspecified retention periods	Ask users for consent to centrally store their chat histories, and separate consent to use the pseudonymised chat histories for accuracy and quality research.	Store the CO-admin logs with the IP-addresses for 30 days.	Help SURF as joint controller to Develop a specific EduGenAI privacy policy for users (admins, teachers and students).
		Determine an adequate retention period for the pseudonymised chat histories for research purposes.		Help SURF as joint controller to Develop a specific EduGenAI privacy policy for users (admins, teachers and students).
		Determine the retention period for RAG-documents uploaded to Personae (13-24 months inactivity)		Help SURF develop a EULA and/or Acceptable Use Policy to warn students not to use the tool for unlawful purposes, and warn about for example rate or size limitations
		If cookies are used to store the chat history: decide on the expiry date of cookies and inform users.		
		Implement specific retention periods for support tickets, the storage of the feedback 'likes', and the logs with Diagnostic Data about user activities (30 or 90 days).		
		Include procedure in the data processing agreement how SURF will deal with requests for disclosure from government authorities.		
9	Loss of control through processing by SURF as controller	Publish statistics about requests for compelled disclosure, and how many requests were granted.	Implement encryption at rest of the database that contains RAG-documents in such a way that each CO has its own privacy encryption keys.	Help SURF develop a EULA and/or Acceptable Use Policy to warn students not to use the tool for unlawful purposes, and warn about for example rate or size limitations.
		Document what personal data SURF processes as controller, with retention periods.		Help SURF develop a EULA and/or Acceptable Use Policy to warn students not to use the tool for unlawful purposes, and warn about for example rate or size limitations.
		Help the COs draft privacy policy, AUP and copyright policy as joint controller		Perform a Data Transfer Impact Assessment if the EU US DPF is invalidated.

		Anticipate on the invalidation of the EU US Data Privacy Framework with regard to OpenAI's language models on Azure, and Claude from Anthropic. This extends to the use of any LLM hosted on infrastructure owned by an American company. Alert the COs to the option to restrict access to LLMs hosted within or by entities from non-adequate third countries, should the transfer mechanisms be invalidated.		Educate users about the downsides of browser storage of the chat history.
10	Loss of control by unauthorised access in third countries	Anticipate on the invalidation of the EU US Data Privacy Framework with regard to OpenAI's language models on Azure, and Claude from Anthropic. This extends to the use of any LLM hosted on infrastructure owned by an American company. Alert the COs to the option to restrict access to LLMs hosted within or by entities from non-adequate third countries, should the transfer mechanisms be invalidated.	Make a locally hosted LLM or EU-based provider the default choice.	Perform a Data Transfer Impact Assessment if the EU US DPF is invalidated. Educate users about the downsides of browser storage of the chat history.
11	Loss of control through lack of backups / data portability	Inform new users about the trade-offs between cloud and local storage, and the option to change the storage location on a chat by chat basis. Warn users about the possible negative consequences of the default choice to only store the chat history on their own device. Offer a simple way for end users to export and import the chat history from their own device. Allow users to decide, per chat, which chats are stored in the SURF cloud and which are stored on their own device. Explore and implement alternatives to cookies for local storage, such as PGLite, to enhance data portability and user control over backups Encrypt the contents of the chat storage cookies.	N/A	Educate users about the downsides of browser storage of the chat history. Determine appropriate retention periods for Personae with their RAG-documents. Determine appropriate retention periods for Personae with their RAG-documents.
12	Loss of control due to orphan RAG-documents	Explore alternatives to for local storage of RAG documents and vector embeddings, such as PGLite.	Offer a delete endpoint for documents that EduGenAI can call.	N/A

22.2 Conclusions

If SURF and the COs effectively implement all the recommended measures, which include the successful realisation and thorough testing of the numerous development goals outlined in this document, there are no more known high risks related to the data processing via EduGenAI. As EduGenAI is a work-in-progress, this initial DPIA will have to be updated after the launch.

